DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN · ESPE
Ingeniería de Seguridad del Software

EJERCICIO PRÁCTICO 2

Aplicación para gestionar turnos de atención del IESS

Informe de diseño seguro

Requisitos, datos, gestión de turnos, riesgos, tecnologías y plan de verificación

Autor
Kenned Jhair Sigcha Palma

Fecha de revisión: 29 de octubre de 2026

Docente: Ing. Luis Enrique Jaramillo Montaño · NRC: 36892
Documento académico. Escenario ficticio; no describe sistemas reales del IESS.

La idea del proyecto en una página

Problema. Una unidad de atención del IESS quiere reducir filas y llamadas: los afiliados (y sus familiares) deben poder buscar, reservar, cancelar y reprogramar citas en línea. El cliente pidió, además, recopilar información médica y laboral, y eso es lo que este trabajo corrige.

Qué vamos a construir. Un prototipo local de un portal de turnos en Python con Django y PostgreSQL, con datos sintéticos y con las seguridades de producción:

- Cuentas con activación de un solo uso, clave con Argon2id, bloqueo progresivo y segundo factor para funcionarios.
- Búsqueda de turnos por especialidad, establecimiento y fecha; reservar, cancelar y reprogramar con las reglas RT-01 a RT-12 (una cita activa por especialidad, tope de citas, confirmación en 24 horas y política de inasistencias).
- Delegación para que un familiar ayude, con alcance solo de agenda, vigencia y revocación.
- Panel de recepción, panel de auditor y registro de auditoría de solo adición.
- Notificaciones neutrales (a archivo o consola) y servicios de afiliación y de agenda simulados, que fallan a propósito para probar el comportamiento.

Qué no hace. No guarda historia clínica, datos laborales, religión ni política; no entrega datos para entrenar IA; no usa SMS ni servicios reales del IESS.

Cómo funciona un turno, en seis pasos

1. El afiliado activa su cuenta con un código de un solo uso y elige su clave.
2. Busca disponibilidad y reserva; el servidor valida sesión, delegación, restricciones, afiliación y, al final, bloquea la franja en una transacción.
3. El turno queda RESERVADO y se confirma en 24 horas; si no, el cupo se libera.
4. Recibe un aviso neutral con fecha y hora, sin diagnóstico ni enlaces que abran información.
5. Asiste; recepción o el profesional registra la atención o la inasistencia.
6. Todo queda en un registro de auditoría que nadie puede editar.

Cómo se protege: tres tipos de control, varias capas

Capa	Preventivo	Detectivo	Correctivo
Acceso	Activación, Argon2id, segundo factor y límite de intentos	Alertas de inicios anómalos	Revocar sesiones y cambiar credenciales
Autorización	Permisos por rol, relación asistencial y objeto	Auditoría de accesos y consultas	Retirar privilegios
Datos y turnos	Restricciones únicas y transacciones; sin datos clínicos	Conciliación agenda y portal	Reasignar o revertir
Servicio	Límites, redundancia y despliegue gradual	Monitoreo de latencia y errores	Failover y restauración

Qué se muestra en clase. Para cada riesgo principal, una demostración de «antes y después»: la clave igual a la fecha de nacimiento, el cambio del identificador de un turno, la segunda reserva, la reserva simultánea, la edición de un registro de auditoría y la caída del servicio de afiliación. **Orden de trabajo:** informe, prototipo, pruebas y demostración.

Resumen ejecutivo

El portal de turnos debe resolver la agenda, no recopilar un expediente. De los 14 requisitos del cliente se **conservan 2, se modifican 9 y se eliminan 3**. Se analizaron 23 riesgos: sin controles, 6 son críticos, 16 son altos y 1 es medio; con los controles propuestos ninguno queda alto o crítico (13 medios y 10 bajos).

- **La salud queda fuera del turno.** Reservar una cita es un acto administrativo; el diagnóstico, los antecedentes y los resultados permanecen en el sistema clínico. La agenda solo guarda un motivo mínimo codificado.
- **La identidad deja de ser un dato público.** Cédula y fecha de nacimiento no autentican a nadie. La contraseña inicial derivada de la fecha de nacimiento se sustituye por activación con secreto de un solo uso, Argon2id, bloqueo progresivo y segundo factor para funcionarios.
- **Los familiares ayudan con una delegación verificada.** Alcance limitado a la agenda, vigencia, revocación inmediata y aviso al titular; nunca acceso a la historia clínica.
- **Los turnos tienen reglas contra el abuso.** Una cita activa por afiliado y especialidad, un tope de citas activas, reserva atómica con restricción única en la base de datos y una política de inasistencias proporcional: aviso, bloqueo temporal de la reserva en línea tras dos inasistencias consecutivas, justificación, apelación humana y canal presencial siempre disponible.
- **Los permisos siguen la función.** Cada rol ve lo que su tarea exige; el soporte trabaja con datos enmascarados y los registros de auditoría no contienen secretos ni se pueden editar.
- **Las notificaciones son neutrales.** Sin diagnóstico ni especialidad detallada y sin enlaces que abran información sin iniciar sesión.
- **La tecnología se elige con evidencia.** Se propone Django 5.2 LTS (soporte hasta abril de 2028) sobre PostgreSQL 18 (soporte hasta noviembre de 2030), con parcheo por severidad y exposición. Se contrastan Django, FastAPI/Starlette, Express y Spring Boot con CVE y CVSS publicados en 2025 y 2026.
- **El siguiente paso es un prototipo local con datos sintéticos** que implemente en código los controles de este informe, con una demostración de «antes y después» por cada riesgo principal.

Cómo se relaciona este informe con lo que pidió el profesor

Pedido	Dónde se atiende
Diagramas	Arquitectura y límites de confianza (§4.1), estados del turno (§3.2), validación de una reserva (§3.4), delegación de familiares (§4.4), mapas de calor (§7).
Análisis de riesgos	Matriz de riesgos con 23 filas, escala y procedimiento (§7).
CVE, CVSS y MITRE	CVE y CVSS reales de las tecnologías candidatas (§5.2), estimación de CVSS por riesgo con vectores calculados (§7.7), técnicas y tácticas de ATT&CK (§8).
Vulnerabilidades en frameworks y lenguajes	Historial de CVE, ciclo de vida y errores típicos de Python y Django (§5.2 a §5.5).
Justificar las tecnologías	Criterios, comparación ponderada, fechas de soporte y recomendación (§5).
Tipos de controles y contraste con el formulario	Controles preventivos, detectivos y correctivos; técnicos, administrativos y físicos; defensa en profundidad; y los controles de cada requisito de I01 a I14 (§9).
Un turno por persona y turnos consecutivos sin asistir	Reglas RT-01 a RT-12, parámetros y salvaguardas (§3).
Errores del usuario	Tabla de errores y diseño defensivo (§6).
Prototipo con seguridad de producción	Hoja de ruta módulo por módulo (§10).
Modelado de amenazas, evaluación de impacto y trazabilidad	Anexo A (STRIDE), Anexo B (borrador de evaluación de impacto, norma de gran escala) y Anexo C (matriz de trazabilidad).
Diseño técnico para el prototipo	Anexo D (inventario de endpoints), E (parámetros de seguridad), F (recuperación de cuenta), G (casos de abuso), H (ciclo de desarrollo seguro), I (reglas de detección) y J (claves y secretos).

Contenido

La idea del proyecto en una página . . . 2

Resumen ejecutivo . . . 3

Contenido . . . 4

Alcance, método y convenciones . . . 7

1. Depuración de requisitos . . . 7

1.1 Requisitos nuevos que se proponen . . . 8

2. Análisis de datos y fundamento normativo . . . 9

2.1 Diferencia entre gestionar un turno y gestionar información clínica . . . 9

2.2 Datos, finalidad, clasificación, necesidad, acceso y conservación . . . 9

2.3 Bases de licitud, menores y decisiones automatizadas . . . 10

2.4 Notificación de vulneraciones . . . 10

2.5 Normativa ecuatoriana aplicada y estado de verificación . . . 11

3. Gestión de turnos: reglas contra el acaparamiento y los turnos fantasma . . . 12

3.1 Tres problemas distintos . . . 12

3.2 Ciclo de vida del turno . . . 12

3.3 Reglas RT-01 a RT-12 . . . 12

3.4 Validación de una solicitud de reserva . . . 13

3.5 Política de inasistencias (parámetros propuestos) . . . 13

3.6 Diseño de datos para imponer las reglas . . . 13

4. Diseño propuesto . . . 16

4.1 Arquitectura y límites de confianza . . . 16

4.2 Recorrido de los datos . . . 16

4.3 Roles y permisos . . . 17

4.4 Representación de familiares . . . 17

4.5 Notificaciones . . . 17

4.6 Integraciones . . . 18

4.7 Capacidad, almacenamiento y disponibilidad . . . 18

5. Selección tecnológica justificada . . . 21

5.1 Criterios y comparación ponderada . . . 21

5.2 Evidencia: CVE y CVSS publicados en 2025 y 2026 . . . 22

5.3 Ciclo de vida y fechas de soporte . . . 24

5.4 Recomendación de pila y justificación . . . 24

5.5 Configuración segura del framework y errores típicos . . . 25

5.6 Gestión de parches y dependencias . . . 26

6. Errores del usuario y diseño defensivo . . . 26

7. Matriz de riesgos . . . 27

7.1 Escala de valoración y procedimiento . . . 27

7.2 Amenaza, vulnerabilidad y consecuencia: un ejemplo . . . 27

7.3 Mapa de calor . . . 27

7.4 Prioridades de tratamiento . . . 28

7.5 Registro de riesgos: identificación y escenario . . . 29

7.6 Registro de riesgos: valoración, controles, verificación y riesgo residual . . . 30

7.7 Apoyo técnico: CWE, OWASP, CVSS estimado y técnica de ATT&CK . . . 32

8. Relación con MITRE ATT&CK . . . 33

8.1 Qué no se mapea y por qué . . . 34

8.2 Versión de ATT&CK y estado de verificación . . . 34

8.3 Mitigaciones y estrategias de detección de ATT&CK . . . 34

9. Verificación de los controles: tipos, defensa en profundidad y contraste con el formulario . . . 35

9.1 Tipos y naturaleza de los controles . . . 35

9.2 Defensa en profundidad . . . 35

9.3 Catálogo de controles por tipo y naturaleza . . . 36

9.4 Controles de cada requisito del formulario . . . 36

9.5 Referencias de apoyo . . . 37

9.6 Contraste con los requisitos del formulario: estándares y pruebas . . . 38

10. Plan de verificación y hoja de ruta del prototipo . . . 39

10.1 Pruebas T01 a T18 . . . 39

10.2 Hoja de ruta del prototipo local . . . 40

10.3 Qué es igual y qué cambia entre producción y la demostración local . . . 40

11. Explicación para el cliente . . . 41

12. Supuestos y preguntas abiertas . . . 41

12.1 Supuestos declarados . . . 41

12.2 Preguntas al cliente . . . 41

13. Fuentes y fecha de consulta . . . 42

13.1 Normativa ecuatoriana . . . 42

13.2 Documentación técnica y vulnerabilidades . . . 42

Anexo A. Modelado de amenazas con STRIDE . . . 44

Anexo B. Borrador de evaluación de impacto del tratamiento . . . 45

B.1 Identificación . . . 45

B.2 Descripción sistemática del tratamiento . . . 45

B.3 Necesidad y proporcionalidad . . . 45

B.4 Riesgos para los derechos y libertades . . . 46
B.5 Medidas y garantías . . . 46
B.6 Obligaciones asociadas y estado . . . 46
B.7 Consulta, conclusión y aprobación . . . 46

Anexo C. Matriz de trazabilidad . . . 47
C.1 Del requisito al módulo del prototipo . . . 47
C.2 Del riesgo al control, la prueba y el módulo . . . 48

Anexo D. Inventario de endpoints . . . 49
D.1 Cobertura de OWASP API Security Top 10:2023 . . . 50

Anexo E. Parámetros de seguridad . . . 51

Anexo F. Recuperación de cuenta y activación . . . 52

Anexo G. Casos de abuso . . . 53

Anexo H. Ciclo de desarrollo seguro . . . 54

Anexo I. Reglas de detección y respuesta . . . 55
I.1 Severidad y respuesta . . . 55

Anexo J. Gestión de claves y secretos . . . 56

Alcance, método y convenciones

Este entregable es un análisis documental y un diseño. No se ejecutaron pruebas ni se conectó ningún servicio real: las pruebas de la sección 10 están diseñadas pero no ejecutadas, y las capacidades, los plazos y las estimaciones son hipótesis declaradas. Después de este informe se construye un prototipo local con datos sintéticos que implementa los controles descritos.

Método

1. Depurar cada requisito y formular preguntas al cliente (§1).
2. Clasificar los datos y fundamentar con la normativa ecuatoriana (§2).
3. Diseñar el servicio de turnos, la arquitectura y los permisos (§3 y §4).
4. Elegir tecnologías con evidencia: CVE, CVSS, fechas de soporte y errores típicos (§5 y §6).
5. Valorar los riesgos con una matriz de 5 × 5 y relacionarlos con CWE, OWASP, CVSS y MITRE ATT&CK (§7 y §8).
6. Contrastar los controles contra estándares y contra los requisitos del formulario (§9).
7. Diseñar las pruebas y la hoja de ruta del prototipo (§10).

Convenciones

- **I01 a I14:** requisitos del cliente. **N01 a N10:** requisitos nuevos. **RT-01 a RT-12:** reglas de turnos. **R01 a R23:** riesgos. **T01 a T18:** pruebas.
- **Tipos de control:** P preventivo, D detectivo, C correctivo. **Naturaleza:** T técnico, A administrativo, F físico.
- **Propiedades:** C confidencialidad, I integridad, D disponibilidad, A autenticidad, T trazabilidad, R responsabilidad, U utilidad, P posesión o control (tríada CIA y Hexad de Parker).
- **Fechas de consulta de las fuentes:** 29 y 30 de octubre de 2026.

> **Importante.** CVSS mide la severidad técnica de una vulnerabilidad, no el riesgo para el IESS. El riesgo combina probabilidad, impacto, exposición y contexto legal. Por eso la matriz de la sección 7 no usa CVSS como nivel de riesgo: lo usa como una columna de apoyo para los riesgos técnicos.

1. Depuración de requisitos

Se conservan I01 e I10, se eliminan I03, I04 e I05 y se modifican los nueve restantes. Cada fila indica la justificación, el requisito definitivo y la pregunta que queda abierta para el cliente.

ID y decisión	Justificación	Requisito definitivo	Pregunta al cliente o supuesto
I01 Conservar	Es la finalidad central: reducir filas y llamadas. Gestionar un turno es una operación administrativa y no requiere acceder a la historia clínica. Se añaden reglas de equidad y de concurrencia (§3).	Buscar turnos por especialidad, establecimiento y fecha; reservar, cancelar y reprogramar con reserva atómica por franja, una cita activa por afiliado y especialidad, tope de citas activas y política de inasistencias con apelación (RT-01 a RT-12).	¿Se gestionan solo citas médicas o también turnos administrativos? Supuesto: solo citas médicas de consulta externa.
I02 Modificar	Minimización (LOPDP art. 10 literal e). La fecha de nacimiento no es un secreto: la conocen familiares y terceros, por eso no sirve para autenticar.	Cédula como identificador; nombres y apellidos devueltos por el servicio de afiliación; correo y teléfono verificados. La fecha de nacimiento se usa solo si el servicio de afiliación la exige para la elegibilidad y nunca como credencial.	¿El servicio de afiliación devuelve nombres y estado de afiliación? Supuesto: sí.
I03 Eliminar	Empleador, cargo, sueldo, cuenta bancaria y contrato no inciden en reservar una cita. Son excesivos y permiten discriminar (art. 10 literales e y f). Exigirlos como condición vicia el consentimiento libre (art. 8). La vigencia de la afiliación se consulta al servicio autorizado (I10).	No se solicita ninguno. El portal solo recibe el resultado «afiliado vigente», «no vigente» o «no confirmado».	¿Algún derecho depende de la relación laboral? Supuesto: lo resuelve el servicio de afiliación, no el portal.
I04 Eliminar	La salud es categoría especial (art. 25) y su tratamiento está prohibido salvo excepciones (art. 26). Exigirla antes de mostrar horarios es desproporcionado (art. 10 literal f). Una reserva no es una historia clínica, que es información confidencial del sistema de salud (Acuerdo Ministerial 5216).	La agenda no almacena diagnósticos, antecedentes, medicamentos, alergias ni resultados. Solo un motivo mínimo codificado (primera vez, control o referencia), sin texto libre.	¿La especialidad exige referencia? Supuesto: en algunas sí; se guarda solo el número de la referencia, no su contenido.
I05 Eliminar	Religión y afiliación política son datos sensibles (arts. 4, 25 y 26) y no tienen finalidad en una agenda. Personalizar la atención no justifica tratarlos.	No se preguntan. De la «composición familiar» solo se registran las relaciones de representación necesarias (I06).	Sin pregunta.

ID y decisión	Justificación	Requisito definitivo	Pregunta al cliente o supuesto
I06 Modificar	Cédula y fecha de nacimiento son datos que conocen terceros: no acreditan autorización. Representar es tratar datos de otra persona y exige base y alcance (art. 7; menores: art. 21 y Reglamento art. 19).	Delegación registrada: el titular, o el tutor legal verificado, autoriza a un representante autenticado, con alcance (solo agenda), vigencia y revocación inmediata. El representante no accede a la historia clínica (§4.4).	¿Cómo acredita el IESS tutelas y poderes? Supuesto: verificación documental presencial una sola vez.
I07 Modificar	Una clave inicial derivada de la fecha de nacimiento es predecible (CWE-521) y dejar el cambio como opcional la perpetúa. NIST SP 800-63B-4 fija topes de duración de sesión y reautenticación.	Activación con secreto de un solo uso y corta vigencia enviado al contacto verificado; la persona define su clave, que se verifica contra claves filtradas y se guarda con Argon2id. Bloqueo progresivo y segundo factor obligatorio para funcionarios y para operaciones sensibles.	¿Existe identidad institucional (SSO) del IESS? Supuesto: no; el prototipo usa cuentas propias con activación.
I08 Modificar	«Todos ven todo» viola la confidencialidad (art. 10 literal g) y la protección por defecto (Reglamento art. 60).	Control de acceso por rol más relación asistencial: recepción ve la agenda de su unidad; el profesional ve datos clínicos solo de pacientes con relación asistencial; soporte ve datos técnicos enmascarados; administración configura sin ver pacientes; auditoría y DPD leen registros. La autorización se comprueba en el servidor en cada solicitud.	¿Cuántos funcionarios hay por rol? Supuesto: la distribución propuesta en §4.3.
I09 Modificar	Un diagnóstico por SMS o correo se expone si el teléfono se pierde, se reenvía o se ve en la pantalla bloqueada. Un enlace que abre información sin iniciar sesión es un token reenviable (CWE-306).	Mensajes neutrales («Tiene una cita el [fecha]. Ingrese al portal»), sin diagnóstico ni especialidad. Los enlaces solo llevan a iniciar sesión o confirman con un token de un solo uso y caducidad corta, sin abrir información.	¿Debe aparecer la especialidad en el recordatorio? Supuesto: no.
I10 Conservar	La integración es necesaria. Se conserva con condiciones de seguridad: contrato con encargados (art. 34), credenciales de servicio, TLS con validación de certificados y tiempos de espera.	Integración con el servicio de afiliación y el sistema de agenda mediante interfaces autorizadas y mínimas, con autenticación entre servicios, tiempos de espera, reintentos idempotentes y estado «pendiente» si el tercero no responde. No se inventa cobertura ni se confirma un turno no persistido.	¿Existen interfaces oficiales? Supuesto: en el prototipo se simulan con servicios de prueba.
I11 Modificar	Registrar contraseñas, tokens y cuerpos completos crea una base secreta de credenciales (CWE-532). Auditar no es copiar datos.	Registro estructurado: fecha y hora, usuario individual, acción, recurso, resultado y correlación. Sin contraseñas, tokens ni contenido clínico. Solo adición, con verificación de integridad y acceso restringido.	¿Qué plazo de auditoría exige la institución? Supuesto: 12 meses en línea y archivo según la normativa aplicable.
I12 Modificar	Un equipo de oficina de 8 GB como aplicación y base de datos no tiene redundancia ni aislamiento: es un punto único de falla y la aplicación comparte host con los datos.	Producción con aplicación y base de datos separadas, redundancia y respaldos externos, dimensionada con pruebas de carga (§4.7). La demostración local usa contenedores en un solo equipo con la misma configuración de seguridad.	¿Hay infraestructura institucional disponible? Supuesto: sí.
I13 Modificar	Dos horas diarias sin reservas dan una disponibilidad máxima de 22/24 = 91,67 %, incompatible con «atención continua».	Despliegues graduales sin interrupción de reservas; una ventana excepcional como máximo una vez al mes, anunciada y en horario de baja demanda. Objetivo de disponibilidad: 99,9 % mensual.	¿Cuál es el horario de menor demanda? Supuesto: de 22:00 a 05:00.
I14 Modificar	Conservar sin plazo contradice el principio de conservación (art. 10 literal i; Reglamento arts. 8 a 11). Entregar los datos para entrenar IA es una finalidad distinta (art. 10 literal d) que exige base válida, y la norma SPDP-SPD-2026-0009-R exige evaluación de impacto antes de desarrollar un sistema de IA con datos personales (art. 6).	Plazos de conservación por categoría (§2). Se elimina la entrega a un proveedor externo para entrenar IA. Un proyecto futuro exigiría base legal, evaluación de impacto, anonimización autorizada y contrato; y un proveedor con acceso, visibilidad o control efectivo de los datos quedaría obligado por la norma de IA (reforma 0037-R).	¿Existe un proyecto de IA aprobado? Supuesto: no.

1.1 Requisitos nuevos que se proponen

ID	Requisito nuevo	Fundamento
N01	Análisis de riesgos, evaluación de impacto previa, auditoría al menos cada 12 meses e informe anual de cumplimiento, conservados 5 años.	LOPDP arts. 40 a 42; Reglamento arts. 29 a 32; SPDP-SPD-2026-0005-R arts. 12, 17 y 18.
N02	Designar un delegado de protección de datos e inscribir su nombramiento en la SPDP dentro de 15 días.	LOPDP art. 48 num. 1; SPDP-SPD-2025-0028-R arts. 5, 9 y 10.7; SPDP-SPD-2026-0005-R art. 12.
N03	Aviso de privacidad que identifique el tratamiento a gran escala y canal autenticado para ejercer derechos: responder el requerimiento en 10 días y atender los derechos en 15 días.	LOPDP arts. 12 a 16 y 62; Reglamento arts. 12 a 16; SPDP-SPD-2026-0005-R art. 18.
N04	Plan de respuesta a incidentes: notificar a la SPDP por el SISPDP, a la ARCOTEL y al titular. El aviso al titular dice la naturaleza de la vulneración, la fecha o período, las medidas adoptadas y las recomendaciones.	LOPDP arts. 43 y 46; Reglamento arts. 24 a 28; SPDP-SPD-2026-0040-R arts. 8, 10 y 11.

ID	Requisito nuevo	Fundamento
N05	Registro de actividades de tratamiento (obligatorio con 100 o más trabajadores), actualizado al menos una vez al año, y registro en el Registro Nacional en 10 días.	LOPDP art. 51; Reglamento arts. 38, 39 y 86; SPDP-SPD-2026-0005-R art. 6.
N06	Contratos con encargados y proveedores (SMS, correo, hosting) con instrucciones, seguridad, y devolución o eliminación de los datos en 5 días con constancia escrita.	LOPDP arts. 34 y 35; Reglamento art. 41; SPDP-SPD-2025-0030-R art. 24.
N07	Gestión de vulnerabilidades: análisis de dependencias, SBOM y plazos de parcheo por severidad y exposición.	LOPDP art. 37; OWASP Top 10:2025 A03.
N08	Reglas de turnos contra el acaparamiento y los turnos fantasma, con revisión humana de cualquier restricción.	LOPDP art. 20 (decisiones automatizadas); §3.
N09	Canales alternos (presencial y telefónico) y cupos para atención prioritaria.	Constitución art. 35 (atención prioritaria).
N10	El prototipo y las pruebas usan solo datos sintéticos.	LOPDP art. 10 (finalidad y minimización).

2. Análisis de datos y fundamento normativo

Se analizaron 18 datos: 10 son necesarios, 2 son condicionales, 1 es opcional y 5 son innecesarios. El cliente no puede exigir los innecesarios solo porque los pidió: la LOPDP limita el tratamiento a lo pertinente y estrictamente necesario para la finalidad (art. 10 literal e).

2.1 Diferencia entre gestionar un turno y gestionar información clínica

Aspecto	Gestionar un turno	Gestionar información clínica
Finalidad	Asignar un cupo de atención	Diagnosticar, tratar y dar seguimiento
Datos	Identidad mínima, contacto, especialidad, fecha y estado	Antecedentes, diagnósticos, medicación, laboratorio
Quién accede	Afiliado, representante y recepción	Profesionales con relación asistencial
Régimen	LOPDP y reglas de agenda	LOPDP arts. 25, 26, 30 y 31, y confidencialidad del sistema de salud
Sistema responsable	Portal de turnos y agenda	Sistema clínico, fuera del alcance del portal
Si se filtra	Revela que una persona acude a una especialidad	Revela la salud de la persona; daño casi irreversible

La distinción gobierna el diseño: el portal gestiona turnos y no almacena información clínica. El sistema clínico queda fuera del alcance y no es accesible desde el portal. Aun así, la especialidad y la fecha de una cita pueden revelar salud, por lo que se tratan con confidencialidad.

2.2 Datos, finalidad, clasificación, necesidad, acceso y conservación

Dato	Finalidad	Clasificación (LOPDP)	Necesidad	Quién accede	Conservación propuesta
Cédula	Identificar al afiliado	Dato personal identificador	Necesario	Titular, representante, recepción; soporte con la cédula enmascarada	Mientras exista la cuenta; baja a los 24 meses de inactividad
Nombres y apellidos	Mostrar y verificar la identidad	Dato personal	Necesario (los devuelve la afiliación)	Igual que la cédula	Igual que la cédula
Fecha de nacimiento	Validar elegibilidad por edad; nunca credencial	Dato personal; si es de un menor, categoría especial (art. 25 literal b)	Condicional	Solo el servicio de afiliación	No se persiste; solo un indicador de menor o mayor de edad
Correo	Activar la cuenta y notificar	Dato personal	Necesario	Titular y servicio de notificaciones; soporte enmascarado	Mientras exista la cuenta
Teléfono	Recordatorio por SMS y segundo factor	Dato personal	Opcional (con consentimiento para el SMS)	Igual que el correo	Mientras exista la cuenta o hasta que se retire
Empleador, cargo, sueldo, cuenta bancaria y contrato	Ninguna	Dato personal económico y laboral	Innecesario	Nadie	No se recoge
Religión y afiliación política	Ninguna	Dato sensible (arts. 4 y 25)	Innecesario	Nadie	No se recoge
Composición familiar general	Ninguna	Dato personal	Innecesario; solo las delegaciones	Nadie	No se recoge
Relación de representación	Autorizar la gestión de citas ajenas	Dato personal; menores y personas con discapacidad, categoría especial	Necesario si hay representación	Titular, representante y recepción (solo vigencia)	Vigencia más 12 meses por controversias

Dato	Finalidad	Clasificación (LOPDP)	Necesidad	Quién accede	Conservación propuesta
Especialidad, establecimiento, fecha y hora del turno	Gestionar la atención	Dato personal vinculado a salud: revela una relación asistencial	Necesario	Afiliado, representante, recepción de su unidad y profesional asignado	Cita más 12 meses; luego agregado anónimo o archivo según la obligación aplicable
Estado del turno y restricciones	Equidad y control de abuso	Dato personal	Necesario	Sistema y recepción; el titular ve las suyas	12 meses; las restricciones expiran a los 14 días (RT-06)
Motivo mínimo codificado	Derivar al profesional correcto	Dato de salud mínimo	Condicional	Profesional asignado y recepción de la unidad	Con el turno
Diagnósticos, antecedentes, medicamentos, alergias y laboratorio	Atención clínica	Salud, categoría especial (art. 25 literal c)	Innecesario en la agenda	Solo el sistema clínico, con relación asistencial	Régimen del sistema clínico, no el de la agenda
Estado de afiliación	Validar el derecho a la atención	Dato personal restringido	Necesario	Servicio de agenda	Caché de hasta 15 minutos
Credenciales (hash Argon2id) y factores	Autenticar	Dato de autenticación	Necesario	Nadie lee la clave	Mientras exista la cuenta
Registros de auditoría	Trazabilidad y seguridad	Dato personal mínimo (usuario e IP)	Necesario	Auditoría, seguridad y DPD, solo lectura	12 meses en línea; archivo posterior según la normativa
Registro de notificaciones	Prueba de aviso	Dato personal	Necesario	Sistema	6 meses
Datos para entrenar IA	Entrenar un asistente externo	No aplica	Innecesario; fuera del alcance	Nadie	No se entrega

Los plazos son propuestas de política que el IESS debe aprobar; no superan lo necesario para la finalidad (LOPDP art. 10 literal i) y el registro de la base debe consignarlos (Reglamento art. 10). Al vencer se eliminan de forma segura, se bloquean o se anonimizan (Reglamento arts. 9 y 11). Los plazos tributarios, contables y de archivo del sector público no se verificaron en esta consulta y los confirma el área jurídica.

2.3 Bases de licitud, menores y decisiones automatizadas

- **Base de licitud.** Como entidad pública, la prestación del servicio se apoya en la obligación legal y en la misión de interés público (LOPDP art. 7 numerales 2 y 4), no en el consentimiento. El consentimiento libre, específico, informado e inequívoco (art. 8) se reserva para lo opcional: el recordatorio por SMS y cualquier uso adicional. La prestación no se condiciona a aceptarlos.
- **Menores y representación.** Para menores de 15 años se requiere el consentimiento del representante legal; desde los 15 años pueden consentir ellos mismos si se les explica con claridad (LOPDP art. 21; Reglamento art. 19). La delegación para citas de menores la ejerce el tutor legal.
- **Decisiones automatizadas.** Bloquear la reserva en línea por inasistencias produce un efecto sobre una persona. La LOPDP reconoce el derecho a no ser sometido a decisiones basadas únicamente en tratamientos automatizados, a pedir una explicación y a impugnarlas (art. 20). Por eso la restricción es temporal, explicada, apelable ante una persona y nunca bloquea la atención presencial (§3.5).
- **Gran escala.** El Reglamento considera de gran escala el tratamiento de datos de pacientes de las instituciones del Sistema Nacional de Salud (art. 4 num. 7), y la norma SPDP-SPD-2026-0005-R lo califica de forma directa para la salud en sistemas sanitarios, asistenciales o de seguridad social (art. 14.1). Además, el modelo MTGE da al portal al menos 9,5 puntos con supuestos mínimos, frente a un umbral de 6 (Anexo B). Efectos: evaluación de impacto previa, delegado, registro de actividades y medidas reforzadas (art. 12).
- **Seguridad en el sector público.** La LOPDP remite al mecanismo gubernamental de seguridad de la información (art. 38). Se debe verificar con la institución cuál es el esquema vigente y mapear los controles contra él.

2.4 Notificación de vulneraciones

El responsable notifica a la autoridad de protección de datos y a la ARCOTEL tan pronto como sea posible y a más tardar en 5 días, salvo que sea improbable que haya riesgo para los derechos; el encargado avisa al responsable en 2 días y el titular recibe la comunicación en 3 días cuando hay riesgo (LOPDP arts. 43 y 46). La norma SPDP-SPD-2026-0040-R establece que la notificación a la SPDP se hace por el sistema SISPDP (arts. 8 y 12), que omitirla o no avisar a los titulares es infracción grave, y que el aviso al titular debe decir la naturaleza de la vulneración, la fecha o período, las medidas adoptadas y las recomendaciones (art. 10). Por eso el plan de

respuesta a incidentes (N04) fija un objetivo interno más estricto y no espera a agotar los plazos.

2.5 Normativa ecuatoriana aplicada y estado de verificación

Norma y disposición	Qué respalda en este análisis
Constitución, art. 66 num. 19 y art. 92	Derecho a la protección de datos: la recolección y el tratamiento requieren autorización del titular o mandato legal; los datos sensibles exigen medidas de seguridad.
Constitución, art. 35	Atención prioritaria a personas adultas mayores, embarazadas y personas con discapacidad: base para los canales alternos y las excepciones de las reglas de turnos.
LOPDP (RO Suplemento 459, 26-may-2021): arts. 4, 7, 8, 9, 10	Definiciones (dato biométrico, sensible, de salud, perfiles, vulneración); bases de licitud; consentimiento; interés legítimo; principios de finalidad, minimización, proporcionalidad, confidencialidad, conservación, seguridad y responsabilidad proactiva.
LOPDP, arts. 12 a 16 y 20	Derechos de información, acceso, rectificación, eliminación y oposición con plazo de 15 días; derecho a no ser sometido a decisiones únicamente automatizadas (relevante para las restricciones por inasistencia).
LOPDP, arts. 21 y 25 a 31	Datos de niñas, niños y adolescentes (desde los 15 años pueden consentir); categorías especiales; prohibición de tratar datos sensibles salvo excepciones; datos de salud.
LOPDP, arts. 33 a 36	Transferencia a terceros con consentimiento informado; contratos con encargados; excepciones.
LOPDP, arts. 37 a 43 y 46	Seguridad; mecanismo gubernamental de seguridad de la información en el sector público (art. 38); protección desde el diseño y por defecto; análisis de riesgos; medidas; evaluación de impacto; notificación de vulneraciones (5 días a la autoridad y a la ARCOTEL, 2 días del encargado al responsable, 3 días al titular).
LOPDP, arts. 47 a 51 y 67 a 68	Obligaciones del responsable, delegado de protección de datos, Registro Nacional e infracciones.
Reglamento General (Decreto 904, RO Suplemento 435, 13-nov-2023): arts. 4 a 11, 19 a 41, 48, 58 a 60 y 86	Gran escala, consentimiento, conservación y eliminación, menores, transferencias, vulneraciones, evaluación de impacto, encargados, DPD, diseño y defecto, y Registro Nacional.
SPDP-SPD-2026-0003-R, actividades familiares o domésticas (suscrita el 26-ene-2026)	Tres criterios para que una actividad pierda el carácter doméstico: finalidad de comunicación o transferencia comercial, difusión a un número indeterminado de personas y violación directa de derechos (art. 4). Sirve para delimitar la ayuda de un familiar frente a la delegación formal (§4.4).
SPDP-SPD-2026-0005-R, norma general sobre el tratamiento a gran escala (suscrita el 2-feb-2026; vigente desde su publicación en el Registro Oficial, que Lexis ubica en el Suplemento 231 del 25-feb-2026)	Modelo MTGE con umbral de 6 puntos (arts. 7 a 10). Califica de gran escala, de forma directa, los tratamientos de salud en sistemas sanitarios, asistenciales o de seguridad social (art. 14.1). Efectos: evaluación de impacto previa, delegado, registro de actividades y medidas reforzadas (art. 12); auditoría cada 12 meses e informe anual, conservados 5 años (arts. 17 y 18).
SPDP-SPD-2026-0009-R, norma general sobre inteligencia artificial (suscrita el 12-feb-2026; publicada en el Registro Oficial N.º 240 del 10-mar-2026)	Aplica a quien desarrolle, entrene, implemente, despliegue o provea sistemas de IA que traten datos de titulares ecuatorianos (art. 1). Exige informar al titular, evaluación de impacto previa al desarrollo, inclusión en el registro de actividades y auditorías (arts. 5 a 7); garantiza el derecho a no ser objeto de decisiones automatizadas (art. 4).
SPDP-SPD-2026-0037-R, reforma de la norma de inteligencia artificial (suscrita el 9-sep-2026; vigente desde su publicación en el Registro Oficial)	Extiende las obligaciones de la 0009-R a los encargados que tengan acceso, visibilidad o control efectivo de los datos (arts. 1, 3, 4, 6, 7 y 8); el encargado que provea un sistema de IA informa al responsable sobre su funcionamiento, limitaciones y riesgos (art. 5); y quien alegue no tener acceso debe conservar evidencia (art. 8). Las obligaciones solo le exigen al encargado lo que cubre su acceso, visibilidad o control (disposición general primera).
SPDP-SPD-2026-0040-R, norma técnica de notificación de vulneraciones (suscrita el 9-sep-2026; publicada en el Registro Oficial Primer Suplemento N.º 376 del 24-sep-2026)	Notificación a la SPDP por el SISPDP; omitirla, u omitir el aviso a los titulares, es infracción grave (arts. 8 y 9.4). El encargado avisa al responsable en 2 días y el responsable a la SPDP en 5 (art. 11). Contenido mínimo del aviso al titular (art. 10).
SPDP-SPD-2025-0028-R, reglamento del delegado de protección de datos (suscrita el 30-jul-2025; vigente desde su firma)	El sector público debe designar delegado (art. 9), y también los actores del sistema de salud que llevan historias clínicas (art. 10.7). El nombramiento se inscribe en la SPDP dentro de 15 días (art. 5). La formación obligatoria del art. 11 rige desde el 1-ene-2029.
SPDP-SPD-2025-0030-R, reglamento para la seudonimización, anonimización, bloqueo y eliminación (suscrita el 7-ago-2025; vigente desde su firma)	Suspensión del tratamiento en 3 días (art. 16); el encargado devuelve o elimina en 5 días con un documento que lo acredite (art. 24); la eliminación se acredita con constancia (art. 20); los datos de salud anonimizados requieren autorización previa de la SPDP (art. 10).
Ministerio de Salud Pública, Acuerdo Ministerial 5216 y su reforma (AM 00127-2021, RO 391, 12-feb-2021)	Reglamento para el manejo de información confidencial en el Sistema Nacional de Salud: la historia clínica es información confidencial; el personal administrativo con acceso debe guardar confidencialidad.
Norma de datos de salud de la SPDP	Estaba prevista para agosto de 2026 en el Plan Regulatorio Institucional 2026.

No se revisaron la Ley Orgánica de Salud, la Ley de Seguridad Social ni la normativa interna del IESS sobre citas: se piden al asesor jurídico.

3. Gestión de turnos: reglas contra el acaparamiento y los turnos fantasma

Un afiliado no puede tener más de una cita activa por especialidad ni encadenar reservas sin asistir, y quien falla de forma repetida pierde de manera temporal la reserva en línea, no la atención. Las reglas protegen el cupo sin convertir un derecho de salud en un castigo.

3.1 Tres problemas distintos

Problema	Causa típica	Daño	Reglas que lo atienden
Acaparamiento: una persona obtiene más turnos de los que le corresponden	Varias reservas en la misma especialidad; bots; una persona que reserva a nombre de muchos familiares	Los cupos se agotan en pocas manos y los afiliados reales quedan sin cita	RT-01, RT-02, RT-03, RT-08, RT-09
Turnos fantasma: se reservan y no se usan	Olvido; reservas «por si acaso»; cancelaciones tardías	Cupos perdidos y filas, aunque la agenda parezca llena	RT-05, RT-06, RT-07
Doble venta: dos afiliados con la misma franja	Solicitudes simultáneas y reintentos	Reclamos y atención interrumpida	RT-04, RT-10

3.2 Ciclo de vida del turno

El turno es una máquina de estados con transiciones controladas por el servidor (Figura 1, al final de esta sección). Un turno solo pasa a ATENDIDO o NO ASISTIÓ si lo registra una persona autorizada de la unidad: el afiliado nunca marca sus propias inasistencias. Toda reserva nace PENDIENTE hasta que la agenda confirma, luego RESERVADO hasta que el afiliado la confirma en 24 horas, y recién entonces CONFIRMADO.

3.3 Reglas RT-01 a RT-12

Las reglas se imponen en el servidor y, cuando es posible, en la base de datos, de modo que ni un error de la aplicación ni una solicitud manipulada las salten.

Regla	Qué evita	Cómo se implementa	Prueba
RT-01 Una cita activa por afiliado y especialidad	Acaparar cupos de una misma especialidad	Índice único parcial sobre afiliado y especialidad para turnos RESERVADO o CONFIRMADO. La base de datos lo impone aunque falle la aplicación.	T16
RT-02 Tope de citas activas por afiliado (propuesta: 3)	Acumular citas en varias especialidades «por si acaso»	Conteo dentro de la transacción de reserva; el valor es un parámetro que aprueba la dirección médica.	T16
RT-03 Sin solape de horarios para un mismo afiliado	Reservar dos lugares a la misma hora	Restricción de exclusión sobre el rango de tiempo (extensión btree_gist de PostgreSQL) o verificación bajo bloqueo.	T16
RT-04 Una franja, un turno	Doble venta del mismo cupo	Índice único parcial por franja más bloqueo de fila al reservar.	T07
RT-05 Toda reserva se confirma en 24 horas	Turnos fantasma y acaparamiento por bots	El turno nace RESERVADO y se confirma con un clic dentro de las 24 horas siguientes, o con una llamada; si no, expira y el cupo se libera con aviso.	T17
RT-06 Política de inasistencias proporcional	Reservas encadenadas sin asistir; castigos injustos	Ver la tabla de la sección 3.5: aviso, tope reducido tras una inasistencia, bloqueo temporal de la reserva en línea tras dos consecutivas, justificación y apelación humana.	T17
RT-07 Cancelar hasta 2 horas antes; reprogramar hasta 2 veces	Cupos bloqueados por cambios tardíos o ciclos de reprogramación	Contador de reprogramaciones por turno; la cancelación libera el cupo de inmediato.	T17
RT-08 Un representante gestiona hasta 5 personas y los topes se aplican a cada afiliado	Acaparar turnos a nombre de terceros	Conteo de delegaciones activas; RT-01 y RT-02 se evalúan sobre el afiliado atendido, no sobre quien opera.	T02, T16
RT-09 Anti-automatización	Bots y reservas masivas	Límites por cuenta, IP y dispositivo; desafío adaptativo solo ante comportamiento sospechoso; ventana de reserva de 30 días; detección de una IP con muchas cédulas.	T09, T16
RT-10 Reserva solo con afiliación vigente	Confirmaciones falsas si el tercero falla	Si el servicio de afiliación no responde, el turno queda PENDIENTE y nunca se afirma cobertura.	T07
RT-11 Cupos y canales para atención prioritaria	Excluir a quien más lo necesita	Porcentaje de cupos reservado a grupos prioritarios; las restricciones automáticas no se aplican a esos grupos; canal telefónico y presencial.	T17

Regla	Qué evita	Cómo se implementa	Prueba
RT-12 Toda decisión queda auditada	Disputas sin evidencia	Reserva, cancelación, inasistencia, restricción y apelación se registran con actor, recurso y resultado en un registro de solo adición.	T11b

3.4 Validación de una solicitud de reserva

Las comprobaciones siguen un orden (Figura 2, al final de esta sección): primero lo barato y lo de seguridad (sesión, CSRF, límites), luego la identidad y la delegación, luego las reglas de negocio y, al final, la transacción atómica. Todo rechazo usa un mensaje genérico para no revelar si una cédula existe, y queda auditado.

3.5 Política de inasistencias (parámetros propuestos)

Los valores son propuestas para que la dirección médica los apruebe. Lo que se fija en el diseño es la estructura: aviso, tope reducido, bloqueo temporal solo de la reserva en línea, justificación y apelación humana.

Situación	Consecuencia propuesta	Salvaguarda
Una inasistencia injustificada en los últimos 90 días	Aviso en el portal. Mientras no justifique ni asista al siguiente turno, solo puede tener 1 turno activo en total.	Evita las reservas encadenadas sin bloquear la atención. La inasistencia la registra recepción o el profesional, nunca el propio afiliado.
Dos inasistencias consecutivas en la misma especialidad	Bloqueo de la reserva en línea de esa especialidad por 14 días.	Puede reservar por el canal presencial o telefónico. El portal explica la causa y la fecha en que termina la restricción.
Tres inasistencias en 90 días	Revisión humana de la unidad (llamada o trabajo social) antes de cualquier medida adicional.	Una persona decide; no hay sanciones automáticas acumulativas (LOPDP art. 20).
Justificación dentro de 72 horas (documento o declaración)	Se revierte la inasistencia y se levanta la restricción.	Aplicación favorable al titular (LOPDP art. 10 literal l).
Casos que no cuentan como inasistencia	Cancelación o reprogramación por la institución, falla del sistema, emergencia médica, y personas de atención prioritaria sin acceso digital.	Se registran como excepción con motivo.
Apelación	Ante una persona de la unidad, con respuesta en 5 días hábiles.	Derecho a explicación y a impugnar (LOPDP art. 20).

Equidad. Se mide la tasa de bloqueos por establecimiento y por grupo de edad para detectar efectos discriminatorios. Las personas de atención prioritaria (Constitución art. 35) mantienen siempre un canal alterno, y ningún bloqueo impide la atención presencial o de urgencia.

3.6 Diseño de datos para imponer las reglas

Ejemplo para PostgreSQL. Los índices únicos parciales y la restricción de exclusión hacen que la propia base rechace un segundo turno activo, una franja ocupada o un solape de horario, incluso si dos solicitudes llegan a la vez.

```
-- Una cita activa por afiliado y especialidad (RT-01)
CREATE UNIQUE INDEX uq_turno_afiliado_especialidad
  ON turno (afiliado_id, especialidad_id)
  WHERE estado IN ('RESERVADO', 'CONFIRMADO');

-- Una franja, un turno (RT-04)
CREATE UNIQUE INDEX uq_turno_franja
  ON turno (franja_id)
  WHERE estado IN ('RESERVADO', 'CONFIRMADO');

-- Sin solape de horario para el mismo afiliado (RT-03); requiere btree_gist
ALTER TABLE turno ADD CONSTRAINT ex_turno_sin_solape
  EXCLUDE USING gist (afiliado_id WITH =, tstzrange(inicio, fin) WITH &&)
  WHERE (estado IN ('RESERVADO', 'CONFIRMADO'));

-- Idempotencia: un reintento no crea otro turno
CREATE UNIQUE INDEX uq_idempotencia
  ON solicitud_reserva (afiliado_id, clave_idempotencia);

-- Reserva atómica (esquema)
BEGIN;
SELECT estado FROM franja WHERE id = :franja FOR UPDATE;   -- bloquea la fila
-- si estado <> 'LIBRE': ROLLBACK y mensaje genérico
INSERT INTO turno (afiliado_id, especialidad_id, franja_id, estado, ...)
  VALUES (:afiliado, :especialidad, :franja, 'RESERVADO', ...);
UPDATE franja SET estado = 'OCUPADA' WHERE id = :franja;
COMMIT;
```

Cada extensión de PostgreSQL ampliaría la superficie de ataque: en 2026 hubo CVE en refint, pgcrypto y pg_trgm (§5.2). Por eso solo se habilita lo estrictamente necesario, aquí btree_gist si se usa la restricción de exclusión.

Figura 1. Ciclo de vida del turno

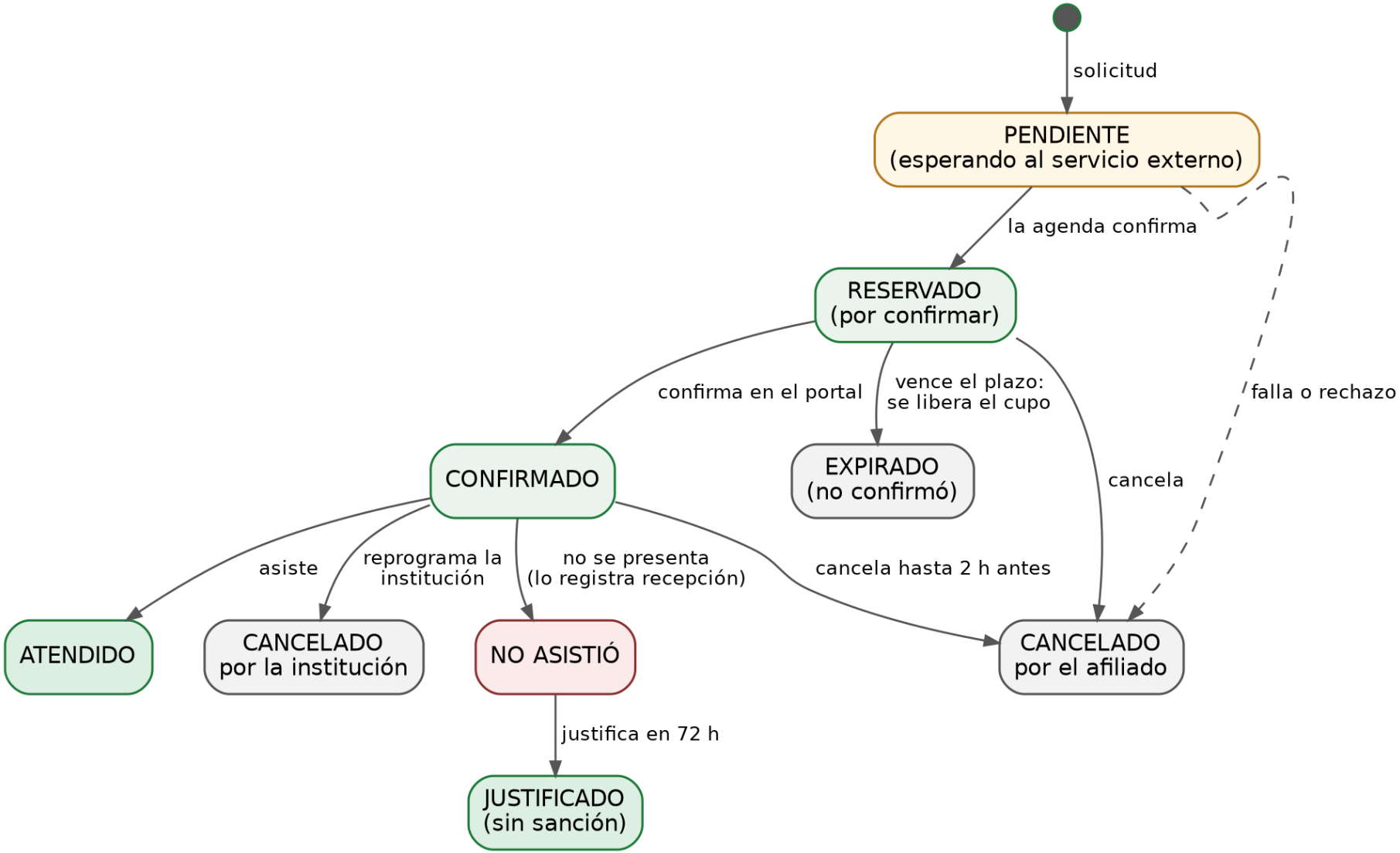


Figura 1. Estados del turno y transiciones. Las inasistencias las registra recepción o el profesional; una inasistencia justificada en 72 horas no genera restricción.

Figura 2. Validación de una reserva

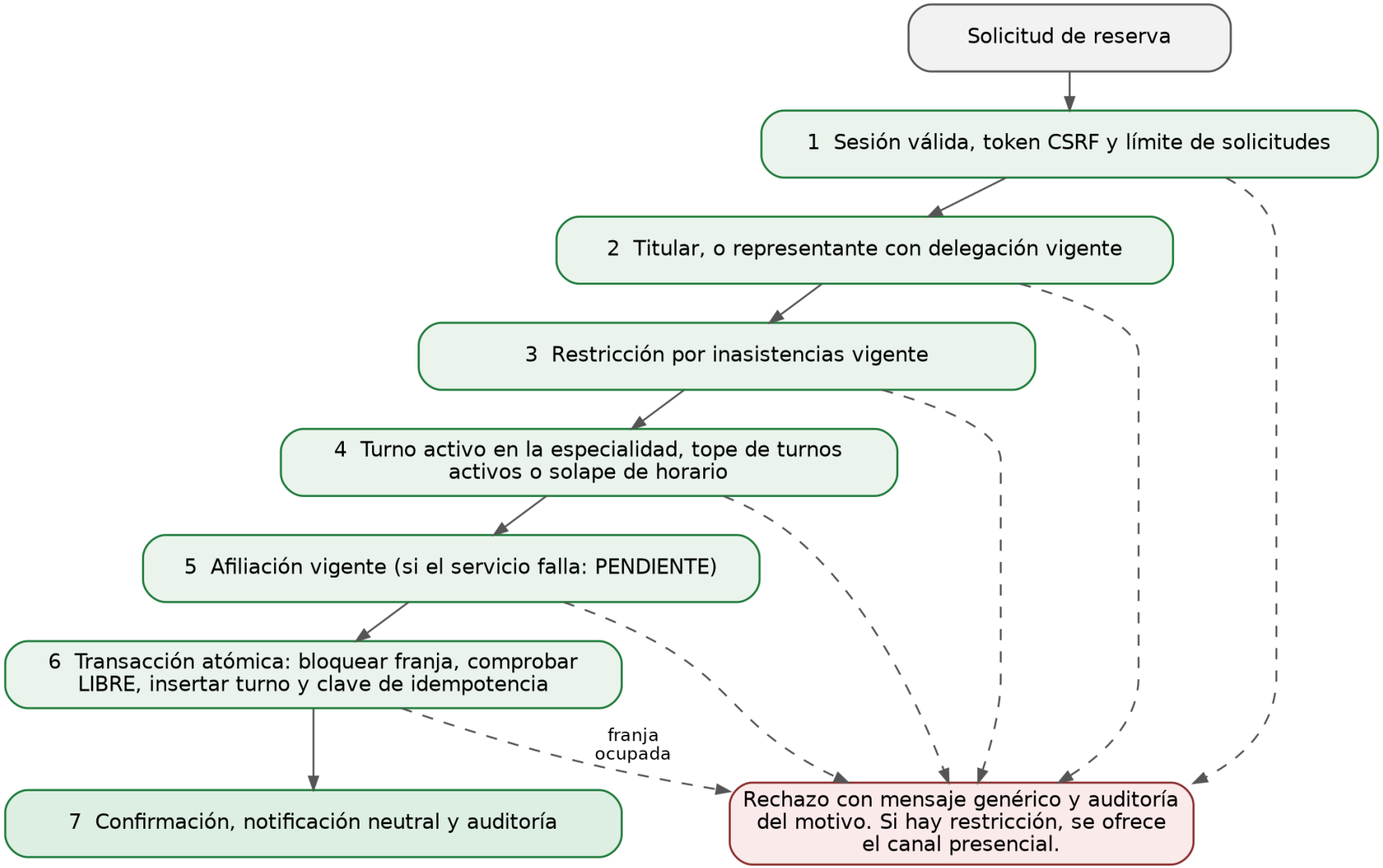


Figura 2. Orden de validación de una reserva. Cada rechazo se audita y, si hay una restricción por inasistencias, se ofrece el canal presencial.

4. Diseño propuesto

El diseño separa la agenda de la información clínica, aplica el mínimo privilegio en cada rol, trata a los terceros como no confiables y deja que la base de datos imponga las reglas críticas.

4.1 Arquitectura y límites de confianza

La Figura 3 (al final de esta sección) muestra las zonas de confianza. Los flujos que cruzan una frontera (Internet, integraciones y red interna) exigen TLS, autenticación y límites. El sistema clínico queda fuera del portal.

Componente	Función	Decisión de seguridad
Cliente web y móvil (PWA)	Buscar, reservar y gestionar	Sin secretos en el cliente; política de contenido (CSP); sin datos sensibles en el almacenamiento local; cierre por inactividad.
Proxy inverso y WAF	TLS, límites, antibots y sala de espera	TLS actual, HSTS y cabeceras de seguridad; límites por ruta, tamaño y tiempo.
Identidad y sesiones	Activación, inicio de sesión y segundo factor	Argon2id, bloqueo progresivo, mensajes genéricos, rotación de sesión al autenticarse, revocación remota.
Turnos y reglas	RT-01 a RT-12	Autorización por objeto en cada solicitud, transacciones, idempotencia, restricciones en la base.
Delegaciones	Representación de familiares	Alcance, vigencia y revocación; aviso al titular.
Notificaciones	Avisos neutrales	Plantillas fijas sin datos clínicos; tokens de un solo uso que no abren información.
Auditoría	Registro de solo adición	Hash encadenado, sin secretos, acceso restringido y copia externa.
Base de datos PostgreSQL	Cuentas, turnos, delegaciones y auditoría	Cifrado en reposo, autenticación SCRAM-SHA-256, roles de mínimo privilegio, sin extensiones innecesarias.
Integraciones	Afiliación y agenda	Autenticación entre servicios, tiempos de espera, circuito abierto, validación de esquema.
Respaldos	Copias y restauración	Regla 3-2-1, inmutables, cifrados y con prueba trimestral de restauración.
Observabilidad	Registros, métricas y alertas	Sin secretos; alertas por abuso, intentos fallidos y accesos anómalos.

4.2 Recorrido de los datos

Etapa	Datos	De → a	Protección	Retención
1. Consulta de disponibilidad	Especialidad, establecimiento y fecha; sin datos personales	Cliente → portal	Límite de solicitudes; caché	Sin retención personal
2. Registro y activación	Cédula, correo y teléfono	Cliente → portal → afiliación	TLS; secreto de un solo uso; verificación de afiliación	Mientras exista la cuenta
3. Inicio de sesión	Credenciales y segundo factor	Cliente → portal	Argon2id; bloqueo progresivo; mensajes genéricos	Solo el hash
4. Reserva	Identificador interno del afiliado, franja y motivo codificado	Portal → agenda	Autorización por objeto; idempotencia; transacción atómica	Cita más 12 meses
5. Confirmación y recordatorio	Fecha y hora; sin especialidad ni diagnóstico	Portal → proveedor SMS o correo	Plantilla neutral; token de un solo uso	6 meses
6. Atención	Información clínica	Sistema clínico (fuera del portal)	Acceso propio de cada profesional	Régimen clínico
7. Auditoría	Evento, actor, recurso y resultado	Todos los servicios → registro	Solo adición; sin secretos	12 meses en línea
8. Vencimiento	Datos vencidos	Tarea programada	Eliminación segura, bloqueo o anonimización	Según plazos de §2

4.3 Roles y permisos

Rol	Agenda propia	Citas de otra persona	Agenda de la unidad	Datos de contacto	Datos clínicos	Configurar oferta	Registros de auditoría	Descarga masiva
Afiliado	S	—	—	S	—	—	—	—
Representante	S	C	—	C	—	—	—	—
Recepción (≈ 60)	—	C	U	M	—	—	—	—
Profesional sanitario (≈ 40)	—	—	U	M	C	—	—	—
Soporte (≈ 8)	—	—	—	M	—	—	T	—
Administración de oferta (≈ 12)	—	—	U	—	—	S	—	—
Administrador de TI	—	—	—	—	—	I	—	—
Auditor y DPD	—	—	L	C	—	—	L	C

S sí; **C** condicionado a una relación asistencial, una delegación vigente o una justificación registrada; **U** solo su unidad; **M** enmascarado (completo solo con justificación y registro); **L** solo lectura; **T** solo registros técnicos, sin datos personales; **I** solo infraestructura, sin datos de clientes; **—** no. La distribución de funcionarios (120) es un supuesto.

Reglas: denegar por defecto; el servidor comprueba identidad, acción y objeto en cada solicitud; segundo factor para todos los funcionarios; acceso excepcional («de emergencia») solo con motivo, aviso al responsable y revisión posterior; separación de funciones y revisión trimestral de privilegios. Los datos clínicos están marcados como «C» porque los consulta el profesional en el sistema clínico, no en el portal.

4.4 Representación de familiares

- La delegación es un registro explícito con titular, representante, alcance, vigencia y estado. Cédula y fecha de nacimiento no sirven como prueba (Figura 4, al final de esta sección).
- Ayudar a un familiar puede ser una actividad doméstica, que la LOPDP excluye (art. 2 literal a); pero el portal es un tratamiento del IESS. Por eso la delegación se registra y los datos siguen protegidos aunque opere un familiar. La norma SPDP-SPD-2026-0003-R fija los criterios para distinguirlo (art. 4). Interpretación a validar con el asesor jurídico: la norma no menciona citas médicas.
- El alcance es la agenda. Nunca incluye información clínica, que solo ve el profesional con relación asistencial.
- Un representante gestiona hasta 5 personas (RT-08) y cada acción queda auditada con ambos identificadores; el titular recibe un aviso neutral.
- Menores de 15 años: representa el tutor legal; de 15 a 17 años pueden consentir ellos mismos y se les informa con claridad (LOPDP art. 21; Reglamento art. 19). Personas con discapacidad o bajo tutela: verificación documental en ventanilla.
- La revocación o el vencimiento surten efecto en la siguiente solicitud, sin esperar a que caduque la sesión del representante.

4.5 Notificaciones

Los mensajes por SMS y correo son canales débiles: se pierden, se reenvían y se leen en pantalla bloqueada. Por eso no llevan diagnóstico ni especialidad y no contienen enlaces que abran información.

Evento	Canal	Contenido permitido	Contenido prohibido
Activación de cuenta	Correo	Enlace de activación de un solo uso y caducidad corta	Datos personales; clave
Reserva creada	Portal, correo	«Tiene una cita pendiente de confirmar. Ingrese al portal.»	Especialidad, profesional, diagnóstico
Recordatorio	SMS (con consentimiento) o correo	«Tiene una cita el 12/11 a las 08:30. Ingrese al portal para ver el detalle.»	Especialidad, diagnóstico, enlaces que abran información
Cancelación por la institución	SMS o correo	«Su cita fue reprogramada. Ingrese al portal.»	Motivo clínico
Restricción por inasistencias	Portal y correo	Causa, fecha de fin, canal alterno y cómo apelar	Diagnóstico o historial
Acción de un representante	Correo al titular	«Se gestionó una cita con su delegación.»	Detalle de la cita
Inicio de sesión desde un dispositivo nuevo	Correo	Fecha, hora y cómo revocar	Dirección IP completa

Controles del canal: SPF, DKIM y DMARC en el dominio institucional; remitente verificado; consentimiento previo para el SMS; límite de envíos; registro de entrega. El SMS no es el único segundo factor de los funcionarios, porque el cambio de SIM y la interceptación lo debilitan: se prefiere TOTP o passkey.

4.6 Integraciones

Integración	Se envía	Se recibe	Controles
Servicio de afiliación	Cédula (y fecha de nacimiento solo si el servicio la exige)	Vigente, no vigente o no confirmado; nombres	mTLS o token de servicio rotado; lista blanca de origen; tiempo de espera de pocos segundos; circuito abierto; caché de hasta 15 minutos; esquema validado; no se registran las respuestas completas.
Sistema de agenda	Franja e identificador interno del afiliado	Confirmación o rechazo	Idempotencia con clave estable; reintentos limitados; estado PENDIENTE; conciliación periódica; contrato de encargado.
Proveedor de SMS y correo	Teléfono o correo y texto neutral	Estado de entrega	TLS; contrato de encargado; sin datos clínicos; límite de envíos por destinatario.

Principio: pedir al tercero solo lo necesario, validar todo lo que responde y no inventar el resultado. Si el servicio de afiliación no responde, el portal muestra «no confirmado» y deja el turno en estado PENDIENTE; no afirma cobertura ni confirma un turno que no se persistió.

4.7 Capacidad, almacenamiento y disponibilidad

Las cifras son hipótesis de diseño para fijar un punto de partida; no son resultados de un benchmark ni una garantía. El proveedor de agenda puede ser el cuello de botella: se mide su cuota, latencia y disponibilidad antes de comprometer capacidad.

Magnitud	Hipótesis	Cálculo	Resultado
Solicitudes de afiliados	3.000 usuarios simultáneos; una acción cada 15 s	3.000 ÷ 15	≈ 200 solicitudes por segundo; ráfaga de prueba de 400
Solicitudes de funcionarios	120 funcionarios; una acción cada 10 s	120 ÷ 10	≈ 12 solicitudes por segundo
Escrituras	10 % de las acciones son reservas, cancelaciones o confirmaciones	10 % de 212	≈ 21 escrituras por segundo; ≈ 40 en ráfaga
Turnos al año	50.000 cuentas; 6 citas por cuenta al año	50.000 × 6	300.000 turnos al año
Almacenamiento al año	2 KB por turno, 3 eventos de auditoría de 0,5 KB y 2 KB por cuenta	300.000 × 3,5 KB + 50.000 × 2 KB	≈ 1,15 GB; con factor 3 por índices y margen, ≈ 3,5 GB
Disponibilidad con mantenimiento diario	2 horas diarias sin reservas	22 ÷ 24	91,67 %: incompatible con atención continua
Disponibilidad objetivo	99,9 % mensual	0,1 % de 43.800 minutos	≈ 44 minutos de caída máxima al mes
Recuperación	Objetivos propuestos	—	RPO ≤ 5 minutos y RTO ≤ 30 minutos

Punto de partida para el ensayo: dos nodos de aplicación de 4 vCPU y 8 GB, una base de datos primaria y una réplica de 4 vCPU y 16 GB, un balanceador y respaldos externos. Se ajusta con las pruebas de carga.

Mediciones necesarias para validar el dimensionamiento

1. Uso real de los portales actuales: concurrencia máxima, curva horaria y días pico.
2. Mezcla de lecturas y escrituras, y tiempo entre acciones del usuario, en web y en móvil.
3. Pruebas de carga y de ráfaga con 3.000 y 6.000 usuarios simultáneos: solicitudes por segundo, latencia p95 y p99, tasa de errores, CPU, memoria, conexiones, bloqueos, colas y tiempos de terceros.
4. Comportamiento con la pérdida de un nodo y con latencia alta del servicio de afiliación.
5. Prueba de restauración midiendo RPO y RTO reales.
6. Crecimiento de los registros y del almacenamiento durante un mes de operación.
7. Cuotas y límites contractuales de los servicios de afiliación, agenda y mensajería.

Figura 3. Arquitectura y límites de confianza

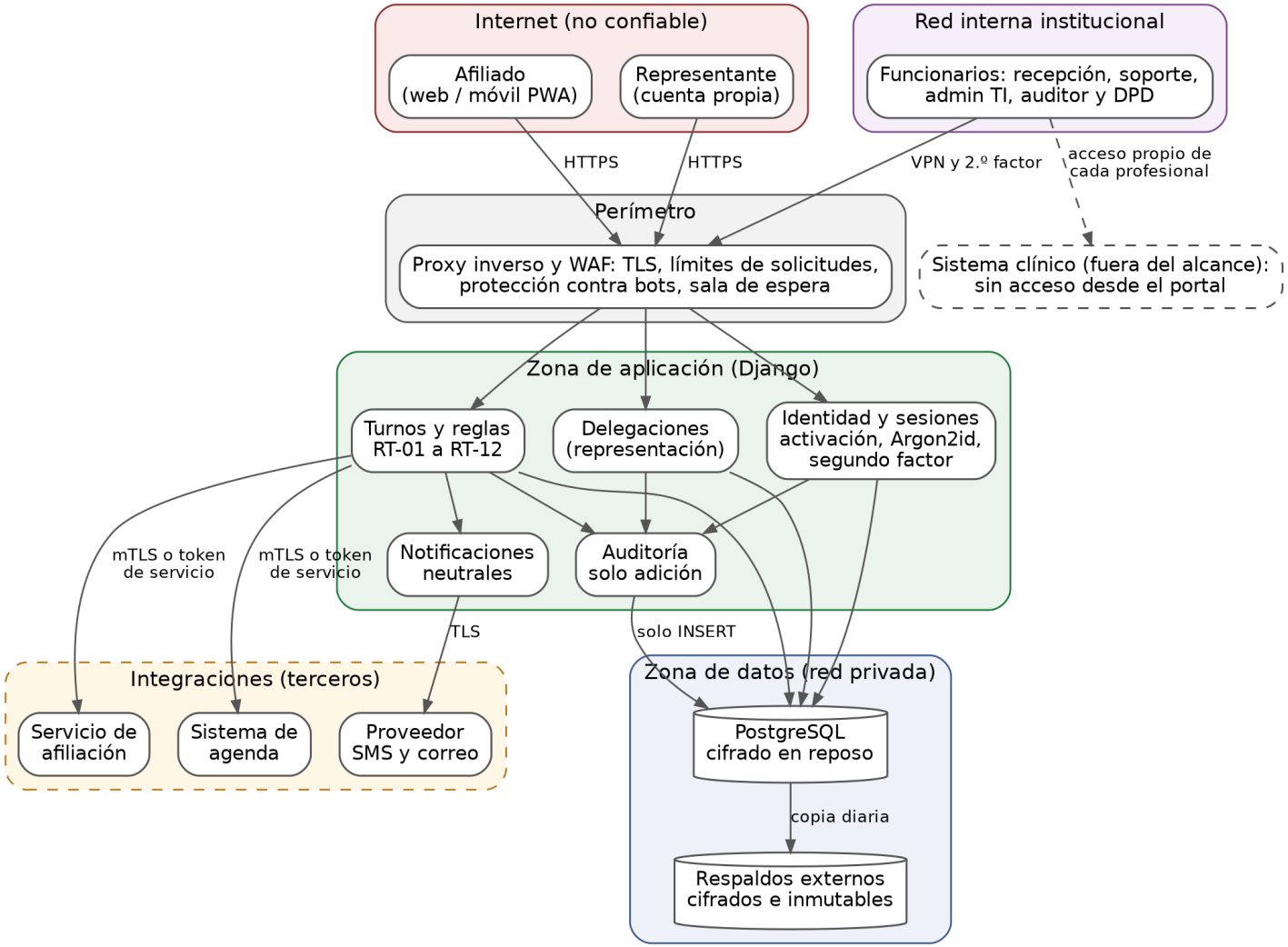


Figura 3. Arquitectura por zonas de confianza. Los flujos que cruzan una frontera exigen TLS, autenticación y límites. El sistema clínico queda fuera del portal.

Figura 4. Representación de familiares

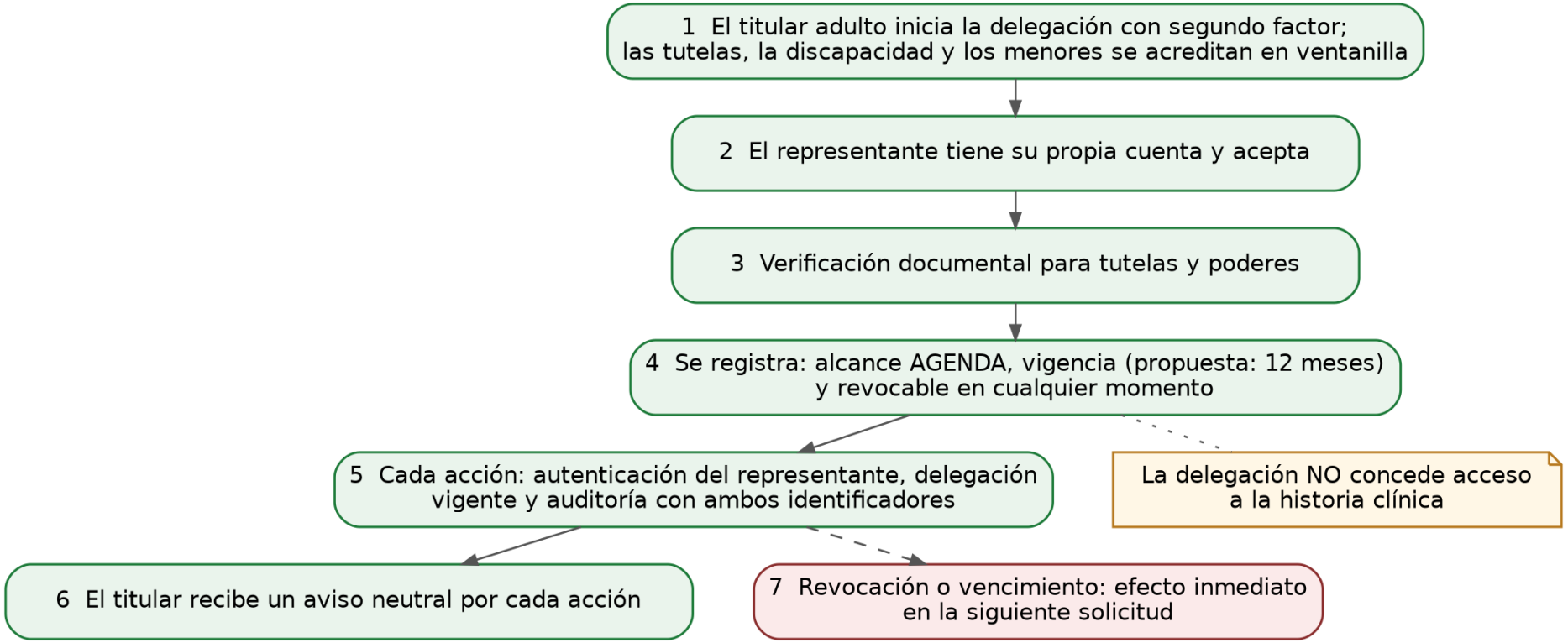


Figura 4. Flujo de una delegación de representación. La delegación no concede acceso a la historia clínica.

5. Selección tecnológica justificada

Se propone Django 5.2 LTS sobre PostgreSQL 18. La elección no se basa en preferencia: se contrastaron cuatro opciones con CVE y CVSS publicados, fechas de soporte y la probabilidad de que el equipo cometa errores al ensamblar la seguridad.

5.1 Criterios y comparación ponderada

Los puntajes de 1 a 5 son un juicio razonado del equipo, no una medición. Se apoyan en la evidencia de la columna final y en las fechas de soporte de la sección 5.3. Los pesos suman 100 %.

Opción	Seguridad por defecto (25 %)	Historial de CVE y parches (20 %)	Ciclo de soporte (15 %)	Error del equipo (20 %)	Encaje con el prototipo (10 %)	Ecosistema de controles (10 %)	Total ponderado	Evidencia principal
Django 5.2 LTS (Python)	5	3	5	4	5	4	4.30	Seguridad incluida en el núcleo (CSRF, escape, ORM, sesiones, hashers). Soporte hasta abril de 2028. Varias CVE de inyección en 2025 y 2026, corregidas con rapidez.
FastAPI y Starlette (Python)	3	3	3	3	4	3	3.10	La autenticación, el CSRF y las sesiones se ensamblan con piezas de terceros. CVE-2026-48710 (BadHost) afectó los controles basados en middleware y llegó al catálogo KEV.
Express (Node.js)	2	3	3	2	4	3	2.65	Núcleo mínimo: casi toda la seguridad depende de middleware y paquetes de npm. CVE en Multer y una ejecución de código sin corrección en expr-eval (9.8).
Spring Boot (Java)	4	3	4	3	2	4	3.40	Seguridad muy completa, pero CVE-2026-40976 (9.1) mostró que la configuración por defecto puede quedar ineficaz; mayor peso y curva para un prototipo.

Criterio (peso)	Qué se evalúa
Seguridad por defecto (25 %)	Qué protecciones trae el framework sin que el equipo las ensamble: CSRF, escape de salida, consultas parametrizadas, hashing de claves y sesiones.
Historial de CVE y parches (20 %)	Frecuencia y gravedad de las vulnerabilidades de 2025 y 2026, rapidez de la corrección y si hubo explotación observada.
Ciclo de soporte (15 %)	Cuánto tiempo recibirá correcciones de seguridad la versión elegida (sección 5.3).
Error del equipo (20 %)	Cuánta de la seguridad depende de que los desarrolladores acierten al configurar y ensamblar piezas, y qué tan fácil es equivocarse.
Encaje con el prototipo (10 %)	Velocidad para construir y explicar en clase un prototipo local con todos los controles.
Ecosistema de controles (10 %)	Disponibilidad de componentes mantenidos para segundo factor, límites de intentos, auditoría y pruebas.

Resultado: Django 5.2 LTS (Python) obtiene 4.30 sobre 5, frente a FastAPI y Starlette 3.10, Express 2.65, Spring Boot 3.40. La ventaja de Django viene de la seguridad por defecto, el soporte extendido y la menor dependencia de piezas ensambladas por el equipo; no de la ausencia de CVE. Spring Boot es una alternativa sólida cuando se dispone de más tiempo y experiencia.

5.2 Evidencia: CVE y CVSS publicados en 2025 y 2026

Estas vulnerabilidades son reales y se consultaron en sus avisos o en fuentes que los reproducen. Se incluyen para tres propósitos: demostrar que ninguna tecnología está libre de fallas, mostrar el tipo de error que se repite y derivar controles concretos.

Tecnología	CVE	Publicación	Qué ocurre	CVSS (fuente)	Lección para este diseño
Django	CVE-2025-64459	5-nov-2025	Inyección SQL en filter(), exclude(), get() y Q() cuando se expande un diccionario manipulado como argumento _connector. Corregida en 5.2.8, 5.1.14 y 4.2.26.	9.1 Crítica (v3.x; aviso del Consejo de Ciberseguridad de los EAU)	No pasar diccionarios de la solicitud a filter() o Q(); lista blanca de campos; parchear.
Django	CVE-2026-1207	3-feb-2026	Inyección SQL en consultas ráster (RasterField, solo PostGIS) por el parámetro del índice de banda. Corregida en 6.0.2, 5.2.11 y 4.2.28. Explotación observada desde el 26-feb-2026.	5.4 Media (CNA de Django); otras fuentes publican 8.1	No habilitar django.contrib.gis si no se usa. El puntaje depende de quién lo calcula.
Django	CVE-2026-33034	7-abr-2026	En ASGI, una cabecera Content-Length ausente o menor que el cuerpo evita el límite de memoria y permite cargar un cuerpo sin límite. Corregida en 6.0.4, 5.2.13 y 4.2.30.	7.5 Alta (v3.0; Tenable)	Limitar el tamaño del cuerpo también en el proxy.
Django	CVE-2026-15307, 15337, 15830 y 15920	4-ago-2026	Cuatro correcciones en 5.2.17 y 6.0.8: escritura de archivos y falsificación de solicitudes por el módulo espacial, dos denegaciones de servicio y un XSS en URLField.	Puntajes no consultados; Django las clasifica como moderadas en los casos revisados	La cadencia de parches de seguridad es de varias por año: se necesita un proceso.
PostgreSQL	CVE-2026-6637	14-may-2026	Extensión refint: desbordamiento de pila que permite ejecutar código como el usuario del sistema operativo, e inyección SQL si la aplicación usa una columna controlada por el usuario como clave primaria en cascada. Corregida en 18.4, 17.10, 16.14, 15.18 y 14.23.	8.8 Alta (v3.1)	No instalar extensiones que no se usan.
PostgreSQL	CVE-2026-2005	12-feb-2026	Extensión pgcrypto: desbordamiento de memoria que permite ejecutar código como el usuario del sistema operativo. Corregida en 18.2, 17.8, 16.12, 15.16 y 14.21.	8.8 Alta (v3.1)	Igual: mínimo de extensiones; hashing de claves en la aplicación con Argon2id.
PostgreSQL	CVE-2026-6478	14-may-2026	Un canal de tiempo en la comparación de claves con hash MD5 permite recuperar credenciales. No afecta a scram-sha-256, el valor por defecto, pero puede haber claves MD5 heredadas de actualizaciones desde PostgreSQL 13 o anterior. Corregida en 18.4, 17.10, 16.14, 15.18 y 14.23.	6.5 Media (v3.1)	Usar SCRAM-SHA-256 y no md5 para la autenticación.
Starlette y FastAPI	CVE-2026-48710 (BadHost)	Divulgación en may-2026; catálogo KEV el 2-sep-2026	La cabecera Host no se validaba al reconstruir request.url; una cabecera mal formada hace que el middleware y el enrutador vean rutas distintas y se salten controles de acceso (CWE-444). Corregida en Starlette 1.0.1.	6.5 Media (GitHub, v3.1); X41 la calificó Alta en v4.0	Autorizar dentro del endpoint, no solo en un middleware. Un puntaje medio puede estar explotado.
Spring Boot	CVE-2026-40976	23-abr-2026	La seguridad web por defecto es ineficaz y permite acceder a todos los endpoints, solo si la aplicación es de servlet, no tiene configuración propia de Spring Security, depende de spring-boot-actuator-autoconfigure y no depende de spring-boot-health (Spring Boot 4.0.0 a 4.0.5; corregida en 4.0.6).	9.1 Crítica (v3.1; vector del aviso de Spring)	No confiar en valores por defecto: probar la autorización.
Spring Boot	CVE-2026-40972	Abr-2026	DevTools: un atacante en la misma red puede, con un ataque de tiempo, descubrir el secreto remoto y llegar a ejecutar código. Corregida en 4.0.6, 3.5.14, 3.4.16, 3.3.19 y 2.7.33.	7.5 Alta (v3.1)	Desactivar herramientas de desarrollo en producción.
npm	CVE-2026-12866 (expr-eval)	23-jun-2026	Ejecución de código por la API toJSFunction(), que compila expresiones con new Function(). Afecta a todas las versiones. NVD no programó su enriquecimiento.	9.8 Crítica (v3.1; aviso de GitLab). NVD no publica puntaje	Una dependencia sin mantenimiento puede quedar sin parche.
Express (Multer)	CVE-2026-3520, 3304 y 2359	Feb y mar-2026	Tres denegaciones de servicio en el middleware de carga de archivos: 3520 (desbordamiento de pila, corregida en Multer 2.1.1), 3304 y 2359 (agotamiento de recursos, corregidas en 2.1.0).	7.5 Alta cada una	La seguridad de Express depende de middleware de terceros.

Los puntajes de Django, PostgreSQL y Spring se leyeron en avisos del proveedor o en espejos de sus notas de versión; los de CVE-2025-64459, CVE-2026-33034 y CVE-2026-48710 provienen de avisos de terceros (CSC de los EAU, Tenable y GitHub). Las descripciones y las versiones afectadas y corregidas se verificaron en las fichas de NVD; falta contrastar el puntaje y el vector con la ficha, y NVD no publica puntaje para CVE-2026-12866.

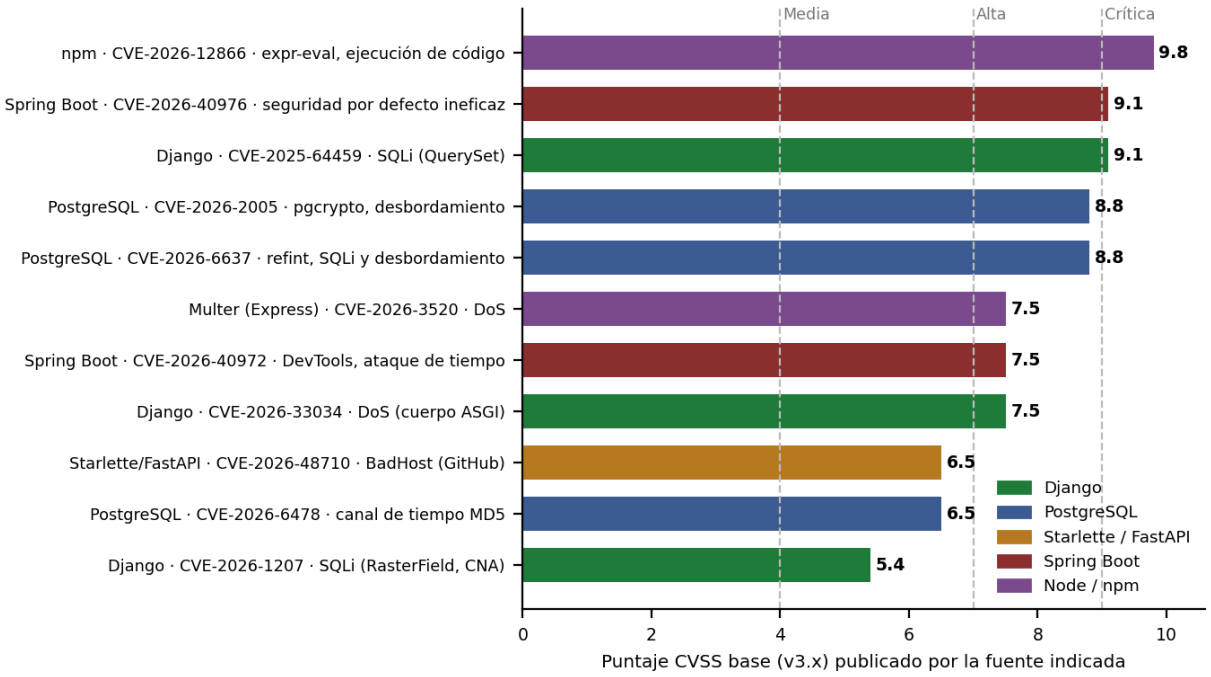


Figura 5. Puntaje CVSS base publicado para las vulnerabilidades consultadas. El puntaje mide severidad técnica, no el riesgo para el IESS.

Qué enseñan estos casos sobre CVSS

- **El puntaje depende de quién lo calcula.** CVE-2026-1207 tiene 5,4 según el CNA de Django y 8,1 según otras fuentes, y se explotó en la práctica. CVE-2026-48710 es 6,5 en GitHub y «Alta» para X41 con CVSS 4.0.
- **Un puntaje medio puede estar explotado.** CVE-2026-48710 entró al catálogo KEV de CISA el 2 de septiembre de 2026. Por eso la prioridad combina CVSS, explotación observada y exposición.
- **La configuración cuenta.** CVE-2026-40976 es crítica solo en una combinación de dependencias y configuración; si el sistema no la cumple, no es vulnerable. Lo mismo vale para CVE-2026-1207: sin django.contrib.gis no aplica.
- **El mismo tipo de error se repite.** Inyección SQL en un ORM (Django), en extensiones de base de datos (PostgreSQL) y en middleware (Starlette): los controles de entrada y de autorización deben estar en varias capas.

5.3 Ciclo de vida y fechas de soporte

Componente	Versión	Fin de soporte	Decisión
Django 5.2 LTS	5.2.17 (ago-2026)	Abril de 2028 (soporte extendido)	Usar, con el último parche al iniciar el prototipo
Django 6.0	6.0.8	Abril de 2027	No usar: soporte corto y sin LTS
Django 6.1	6.1	Diciembre de 2027 (extendido)	No usar: soporte corto y sin LTS
Django 4.2 LTS	4.2.30	Terminó el 7-abr-2026	No usar: sin parches de seguridad
PostgreSQL 18	18.6	14-nov-2030	Usar. PostgreSQL 19 está en candidata de lanzamiento desde el 15-oct-2026; se mantiene la 18 por su mayor madurez
PostgreSQL 17	17.11	8-nov-2029	Alternativa aceptable
PostgreSQL 14	14.24	12-nov-2026	No usar: deja de recibir correcciones en pocos días
Python 3.13 y 3.14	3.13 en fase de seguridad; 3.14 en fase de correcciones	3.13: octubre de 2029. 3.14: octubre de 2030	Elegir una de las dos; confirmar su compatibilidad con Django 5.2

Fuentes: página oficial de descargas de Django (soporte extendido de 5.2 LTS hasta abril de 2028 y 4.2 terminado el 7-abr-2026), la política de versiones de postgresql.org y la guía de desarrolladores de Python (devguide.python.org), estas dos consultadas el 30-oct-2026. El siguiente LTS de Django (6.2) está previsto para abril de 2027: la migración se planifica antes de abril de 2028. En Python, una versión pasa a solo seguridad a los dos años y llega al fin de vida a los cinco.

5.4 Recomendación de pila y justificación

Decisión	Tecnología	Por qué	Riesgo asociado y mitigación
Lenguaje y framework	Python y Django 5.2 LTS	Trae CSRF, escape automático, ORM con consultas parametrizadas, sesiones, validadores de clave y soporte de Argon2: menos seguridad depende de que el equipo ensamble piezas. Soporte hasta abril de 2028.	Inyección SQL en filter(), exclude(), get() y Q() cuando se expande un diccionario manipulado como argumento _connector. Corregida en 5.2.8, 5.1.14 y 4.2.26.
Base de datos	PostgreSQL 18	Índices únicos parciales y restricciones de exclusión para RT-01 a RT-04, transacciones, autenticación SCRAM-SHA-256 y soporte hasta noviembre de 2030.	CVE en extensiones: instalar solo lo necesario y aplicar cada versión menor.
Contraseñas	Argon2id (argon2-cffi, integrado en Django)	Función especializada y con memoria; la guía de OWASP sobre almacenamiento de contraseñas la prioriza.	Parámetros según la guía vigente de OWASP; revisarlos con pruebas de rendimiento.
Segundo factor	TOTP (por ejemplo, django-otp); passkeys como mejora	Resistente al cambio de SIM; el SMS queda como aviso, no como único factor.	Recuperación de cuenta solo con verificación en ventanilla.
Límite de intentos	django-axes o implementación propia	Bloqueo progresivo por cuenta y origen (RT-09, R05, R18).	Evitar que el bloqueo sirva para dejar sin acceso a otra persona: tiempos cortos y avisos.
Servidor	Gunicorn detrás de un proxy inverso (nginx o Caddy)	TLS, límites de tamaño y de tiempo, cabeceras de seguridad.	Configuración del proxy en el repositorio y revisada.
Calidad y seguridad en CI	pytest, pip-audit, Bandit, OWASP ZAP, gitleaks	Cubren pruebas, dependencias vulnerables, análisis estático, análisis dinámico y secretos (T14, T15).	Herramientas de uso común: confirmar versiones al instalarlas.
Entorno local	Docker Compose con red interna	Reproduce la separación aplicación y base de datos y los respaldos.	Sin puertos de base de datos expuestos al anfitrión.

5.5 Configuración segura del framework y errores típicos

La mayor parte del riesgo de un framework seguro viene de cómo se configura y de los atajos del desarrollador. La primera tabla es la lista de verificación de la configuración; la segunda recoge errores frecuentes y su control de revisión.

Ajuste de Django	Valor	Riesgo que evita
DEBUG	False en toda operación que no sea el desarrollo	Páginas de error con rutas, variables y secretos
ALLOWED_HOSTS	Lista explícita de dominios	Ataques por cabecera Host (comparar con BadHost)
SECRET_KEY	Desde el entorno o un gestor de secretos; nunca en el repositorio	Falsificación de sesiones y tokens
SECURE_SSL_REDIRECT y HSTS	Activos	Tráfico sin cifrar y degradación a HTTP
SESSION_COOKIE_SECURE, HTTPONLY y SAMESITE	True, True y Lax o Strict	Robo de cookie y CSRF (R19)
CSRF_COOKIE_SECURE y CsrfViewMiddleware	Activos; sin @csrf_exempt	Acciones no deseadas desde otro sitio (R16)
X_FRAME_OPTIONS y SECURE_CONTENT_TYPE_NOSNIFF	DENY y True	Clickjacking y sniffing de tipos
PASSWORD_HASHERS	Argon2id primero	Hash débil (R05)
AUTH_PASSWORD_VALIDATORS	Longitud, comunes y similitud con datos personales	Claves predecibles (R05)
Sesiones	Duración de 24 horas e inactividad de 1 hora en operaciones sensibles; serializador JSON	Sesiones largas (R19)
Verificación previa al despliegue	python manage.py check --deploy sin advertencias	Configuración insegura (OWASP A02)
Registros	Filtro que redacta contraseñas, tokens y cuerpos	Secretos en registros (R08)

Error frecuente del desarrollador	Consecuencia	CWE	Control de revisión
Pasar request.GET o request.POST como argumentos de filter()	Inyección o acceso a campos no previstos (como CVE-2025-64459)	CWE-89, CWE-915	Lista blanca de campos filtrables y revisión de código
SQL crudo con f-strings	Inyección SQL	CWE-89	Prohibir SQL crudo; análisis estático con Bandit
ModelForm con fields = '__all__'	Asignación masiva (el usuario cambia campos que no debía)	CWE-915	Declarar campos explícitos
mark_safe o |safe con datos del usuario	XSS	CWE-79	Mantener el escape automático y la CSP
@csrf_exempt en vistas con cookies	CSRF	CWE-352	Prohibido sin justificación escrita

Error frecuente del desarrollador	Consecuencia	CWE	Control de revisión
Autorizar solo la vista de lista y no la de detalle	Acceso a objetos ajenos (IDOR)	CWE-639	Pruebas de autorización por objeto (T13)
Redirigir al parámetro next sin validarlo	Redirección abierta y phishing	CWE-601	Validar con url_has_allowed_host_and_scheme
DEBUG activo o SECRET_KEY en el repositorio	Fuga de secretos	CWE-215, CWE-798	check --deploy y gitleaks
Registrar request.POST completo	Contraseñas en los registros	CWE-532	Filtro de redacción (T06)
Reservar sin transacción ni restricción única	Doble reserva	CWE-362	Restricciones en la base y prueba concurrente (T07)
Mensajes de error distintos según la cédula	Enumeración de afiliados	CWE-204	Mensajes genéricos (T03)

5.6 Gestión de parches y dependencias

Se mantiene una lista de componentes (SBOM), se fijan las versiones y se escanean en cada integración. Los plazos son propuestas del equipo; el IESS los aprueba.

Severidad	Plazo propuesto	Ajuste por contexto
Crítica (CVSS 9,0 o más) o incluida en el catálogo de vulnerabilidades explotadas (KEV)	72 horas	Si hay explotación activa, siempre cuenta como crítica, aunque el puntaje sea medio
Alta (7,0 a 8,9)	7 días	Subir un nivel si el componente está expuesto a Internet
Media (4,0 a 6,9)	30 días	Bajar un nivel solo con evidencia de que la función afectada no se usa
Baja (menos de 4,0)	Próximo ciclo de mantenimiento	Registrar la decisión

Si un componente vulnerable no se usa (por ejemplo, GIS), se documenta «no aplica» con la evidencia de que no está instalado ni habilitado. Si hay explotación activa en el catálogo KEV, se trata como crítica.

6. Errores del usuario y diseño defensivo

Muchos incidentes empiezan con un error humano razonable. El diseño asume que el afiliado y el funcionario se equivocarán y reduce el daño con confirmaciones, mensajes claros y límites. Este análisis alimenta los riesgos R14, R19 y R20.

Error del usuario	Consecuencia	Diseño defensivo
Compartir la clave con un familiar para que «ayude»	Pérdida de control de la cuenta y exposición de citas	Delegación formal (§4.4), aviso al titular y mensajes que expliquen por qué no compartir la clave.
Doble clic o reintento al reservar	Dos turnos o un error confuso	Idempotencia, botón que se desactiva y mensaje claro (RT-04).
Cancelar sin querer	Pérdida de un turno difícil de conseguir	Confirmación antes de cancelar y opción de deshacer durante 10 minutos si el cupo sigue libre.
Elegir mal especialidad, establecimiento o fecha	Cita inútil e inasistencia	Resumen antes de confirmar y primera reprogramación sin penalización (RT-07).
Olvidar la cita	Inasistencia y cupo perdido	Recordatorios neutrales a las 72 y 24 horas, con acceso directo a cancelar.
Escribir mal el correo o el teléfono	Avisos que llegan a otra persona	Verificación con código y datos enmascarados en pantalla.
Usar equipos compartidos y no cerrar sesión	Acceso de terceros	Cierre por inactividad, aviso de equipo compartido y sin función de «recordarme» (NIST SP 800-63B-4).
Responder a mensajes falsos (phishing)	Robo de credenciales	Comunicación oficial con dominio verificado; el sistema nunca pide la clave por mensaje; alerta de dispositivo nuevo.
Perder el teléfono del segundo factor	Bloqueo de la cuenta o acceso de un tercero	Revocación remota y recuperación verificada en ventanilla.
Ingresar la cédula de un familiar sin delegación	Rechazo y frustración, o intento de suplantación	Mensaje claro con el camino correcto: iniciar una delegación o acudir a ventanilla.
Elegir una clave débil	Cuenta vulnerable	Validación contra claves filtradas, longitud mínima e indicador de fortaleza.
Confundir cédulas al representar	Datos de otra persona	Mostrar los nombres devueltos por la afiliación para confirmar antes de operar.
Personal: compartir una cuenta, consultar por curiosidad o enviar capturas por chat	Fuga de datos de pacientes y pérdida de responsabilidad	Cuentas individuales, auditoría con alertas, capacitación y acuerdo de confidencialidad.

7. Matriz de riesgos

Se identificaron 23 riesgos. Sin controles, 6 son críticos, 16 son altos y 1 es medio. Con los controles implementados y funcionando, 13 quedan medios y 10 bajos; ninguno queda alto o crítico.

7.1 Escala de valoración y procedimiento

Valor	Probabilidad (en un año de operación)	Impacto (consecuencia más grave)
1	Excepcional: requiere condiciones muy restringidas	Menor: sin afectación de derechos; recuperable
2	Poco probable: exige acceso especial o varias condiciones	Limitado: pocos registros o una breve interrupción
3	Plausible: hay un actor y una ruta razonables	Relevante: un proceso o varios titulares afectados
4	Probable: exposición amplia y barreras débiles	Importante: datos de salud, fraude o interrupción amplia de la atención
5	Muy probable: condición repetible o acceso casi irrestricto	Grave: compromiso masivo, daño irreversible o sanción grave

Nivel = probabilidad × impacto	Clasificación	Prioridad y respuesta
20 a 25	Crítico	P1: no se opera sin los controles implementados y verificados
10 a 16	Alto	P2: controles antes del lanzamiento o plan con fecha y responsable
5 a 9	Medio	P3: controles en la segunda fase y vigilancia
1 a 4	Bajo	P4: se acepta y se monitorea

Procedimiento.

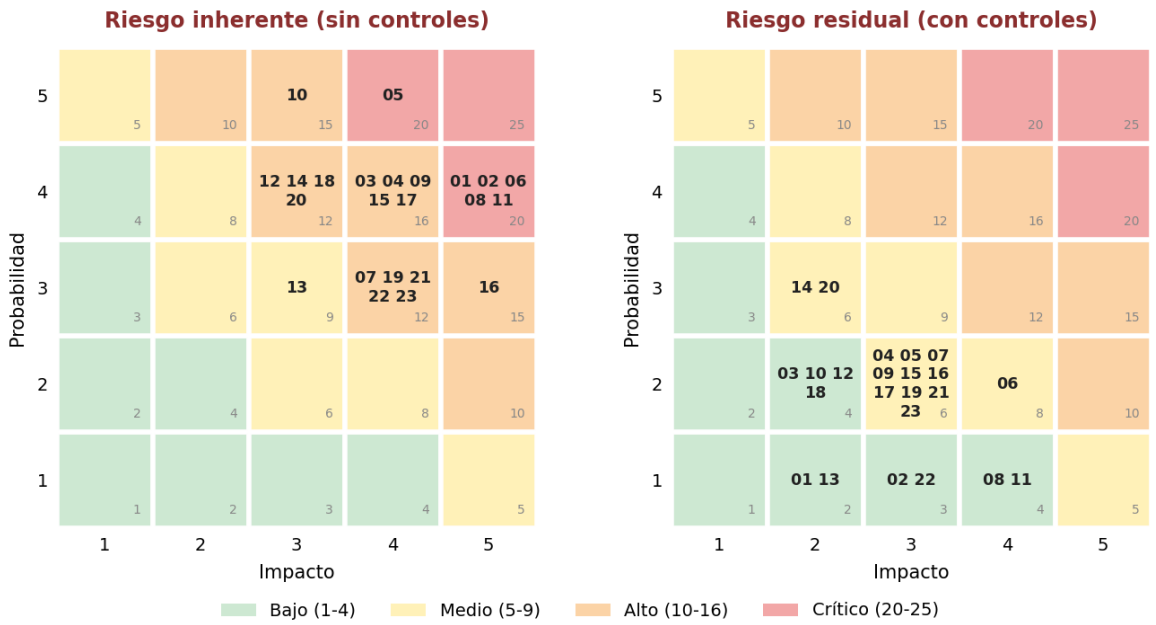
1. Identificar el activo o dato y el requisito del cliente que lo origina.
2. Separar tres cosas: la **amenaza** (quién o qué puede causar daño), la **vulnerabilidad** (la condición que lo permite) y la **consecuencia** (lo que ocurre si se materializa).
3. Valorar probabilidad e impacto inherentes, es decir, sin controles, justificando cada valor con la escala.
4. Multiplicar, asignar la clasificación y la prioridad. Un impacto 5 exige revisión específica aunque el nivel sea medio.
5. Definir controles preventivos (P), detectivos (D) y correctivos (C), cómo se verifican, y revalorar probabilidad e impacto suponiendo que los controles se implementan y funcionan.
6. Justificar el riesgo residual indicando qué factor baja y por qué.

El análisis considera las particularidades del tratamiento, de las partes y de las categorías y el volumen de los datos, como exige la LOPDP (arts. 40 y 41). Las puntuaciones son estimaciones razonadas para priorizar, no frecuencias medidas. La escala 5 × 5 es una práctica común; NIST SP 800-30 e ISO/IEC 27005 pueden citarse como referencia metodológica y no se consultaron en esta sesión.

7.2 Amenaza, vulnerabilidad y consecuencia: un ejemplo

Concepto	Definición	Ejemplo en este sistema (R05)
Amenaza	Actor o evento con capacidad de causar daño	Un atacante que prueba fechas de nacimiento como contraseñas
Vulnerabilidad	Condición que permite que la amenaza prospere	La clave inicial es la fecha de nacimiento y el cambio es opcional (CWE-521)
Consecuencia	Daño si se materializa	Toma masiva de cuentas y acceso a citas y datos de salud
Riesgo	Posibilidad de que ocurra y gravedad de la consecuencia	Probabilidad 5 por impacto 4 = 20: crítico

7.3 Mapa de calor



Los números dentro de cada celda son los identificadores de riesgo (R01 a R23).

Figura 6. Distribución de los 23 riesgos antes y después de los controles.

7.4 Prioridades de tratamiento

Los riesgos P1 son R01, R02, R05, R06, R08, R11. Los de recolección y cesión de datos (R01, R02, R11) se eliminan por diseño: el dato no existe, así que el riesgo no depende de un control técnico. Los demás (R05, R06, R08) exigen controles implementados antes de cualquier operación y son los primeros que el prototipo demuestra en clase. Las tablas completas del registro siguen en las páginas apaisadas (7.5 a 7.7).

7.5 Registro de riesgos: identificación y escenario

ID y requisito	Activo o dato	Amenaza	Vulnerabilidad o condición	Escenario y consecuencia	Propiedad
R01 I03, I05	Datos laborales, bancarios, religiosos y políticos de los afiliados	Atacante externo o funcionario que consulta o filtra los datos	Se recolectan sin finalidad y se guardan junto a la cuenta (CWE-359)	Una filtración expone sueldo, cuenta bancaria, religión y filiación política; hay discriminación y fraude	C
R02 I04	Diagnósticos, antecedentes, medicamentos, alergias y laboratorio	Funcionario curioso o atacante externo	Se exigen antes de mostrar horarios y se guardan en la agenda (CWE-359)	Se expone la salud de afiliados y hay discriminación o extorsión	C
R03 I09	Mensajes SMS y correo; enlace de acceso directo	Tercero que ve o reenvía el mensaje; atacante que obtiene el enlace	Diagnóstico en el mensaje y enlace que abre información sin autenticar (CWE-306)	Un familiar o un compañero lee el diagnóstico; el enlace reenviado da acceso a datos y acciones	C, A
R04 I06	Turnos y datos de otra persona	Tercero que conoce la cédula y la fecha de nacimiento	La representación solo exige datos conocidos por terceros (CWE-287)	Se consultan, cancelan o reservan citas ajenas; se revela atención médica y se afecta el acceso	C, I, A
R05 I07	Cuentas de afiliados y de funcionarios	Atacante que prueba fechas de nacimiento y claves comunes	Clave inicial igual a la fecha de nacimiento, cambio opcional y sin bloqueo (CWE-521, CWE-307)	Toma masiva de cuentas; acceso a citas y datos de salud	C, I, A
R06 I08	Expedientes y agenda completos	Funcionario curioso o malicioso; cuenta robada	Todos los roles ven todo (CWE-862, CWE-863)	Consulta masiva y venta o filtración de datos clínicos	C, R
R07 I10	Servicios de afiliación y de agenda	Servicio falso o comprometido; atacante en la red; falla del tercero	Sin autenticación mutua, validación de respuestas ni tiempos de espera (CWE-295, CWE-345)	Cobertura falsa, turno no persistido o datos expuestos en tránsito; la caída del tercero arrastra al portal	I, D, C
R08 I11	Registros de auditoría y de soporte	Soporte curioso o intruso que lee los registros	Se guardan contraseñas, tokens y cuerpos completos (CWE-532)	Suplantación masiva de identidades y difusión de datos clínicos	C, T
R09 I12	Servicio y base de datos	Falla de hardware o de energía; atacante que compromete el equipo	Una computadora de oficina de 8 GB hace de aplicación y base de datos	Caída total, pérdida de datos y compromiso de la base desde la aplicación	D, C, I
R10 I13	Reservas durante el mantenimiento	Mantenimiento programado; atacante que lo aprovecha	Dos horas diarias sin reservas	Disponibilidad máxima de 91,67 %; vuelven las filas y las llamadas	D
R11 I14	Base completa de afiliados y su información de salud	Proveedor externo; reutilización secundaria	Entrega general para entrenar IA y conservación indefinida	Reidentificación, uso no autorizado, sanción y pérdida de control sobre los datos	C, P
R12 I01	Cupos de atención	Persona o bot que acapara turnos con varias reservas o varias cédulas	Sin límite de turnos activos ni de frecuencia (CWE-799, CWE-770)	Los cupos se agotan en pocas manos y los afiliados reales quedan sin cita	D, U
R13 I01	Franjas de la agenda	Solicitudes simultáneas y reintentos	Reserva sin transacción atómica ni idempotencia (CWE-362, CWE-367)	Dos afiliados con la misma franja o confirmaciones falsas	I, D
R14 I01	Turnos no utilizados	Reservas sin intención de asistir; olvidos; sanciones automáticas injustas	Sin confirmación ni política de inasistencias	Cupos perdidos y filas; o bloqueos injustos a quien no pudo asistir	D, U
R15 I01, I06	Citas y datos de otros afiliados vía API	Afiliado autenticado que manipula identificadores	Sin autorización a nivel de objeto (CWE-639)	Consulta o cancelación de citas ajenas y fuga de datos	C, I
R16 Transversal	Formularios, API y base de datos	Atacante externo	Validación insuficiente: inyección SQL, XSS y CSRF (CWE-89, CWE-79, CWE-352)	Lectura o alteración de la base de datos; scripts en el navegador; acciones no deseadas	C, I, D
R17 Transversal	Framework, lenguaje y dependencias	Atacante que explota un CVE publicado	Componentes sin parchear o fuera de soporte (CWE-1395, CWE-1104)	Explotación de una vulnerabilidad conocida (por ejemplo, inyección SQL o denegación de servicio)	C, I, D
R18 I02, I07	Pertenencia de una cédula al sistema	Atacante que enumera cédulas	Respuestas distintas para cédula inexistente y clave incorrecta (CWE-204)	Se confirma quién es afiliado; sirve para phishing y suplantación	C
R19 I07	Sesiones de usuarios	Atacante con una cookie robada; equipos compartidos (cabinas, centros de atención)	Sesión larga sin cierre por inactividad (CWE-613, CWE-384)	Acceso a citas y datos durante días	C, I
R20 I07, I09	Cuentas y confianza en las notificaciones	Phishing a afiliados y funcionarios	Mensajes legítimos y falsos se parecen; las claves se reutilizan	Robo de credenciales y fraude	C
R21 I01, I12	Servicio de búsqueda y reserva	Bots y tráfico malicioso	Sin cuotas, límites por ruta ni caché (CWE-770)	Se agotan las conexiones y los afiliados no pueden reservar	D
R22 I11	Registros de auditoría	Funcionario o atacante que altera o borra registros	Permisos de edición y sin integridad (CWE-117, CWE-778)	Se pierde evidencia: no se puede atribuir ni demostrar no repudio	I, T, R
R23 Transversal	Capacidad de detectar y notificar incidentes	Cualquier atacante; error humano	Sin monitoreo, plan de respuesta ni responsables (CWE-778)	Una vulneración pasa semanas sin detectarse y no se notifica a tiempo	C, I, D

Propiedades: C confidencialidad, I integridad, D disponibilidad, A autenticidad, T trazabilidad, R responsabilidad, U utilidad, P posesión o control.

7.6 Registro de riesgos: valoración, controles, verificación y riesgo residual

ID	Probabilidad y justificación	Impacto y justificación	Nivel y prioridad	Controles propuestos (P preventivo, D detectivo, C correctivo)	Verificación	Riesgo residual y justificación
R01	**4**. Son datos atractivos y estarían en la misma base de las cuentas.	**5**. Datos sensibles y financieros de hasta 50.000 personas; sanción grave.	4×5 = 20 **Crítico**, P1	**P:** No recolectar: esquema sin esos campos y revisión de formularios. **D:** Inventario de tratamientos y escaneo de campos del esquema. **C:** Eliminación segura si se detecta algún dato excluido.	T01: reservar sin esos campos y revisar que no existen en la base.	1×2 = 2 **Bajo**. El dato no existe. Queda el riesgo de que un cambio futuro lo reintroduzca; lo cubre la revisión de diseño.
R02	**4**. Dato de alto valor, accesible a todos los roles según I08.	**5**. Categoría especial (art. 25 LOPDP); daño difícil de revertir.	4×5 = 20 **Crítico**, P1	**P:** Separar agenda y sistema clínico; la agenda no almacena datos de salud. **D:** Revisión del esquema y alertas por campos clínicos. **C:** Purga de los datos clínicos que se hubieran copiado.	T01: la reserva funciona sin datos de salud; el esquema no tiene esos campos.	1×3 = 3 **Bajo**. Solo queda un motivo mínimo codificado, sin texto libre.
R03	**4**. Los mensajes se reenvían y se ven en pantalla bloqueada.	**4**. Revela salud y permite acciones en nombre del afiliado.	4×4 = 16 **Alto**, P2	**P:** Mensajes neutrales; enlace sin datos que exige iniciar sesión; token de un solo uso y con caducidad. **D:** Alerta si un token se usa desde orígenes distintos. **C:** Invalidar el token y avisar al afiliado.	T05: reenviar el enlace y abrirlo sin sesión no muestra datos.	2×2 = 4 **Bajo**. El horario o el remitente aún sugiere una relación asistencial, pero sin diagnóstico ni acceso.
R04	**4**. Cédula y fecha de nacimiento circulan ampliamente.	**4**. Afecta la atención de la persona y revela su relación con el servicio.	4×4 = 16 **Alto**, P2	**P:** Delegación autenticada con alcance, vigencia y revocación; verificación documental de tutelas. **D:** Aviso al titular por cada acción del representante. **C:** Revocar la delegación y restaurar el turno.	T02: operar sin delegación y con delegación revocada.	2×3 = 6 **Medio**. Un documento falso de tutela puede pasar; lo reduce la revisión humana en ventanilla.
R05	**5**. La regla permite generar la clave de cualquier afiliado.	**4**. Compromete acciones y datos de salud de miles de cuentas.	5×4 = 20 **Crítico**, P1	**P:** Activación con secreto de un solo uso; clave propia con verificación de claves filtradas; Argon2id; bloqueo progresivo; segundo factor (TOTP o passkey) para funcionarios. **D:** Alertas por intentos distribuidos y por inicios desde dispositivos nuevos. **C:** Restablecimiento verificado y revocación de sesiones.	T03: clave biográfica rechazada, activación no reutilizable, bloqueo tras fallos.	2×3 = 6 **Medio**. Siguen posibles el phishing y el equipo comprometido del afiliado.
R06	**4**. Con 120 funcionarios y acceso total, el abuso es plausible.	**5**. Salud de miles de pacientes; no se puede deshacer.	4×5 = 20 **Crítico**, P1	**P:** RBAC más relación asistencial; denegar por defecto; enmascaramiento; segundo factor. **D:** Auditoría con alertas por consultas anómalas y revisión trimestral de accesos. **C:** Retiro de privilegios e investigación.	T04: matriz de permisos por rol y paciente.	2×4 = 8 **Medio**. El acceso clínico legítimo se mantiene; se vigila con auditoría.
R07	**3**. Las integraciones son un punto de confianza frecuente.	**4**. Confirmaciones erróneas y caída del servicio de reservas.	3×4 = 12 **Alto**, P2	**P:** TLS con validación de certificado, autenticación entre servicios, lista blanca, tiempos de espera, circuito abierto e idempotencia. **D:** Monitoreo de latencia, errores y vencimiento de certificados. **C:** Modo degradado con estado pendiente y conciliación.	T07: simular tiempo de espera y respuesta alterada.	2×3 = 6 **Medio**. Depende de las garantías del sistema externo.
R08	**4**. Cada solicitud reproduce el secreto en el registro.	**5**. Un solo archivo concentra credenciales de todos los usuarios.	4×5 = 20 **Crítico**, P1	**P:** Lista blanca de campos, redacción de secretos y registros estructurados; acceso restringido. **D:** Escaneo de secretos en los registros. **C:** Rotación de las credenciales expuestas.	T06: enviar marcadores ficticios y comprobar que no aparecen.	1×4 = 4 **Bajo**. Un fallo de instrumentación futuro podría reintroducirlo; lo cubre la revisión continua.
R09	**4**. Un único equipo sin redundancia ni aislamiento.	**4**. Se detiene la atención de miles de afiliados.	4×4 = 16 **Alto**, P2	**P:** Aplicación y base de datos separadas, redundancia y respaldos externos inmutables. **D:** Monitoreo de recursos y de salud de los servicios. **C:** Plan de recuperación ante desastres.	T08: retirar un nodo y restaurar un respaldo midiendo RPO y RTO.	2×3 = 6 **Medio**. Quedan fallas de terceros y regionales.
R10	**5**. La interrupción ocurre todos los días por diseño.	**3**. Afecta a los usuarios que reservan en esa franja.	5×3 = 15 **Alto**, P2	**P:** Despliegues graduales sin interrupción; ventana mensual excepcional y anunciada. **D:** Medición del objetivo de disponibilidad. **C:** Plan de contingencia con canal presencial.	T08: medir disponibilidad durante un despliegue.	2×2 = 4 **Bajo**. Quedan interrupciones no planificadas.
R11	**4**. Se pide la cesión de toda la base.	**5**. Datos sensibles de 50.000 afiliados; pérdida de control irreversible.	4×5 = 20 **Crítico**, P1	**P:** Eliminar la entrega; contrato con cláusulas; plazos de conservación; anonimización autorizada para estadísticas. **D:** Registro de comunicaciones a terceros. **C:** Exigir eliminación y devolución al proveedor.	T10 y T11: inspeccionar campos y contratos; ejecutar el vencimiento.	1×4 = 4 **Bajo**. No se puede deshacer una divulgación ya producida.

ID	Probabilidad y justificación	Impacto y justificación	Nivel y prioridad	Controles propuestos (P preventivo, D detectivo, C correctivo)	Verificación	Riesgo residual y justificación
R12	**4**. El servicio es público y la automatización es sencilla.	**3**. Cientos de afiliados sin acceso oportuno.	4×3 = 12 **Alto**, P2	**P:** RT-01 a RT-04, RT-08 y RT-09: una cita activa por especialidad, tope de citas activas, anti-automatización. **D:** Alertas por patrones (una IP con muchas cédulas). **C:** Liberar los cupos acaparados.	T16: intentar segunda reserva y reservas masivas.	2×2 = 4 **Bajo**. Un actor con varias cuentas legítimas puede acaparar poco.
R13	**3**. Es habitual perder respuestas y repetir solicitudes.	**3**. Reclamos y atención interrumpida.	3×3 = 9 **Medio**, P3	**P:** Índice único parcial por franja, bloqueo de fila e idempotencia. **D:** Conciliación periódica agenda contra portal. **C:** Reasignar el turno y avisar.	T07: dos solicitudes simultáneas por la última franja.	1×2 = 2 **Bajo**. La restricción única impide el duplicado a nivel de base.
R14	**4**. Las inasistencias son frecuentes en agendas públicas.	**3**. Pierden los afiliados que sí necesitaban el cupo.	4×3 = 12 **Alto**, P2	**P:** Confirmación, liberación automática, bloqueo temporal proporcional y apelación humana (RT-05 a RT-07). **D:** Indicadores de inasistencia por unidad. **C:** Revertir la sanción si se justifica.	T17: escenarios de inasistencia, justificación y apelación.	3×2 = 6 **Medio**. Habrá inasistencias legítimas que no se pueden eliminar.
R15	**4**. Cambiar un identificador es trivial y muy común.	**4**. Miles de turnos y datos de otras personas.	4×4 = 16 **Alto**, P2	**P:** Autorización por objeto en el servidor e identificadores no secuenciales. **D:** Alertas por respuestas 403 repetidas. **C:** Invalidar sesiones y notificar si hubo exposición.	T13: cambiar el identificador de un turno con otra cuenta devuelve 403.	2×3 = 6 **Medio**. Pueden quedar fallos de lógica no cubiertos por las pruebas.
R16	**3**. Aplicación expuesta a Internet con formularios.	**5**. Lectura o alteración de toda la base.	3×5 = 15 **Alto**, P2	**P:** ORM y consultas parametrizadas, autoescape, token CSRF, CSP, validación en el servidor y WAF. **D:** Alertas de WAF y de errores de base de datos. **C:** Parchear, aislar y restaurar.	T14: cargas de inyección y análisis dinámico; el ataque falla.	2×3 = 6 **Medio**. Pueden aparecer vulnerabilidades nuevas en dependencias.
R17	**4**. Los frameworks publican correcciones de seguridad varias veces al año.	**4**. Hasta compromiso de la base según el CVE.	4×4 = 16 **Alto**, P2	**P:** Versiones con soporte (LTS), análisis de dependencias en CI, SBOM y plazos de parcheo. **D:** Alertas de nuevos CVE y del catálogo KEV. **C:** Parche de emergencia y reversión.	T15: escaneo de dependencias sin hallazgos críticos abiertos.	2×3 = 6 **Medio**. Siempre existe una ventana entre la publicación del CVE y el parche.
R18	**4**. La cédula es un número secuencial y fácil de probar.	**3**. Confirma datos personales de muchas personas.	4×3 = 12 **Alto**, P2	**P:** Mensajes genéricos, tiempos de respuesta constantes y límites por origen. **D:** Alertas por consultas de muchas cédulas. **C:** Bloqueo temporal del origen.	T03: la respuesta no distingue cédula inexistente de clave incorrecta.	2×2 = 4 **Bajo**. La enumeración lenta y distribuida es difícil de detectar.
R19	**3**. Los equipos compartidos son comunes.	**4**. Acceso persistente a datos de salud.	3×4 = 12 **Alto**, P2	**P:** Sesión de 24 h y 1 h de inactividad en operaciones sensibles, cookies HttpOnly, Secure y SameSite, rotación al iniciar sesión y revocación remota. **D:** Alerta de dispositivo nuevo. **C:** Cerrar todas las sesiones.	T03: expiración por tiempo e inactividad; revocación.	2×3 = 6 **Medio**. Una cookie robada sirve hasta que expira o se revoca.
R20	**4**. Los mensajes sobre citas son un señuelo muy creíble.	**3**. Cientos de cuentas comprometidas.	4×3 = 12 **Alto**, P2	**P:** Dominios oficiales, SPF, DKIM y DMARC; no pedir claves por mensaje; segundo factor resistente a phishing para funcionarios; capacitación. **D:** Canal de reporte de mensajes sospechosos. **C:** Revocar sesiones y avisar a los afectados.	T12: simulacro de phishing con el personal.	3×2 = 6 **Medio**. El engaño a una persona no se elimina; se limita su alcance.
R21	**3**. Exposición pública y automatización simple.	**4**. Bloquea el acceso a la atención.	3×4 = 12 **Alto**, P2	**P:** Límites de solicitudes, tamaño y tiempo; caché; WAF o CDN; sala de espera; autoescalado. **D:** Métricas de latencia y colas. **C:** Degradación controlada.	T09: carga de 200 y ráfaga de 400 solicitudes por segundo.	2×3 = 6 **Medio**. Un ataque mayor exige protección del proveedor de red.
R22	**3**. Un administrador con acceso puede ocultar acciones.	**4**. Se pierde la capacidad de investigar y responder.	3×4 = 12 **Alto**, P2	**P:** Solo adición, hash encadenado, copia externa y separación de funciones. **D:** Verificación periódica de la cadena de hashes. **C:** Restaurar desde la copia e investigar.	T11b: intentar modificar un registro; la cadena detecta la alteración.	1×3 = 3 **Bajo**. La alteración es técnicamente detectable.
R23	**3**. Sin telemetría, los incidentes se descubren tarde.	**4**. Sanción agravada y daño ampliado.	3×4 = 12 **Alto**, P2	**P:** Plan de respuesta, responsables y formatos de notificación. **D:** Monitoreo centralizado y alertas. **C:** Contención y notificación en los plazos de ley.	T12: simulacro semestral midiendo tiempos.	2×3 = 6 **Medio**. La detección depende de que el monitoreo cubra todos los componentes.

7.7 Apoyo técnico: CWE, OWASP, CVSS estimado y técnica de ATT&CK

ID	CWE	OWASP Top 10:2025	Vector CVSS v3.1 estimado	Puntaje	Técnica de ATT&CK relacionada
R01	CWE-359	A06 Insecure Design	No aplica: no es una vulnerabilidad técnica explotable	—	No se mapea: es una decisión de recolección, no una conducta del intruso.
R02	CWE-359	A06 Insecure Design	No aplica: no es una vulnerabilidad técnica explotable	—	No se mapea: es una decisión de recolección.
R03	CWE-306, CWE-200	A01 Broken Access Control	AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:N	6.5 Media	T1528 Steal Application Access Token.
R04	CWE-287, CWE-639	A07 Authentication Failures	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N	8.2 Alta	No se mapea directo; la fase previa es la enumeración (R18).
R05	CWE-521, CWE-307	A07 Authentication Failures	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	9.1 Crítica	T1110.001 Password Guessing; T1110.003 Password Spraying; T1110.004 Credential Stuffing.
R06	CWE-862, CWE-863	A01 Broken Access Control	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N	7.1 Alta	T1078 Valid Accounts; T1213 Data from Information Repositories.
R07	CWE-295, CWE-345	A10 Mishandling of Exceptional Conditions	AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N	7.4 Alta	T1557 Adversary-in-the-Middle; T1195 Supply Chain Compromise (si el proveedor es el comprometido).
R08	CWE-532	A09 Security Logging and Alerting Failures	AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N	5.5 Media	T1552.001 Credentials In Files.
R09	N/A (arquitectura)	A02 Security Misconfiguration	No aplica: no es una vulnerabilidad técnica explotable	—	T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery (si hay ransomware).
R10	N/A (diseño)	A06 Insecure Design	No aplica: no es una vulnerabilidad técnica explotable	—	No se mapea: es una decisión operativa.
R11	CWE-359	A06 Insecure Design	No aplica: no es una vulnerabilidad técnica explotable	—	No se mapea: es una decisión de cesión de datos.
R12	CWE-799, CWE-770	A06 Insecure Design	AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:L	4.3 Media	No se mapea: abuso de lógica de negocio.
R13	CWE-362, CWE-367	A06 Insecure Design	AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:N	3.1 Baja	No se mapea: es una condición de carrera.
R14	N/A (regla de negocio)	A06 Insecure Design	No aplica: no es una vulnerabilidad técnica explotable	—	No se mapea: es una regla de negocio.
R15	CWE-639	A01 Broken Access Control	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N	7.1 Alta	T1190 Exploit Public-Facing Application.
R16	CWE-89, CWE-79, CWE-352	A05 Injection	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	9.8 Crítica	T1190 Exploit Public-Facing Application.
R17	CWE-1395, CWE-1104	A03 Software Supply Chain Failures	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N	9.1 Crítica	T1190 Exploit Public-Facing Application; T1195.001 Compromise Software Dependencies and Development Tools.
R18	CWE-204	A07 Authentication Failures	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	5.3 Media	T1589 Gather Victim Identity Information (Reconnaissance).
R19	CWE-613, CWE-384	A07 Authentication Failures	AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N	6.8 Media	T1539 Steal Web Session Cookie.
R20	N/A (factor humano)	A07 Authentication Failures	No aplica: no es una vulnerabilidad técnica explotable	—	T1566 Phishing.
R21	CWE-770	A06 Insecure Design	AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	7.5 Alta	T1499 Endpoint Denial of Service; T1498 Network Denial of Service.
R22	CWE-117, CWE-778	A09 Security Logging and Alerting Failures	AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N	4.9 Media	T1070 Indicator Removal; T1565.001 Stored Data Manipulation.
R23	CWE-778	A09 Security Logging and Alerting Failures	No aplica: no es una vulnerabilidad técnica explotable	—	No se mapea: es una capacidad organizativa.

Los vectores son estimaciones del equipo, no CVE publicados. El puntaje se calculó con una calculadora de CVSS v3.1 verificada contra siete puntajes oficiales (por ejemplo, CVE-2026-40976 = 9,1 y CVE-2026-1207 = 5,4). CVSS no se calcula para decisiones de recolección ni para reglas de negocio, porque no son vulnerabilidades técnicas.

8. Relación con MITRE ATT&CK

Las columnas «Técnica del adversario» y «Táctica» describen lo que hace el atacante; las tres últimas columnas describen lo que hace la defensa. ATT&CK clasifica conductas de adversarios en sistemas de TI; no sustituye la valoración de riesgos ni la normativa. Los escenarios son hipótesis de amenaza, no ataques observados.

Escenario (riesgos)	Técnica del adversario	Táctica	Relación con el escenario	Prevenir	Detectar	Responder
Toma de cuentas por claves predecibles o filtradas (R05, R18)	T1110.001 Password Guessing; T1110.003 Password Spraying; T1110.004 Credential Stuffing	Credential Access	Prueba de fechas de nacimiento y claves comunes contra muchas cuentas, o de credenciales filtradas de otros servicios.	Activación de un solo uso; Argon2id; verificación contra claves filtradas; límite de intentos y bloqueo progresivo; segundo factor.	Alertas por muchos fallos desde pocos orígenes o por muchas cuentas con pocos fallos.	Bloqueo del origen, restablecimiento verificado y revocación de sesiones.
Inyección, acceso a recursos ajenos y CVE del framework (R15, R16, R17)	T1190 Exploit Public-Facing Application	Initial Access	Explotación de inyección, de IDOR o de una vulnerabilidad conocida en la aplicación expuesta a Internet.	Consultas parametrizadas; autorización por objeto; parches; WAF.	Alertas de WAF, errores de base de datos y 403 repetidos.	Parchear, aislar y notificar.
Dependencias vulnerables o comprometidas (R17)	T1195.001 Compromise Software Dependencies and Development Tools	Initial Access	Una dependencia con código malicioso o vulnerable llega a producción.	SBOM, versiones fijadas con hash, fuentes de confianza y análisis de dependencias.	Alertas de nuevos CVE y del catálogo KEV.	Parche de emergencia y reversión.
Abuso de cuentas de funcionarios (R06)	T1078 Valid Accounts	Initial Access, Persistence, Privilege Escalation y Stealth	Una cuenta legítima, robada o abusada, consulta datos fuera de su función.	Mínimo privilegio; segundo factor; acceso temporal.	Consultas anómalas o fuera de horario.	Suspender la cuenta y revisar accesos.
Consulta masiva y salida de datos (R06)	T1213 Data from Information Repositories	Collection	Un usuario interno reúne datos de pacientes con las herramientas del sistema.	Sin exportación masiva; enmascaramiento; relación asistencial.	Alertas por volumen de consultas.	Investigar y revocar privilegios.
Secretos en los registros (R08)	T1552.001 Credentials In Files	Credential Access	Un intruso o un soporte curioso obtiene credenciales escritas en registros.	Lista blanca de campos y redacción de secretos.	Escaneo de secretos en los registros.	Rotar las credenciales expuestas.
Mensajes falsos sobre citas (R20)	T1566 Phishing	Initial Access	Correos o SMS que imitan al IESS para robar credenciales.	SPF, DKIM y DMARC; segundo factor resistente al phishing; capacitación.	Canal de reporte y alerta de dispositivo nuevo.	Revocar sesiones y avisar a los afectados.
Sesión robada (R19)	T1539 Steal Web Session Cookie	Credential Access	Una cookie robada permite actuar como el afiliado mientras la sesión sea válida.	Sesión corta; cookies HttpOnly, Secure y SameSite; rotación.	La misma sesión usada desde dos orígenes.	Revocación remota.
Enlace o token expuesto (R03)	T1528 Steal Application Access Token	Credential Access	Un enlace de acceso directo reenviado o interceptado funciona como credencial.	Tokens de un solo uso que no abren información.	Uso del token desde orígenes distintos.	Invalidar el token y avisar.
Integraciones con terceros (R07)	T1557 Adversary-in-the-Middle	Collection y Credential Access	Un atacante en la red intercepta o altera la comunicación con el servicio externo.	TLS con validación de certificado; autenticación mutua.	Monitoreo de certificados y de red.	Rotar claves y certificados.
Enumeración de cédulas (R18)	T1589 Gather Victim Identity Information	Reconnaissance	Confirmar qué cédulas son afiliadas sirve de base para engaños posteriores.	Mensajes genéricos; límites por origen.	Alertas por consultas de muchas cédulas.	Bloqueo temporal del origen.
Saturación del servicio (R21)	T1499 Endpoint Denial of Service; T1498 Network Denial of Service	Impact	Solicitudes masivas agotan la aplicación o la red.	Límites; sala de espera; CDN; autoescalado.	Métricas de latencia y colas.	Degradación controlada.
Alteración de registros (R22)	T1070 Indicator Removal; T1565.001 Stored Data Manipulation	Stealth; Impact	Un supervisor o intruso borra o altera registros y datos almacenados para ocultar una acción.	Registro de solo adición; hash encadenado; copia externa.	Verificación periódica de la cadena de hashes.	Restaurar desde la copia e investigar.
Ransomware y pérdida de copias (R09)	T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery	Impact	Se cifran los datos y se borran las copias guardadas en el mismo servidor.	Copias inmutables fuera del servidor; segmentación.	Alertas de cifrado masivo y de borrado de copias.	Restauración según el plan de recuperación.

8.1 Qué no se mapea y por qué

No se fuerza una técnica para cada riesgo. Quedan sin correspondencia R01, R02 y R11 (decisiones de recolección y cesión de datos), R04 (suplantación por datos conocidos, cuya fase previa es la enumeración de R18), R10 (decisión operativa), R12, R13 y R14 (abuso de lógica de negocio, condiciones de carrera y reglas de turnos) y R23 (capacidad organizativa). Se tratan por su causa en la matriz y no necesitan una técnica del adversario.

8.2 Versión de ATT&CK y estado de verificación

Se usó la versión 20 de ATT&CK. La versión 19 (abril de 2026) dividió la táctica Defense Evasion en Stealth y Defense Impairment; la matriz Enterprise tiene 15 tácticas y 44 mitigaciones. Por eso el material anterior usa otros nombres de táctica.

Elemento	Estado de verificación
Versión de ATT&CK	Versión 20 (exportación oficial). La división de Defense Evasion en Stealth y Defense Impairment se introdujo en la versión 19 (abril de 2026).
Técnicas, tácticas, mitigaciones y estrategias de detección	Verificados contra la exportación oficial v20; la página de cada técnica es la referencia para citar.
T1070 Indicator Removal	Además, leída en la página oficial: táctica Stealth, versión 3.0.

8.3 Mitigaciones y estrategias de detección de ATT&CK

Todos los identificadores, nombres, tácticas, mitigaciones y estrategias de detección de esta tabla se tomaron de la exportación oficial de ATT&CK v20 (enterprise-attack-v20_0.xlsx: hojas de técnicas, mitigaciones, estrategias de detección y relaciones). Las mitigaciones de ATT&CK se corresponden con nuestros controles preventivos y correctivos (por ejemplo, M1029 con la copia externa de la auditoría, M1053 con los respaldos y M1013 con el ciclo de desarrollo seguro del Anexo H), y las estrategias de detección, con los controles detectivos del Anexo I.

Técnica y táctica	Mitigaciones (M)	Estrategia de detección (DET)
T1110.001 Brute Force: Password Guessing. Táctica: Credential Access	M1027 Password Policies, M1032 Multi-factor Authentication, M1036 Account Use Policies, M1051 Update Software	DET0551 Password Guessing via Multi-Source Authentication Failure Correlation
T1110.003 Brute Force: Password Spraying. Táctica: Credential Access	M1027 Password Policies, M1032 Multi-factor Authentication, M1036 Account Use Policies	DET0487 Distributed Password Spraying via Authentication Failures Across Multiple Accounts
T1110.004 Brute Force: Credential Stuffing. Táctica: Credential Access	M1018 User Account Management, M1027 Password Policies, M1032 Multi-factor Authentication, M1036 Account Use Policies	DET0460 Credential Stuffing Detection via Reused Breached Credentials Across Services
T1078 Valid Accounts. Táctica: Initial Access, Persistence, Privilege Escalation, Stealth	M1013 Application Developer Guidance, M1015 Active Directory Configuration, M1017 User Training, M1018 User Account Management, M1026 Privileged Account Management, M1027 Password Policies, M1032 Multi-factor Authentication, M1036 Account Use Policies	DET0560 Detection of Valid Account Abuse Across Platforms
T1190 Exploit Public-Facing Application. Táctica: Initial Access	M1016 Vulnerability Scanning, M1026 Privileged Account Management, M1030 Network Segmentation, M1035 Limit Access to Resource Over Network, M1037 Filter Network Traffic, M1048 Application Isolation and Sandboxing, M1050 Exploit Protection, M1051 Update Software	DET0080 Exploit Public-Facing Application – multi-signal correlation (request → error → post-exploit process/egress)
T1195.001 Supply Chain Compromise: Compromise Software Dependencies and Development Tools. Táctica: Initial Access	M1013 Application Developer Guidance, M1016 Vulnerability Scanning, M1033 Limit Software Installation, M1051 Update Software	DET0009 Supply-chain tamper in dependencies/dev-tools (manager→write/install→first-run→egress)
T1213 Data from Information Repositories. Táctica: Collection	M1017 User Training, M1018 User Account Management, M1032 Multi-factor Authentication, M1041 Encrypt Sensitive Information, M1047 Audit, M1054 Software Configuration, M1060 Out-of-Band Communications Channel	DET0413 Abuse of Information Repositories for Data Collection
T1552.001 Unsecured Credentials: Credentials In Files. Táctica: Credential Access	M1017 User Training, M1022 Restrict File and Directory Permissions, M1027 Password Policies, M1047 Audit	DET0307 Detect Access to Unsecured Credential Files Across Platforms
T1566 Phishing. Táctica: Initial Access	M1017 User Training, M1021 Restrict Web-Based Content, M1031 Network Intrusion Prevention, M1047 Audit, M1049 Antivirus/Antimalware, M1054 Software Configuration	DET0070 Detection Strategy for Phishing across platforms.
T1539 Steal Web Session Cookie. Táctica: Credential Access	M1017 User Training, M1021 Restrict Web-Based Content, M1032 Multi-factor Authentication, M1047 Audit, M1051 Update Software, M1054 Software Configuration	DET0509 Detection of Web Session Cookie Theft via File, Memory, and Network Artifacts
T1528 Steal Application Access Token. Táctica: Credential Access	M1017 User Training, M1018 User Account Management, M1021 Restrict Web-Based Content, M1047 Audit	DET0515 Detection Strategy for T1528 - Steal Application Access Token

Técnica y táctica	Mitigaciones (M)	Estrategia de detección (DET)
T1557 Adversary-in-the-Middle. Táctica: Collection, Credential Access	M1017 User Training, M1030 Network Segmentation, M1031 Network Intrusion Prevention, M1035 Limit Access to Resource Over Network, M1037 Filter Network Traffic, M1041 Encrypt Sensitive Information, M1042 Disable or Remove Feature or Program	DET0296 Detect Adversary-in-the-Middle via Network and Configuration Anomalies
T1589 Gather Victim Identity Information. Táctica: Reconnaissance	M1056 Pre-compromise	DET0841 Detection of Gather Victim Identity Information
T1499 Endpoint Denial of Service. Táctica: Impact	M1037 Filter Network Traffic	DET0208 Endpoint Resource Saturation and Crash Pattern Detection Across Platforms
T1498 Network Denial of Service. Táctica: Impact	M1037 Filter Network Traffic	DET0518 Behavioral Detection of T1498 – Network Denial of Service Across Platforms
T1070 Indicator Removal. Táctica: Stealth	M1022 Restrict File and Directory Permissions, M1029 Remote Data Storage, M1041 Encrypt Sensitive Information	DET0184 Behavioral Detection of Indicator Removal Across Platforms
T1565.001 Data Manipulation: Stored Data Manipulation. Táctica: Impact	M1022 Restrict File and Directory Permissions, M1029 Remote Data Storage, M1041 Encrypt Sensitive Information	DET0193 Detection Strategy for Stored Data Manipulation across OS Platforms.
T1486 Data Encrypted for Impact. Táctica: Impact	M1040 Behavior Prevention on Endpoint, M1053 Data Backup	DET0215 Detection of Multi-Platform File Encryption for Impact
T1490 Inhibit System Recovery. Táctica: Impact	M1018 User Account Management, M1028 Operating System Configuration, M1038 Execution Prevention, M1053 Data Backup	DET0329 Behavioral Detection for T1490 - Inhibit System Recovery

9. Verificación de los controles: tipos, defensa en profundidad y contraste con el formulario

Un control de seguridad es una medida para reducir la probabilidad de un evento, detectarlo mientras ocurre o disminuir sus consecuencias. Un mismo riesgo necesita varios controles, de tipos distintos y de naturaleza distinta. En esta sección se verifica que cada riesgo de la matriz tenga al menos un control **preventivo**, uno **detectivo** y uno **correctivo**, y se contrasta con los requisitos del formulario (I01 a I14).

9.1 Tipos y naturaleza de los controles

Tipo	Qué hace	Ejemplos en este diseño
Preventivo	Impide que el incidente ocurra	Segundo factor, autorización por objeto, validación de entrada, permisos mínimos, restricciones únicas, cifrado, segmentación, actualizaciones, políticas
Detectivo	Identifica eventos o anomalías cuando ocurren o después	Registros de auditoría, alertas por intentos fallidos, monitoreo, conciliación, revisión de eventos
Correctivo	Reduce las consecuencias y recupera el estado normal	Restaurar un respaldo, cambiar credenciales, revocar sesiones, aplicar un parche, aislar un componente, failover

Naturaleza	Qué es	Ejemplos en este diseño
Técnico	Software o mecanismos tecnológicos	Segundo factor, WAF, cifrado, permisos, restricciones en la base de datos
Administrativo	Políticas, procesos, capacitación y segregación de funciones	Revisión trimestral de accesos, doble aprobación, contratos con encargados, política de inasistencias, simulacros
Físico	Control de acceso a instalaciones y protección de equipos	Acceso a la sala de servidores, CCTV, bloqueo de pantallas de recepción, UPS y copia en otra ubicación

> **Error frecuente.** Pensar que un control detectivo «previene» el ataque. Un registro o una alerta ayudan a detectar o investigar, pero por sí solos no impiden el intento. Por eso cada riesgo de la matriz combina los tres tipos: el registro de auditoría (R22) es detectivo; lo que impide editarlo es la restricción de solo adición, que es preventiva.

9.2 Defensa en profundidad

No se depende de un único control. Una petición atraviesa seis capas en este orden: perímetro, identidad, autorización, reglas y validación, registros y alertas, y respaldo y recuperación. Si una capa falla, la siguiente limita el daño.

Capa (en orden)	Preventivo	Detectivo	Correctivo
1. Perímetro	TLS, WAF, límites de solicitudes, sala de espera	Alertas de WAF y de picos	Bloqueo del origen, degradación controlada
2. Identidad	Activación de un solo uso, Argon2id, segundo factor, bloqueo progresivo	Alertas de inicio de sesión anómalo o de dispositivo nuevo	Revocar sesiones y cambiar credenciales

Capa (en orden)	Preventivo	Detectivo	Correctivo
3. Autorización	Rol, relación asistencial, objeto y delegación vigente	Auditoría de accesos y de respuestas 403	Retirar privilegios y revocar delegaciones
4. Reglas y validación	Validación de entrada, RT-01 a RT-12 y restricciones en la base	Conciliación agenda y portal; alertas de patrones de abuso	Reasignar o revertir turnos
5. Registros y alertas	Solo adición, sin secretos, acceso restringido	Verificación de la cadena de hashes; revisión de eventos	Restaurar desde la copia e investigar
6. Respaldo y recuperación	Copias 3-2-1, inmutables, fuera del servidor	Monitoreo del éxito de las copias	Failover y restauración (RPO 5 min, RTO 30 min)

9.3 Catálogo de controles por tipo y naturaleza

Control	Tipo	Naturaleza	Riesgos
Segundo factor y activación de un solo uso	Preventivo	Técnico	R05, R19, R20
Límite de intentos y bloqueo progresivo	Preventivo	Técnico	R05, R18
Autorización por objeto y por rol	Preventivo	Técnico	R04, R06, R15
Validación de entrada, ORM parametrizado y CSP	Preventivo	Técnico	R16
Restricciones únicas y transacciones	Preventivo	Técnico	R12, R13
Cifrado en tránsito y en reposo; Argon2id	Preventivo	Técnico	R05, R07, R09
Mensajes neutrales y tokens de un solo uso	Preventivo	Técnico	R03
Minimización de datos y separación agenda y clínica	Preventivo	Administrativo	R01, R02, R11
Mínimo privilegio y revisión trimestral de accesos	Preventivo	Administrativo	R06
Segregación de funciones: quien corrige no aprueba	Preventivo	Administrativo	R22
Contratos y cláusulas con encargados	Preventivo	Administrativo	R07, R11
Capacitación y simulacros de phishing	Preventivo	Administrativo	R20
Política de inasistencias con apelación humana	Preventivo y correctivo	Administrativo	R14
Actualización de dependencias y plazos de parcheo	Preventivo	Administrativo y técnico	R17
Acceso controlado a la sala de servidores y CCTV	Preventivo	Físico	R09
Bloqueo de pantalla y cierre de sesión en equipos de recepción	Preventivo	Físico	R06, R19
Registros de auditoría de solo adición	Detectivo	Técnico	R08, R22
Alertas y monitoreo (WAF, fallos, consultas anómalas, latencia)	Detectivo	Técnico	R05, R06, R15, R21, R23
Conciliación entre agenda y portal	Detectivo	Técnico	R13
Revisión de eventos y auditoría interna	Detectivo	Administrativo	R06, R22
Revocar sesiones y cambiar credenciales	Correctivo	Técnico	R05, R19
Restauración desde respaldo y failover	Correctivo	Técnico	R09, R10
Parche y aislamiento de componentes	Correctivo	Técnico	R16, R17
Plan de respuesta y notificación a la SPDP	Correctivo	Administrativo	R23
Respaldo en otra ubicación y energía de respaldo (UPS)	Correctivo	Físico	R09

Verificación de cobertura: los 23 riesgos de la matriz (sección 7.6) tienen controles preventivo, detectivo y correctivo definidos (cobertura completa). Los controles físicos son los menos numerosos porque el prototipo es local, pero en producción son parte del requisito I12.

9.4 Controles de cada requisito del formulario

Requisito	Preventivo	Detectivo	Correctivo	Naturaleza
I01 Turnos	Restricciones únicas, RT-01 a RT-12, idempotencia	Conciliación; alertas de abuso	Reasignar o revertir; apelación	T y A
I02 Identificación	Datos mínimos; la fecha de nacimiento no autentica	Alertas de enumeración	Bloqueo del origen	T y A
I03 Laboral	No se recolecta	Revisión del esquema	Eliminación segura	A y T
I04 Salud	Agenda separada de lo clínico	Revisión del esquema; alertas de campos clínicos	Purga de datos copiados	A y T
I05 Religión y política	No se recolecta	Revisión del esquema	Eliminación segura	A y T
I06 Familiares	Delegación con alcance, vigencia y revocación	Aviso al titular; auditoría	Revocar y restaurar el turno	T y A

Requisito	Preventivo	Detectivo	Correctivo	Naturaleza
I07 Autenticación	Activación, Argon2id, segundo factor, bloqueo, sesiones cortas	Alertas de inicio anómalo	Revocar sesiones; restablecer	T
I08 Permisos	RBAC y relación asistencial; mínimo privilegio	Auditoría y revisión trimestral	Retirar privilegios	T y A
I09 Notificaciones	Plantillas neutrales; tokens de un solo uso	Uso del token desde orígenes distintos	Invalidar el token	T y A
I10 Integración	Autenticación entre servicios, tiempos de espera, contrato	Monitoreo de latencia y certificados	Modo PENDIENTE y conciliación	T y A
I11 Auditoría	Solo adición; sin secretos; separación de funciones	Verificación de la cadena de hashes	Restaurar desde la copia	T y A
I12 Infraestructura	Separación, redundancia, cifrado; acceso físico controlado	Monitoreo de recursos	Plan de recuperación; UPS	T, A y F
I13 Disponibilidad	Despliegue gradual; ventana excepcional anunciada	Medición del objetivo de disponibilidad	Contingencia con canal presencial	T y A
I14 Conservación e IA	Plazos; sin entrega para IA; contratos	Registro de comunicaciones a terceros	Exigir eliminación y devolución	A y T

T técnico, A administrativo, F físico.

9.5 Referencias de apoyo

Además de los tipos de control, los controles se contrastaron con OWASP Top 10:2025 (tabla siguiente), con la LOPDP y su Reglamento, y con NIST SP 800-63B-4 para autenticación y sesiones. NIST recomienda reautenticar como máximo a los 30 días con un factor y a las 24 horas con dos factores, con inactividad de hasta 1 hora en el segundo caso, y no usar «recordar este navegador» en lugar de autenticarse: de ahí salen la sesión de 24 horas y la inactividad de 1 hora (R19).

Categoría OWASP Top 10:2025	Controles del diseño	Requisitos	Riesgos	Pruebas
A01 Broken Access Control	Autorización por objeto y por rol; relación asistencial; delegaciones con alcance; denegar por defecto	I06, I08	R04, R06, R15	T02, T04, T13
A02 Security Misconfiguration	Lista de verificación de Django; mínimo de extensiones; cabeceras; sin DEBUG; configuración como código	I12	R09	T18
A03 Software Supply Chain Failures	Versiones LTS, SBOM, análisis de dependencias en CI y plazos de parcheo	N07	R17	T15
A04 Cryptographic Failures	TLS; cifrado en reposo; Argon2id; sin MD5; gestión de secretos	I07, I12	R05	T03, T18
A05 Injection	ORM parametrizado, validación en el servidor, escape automático y CSP	Transversal	R16	T14
A06 Insecure Design	Minimización; agenda separada de lo clínico; reglas de turnos RT-01 a RT-12; evaluación de impacto	I01, I03, I04, I05, I13, I14	R01, R02, R10 a R14	T01, T07, T16, T17
A07 Authentication Failures	Activación de un solo uso, segundo factor, bloqueo, sesiones cortas y mensajes genéricos	I02, I07	R05, R18, R19, R20	T03
A08 Software or Data Integrity Failures	Registro con hash encadenado, idempotencia y restricciones únicas, despliegue verificado	I11	R13, R22	T07, T11b
A09 Security Logging and Alerting Failures	Auditoría útil y sin secretos; alertas; plan de respuesta	I11	R08, R22, R23	T06, T12
A10 Mishandling of Exceptional Conditions	Fallos de terceros como PENDIENTE; circuito abierto; errores sin detalles; fallar de forma segura	I10	R07	T07

9.6 Contraste con los requisitos del formulario: estándares y pruebas

Requisito del formulario	Decisión	Control principal	OWASP 2025	Norma	Prueba	Estado en el prototipo
I01 Buscar y reservar	Conservar	RT-01 a RT-12; restricciones en la base	A06, A01	LOPDP art. 20	T07, T16, T17	Implementar
I02 Identificación	Modificar	Datos mínimos; la fecha de nacimiento no es credencial	A06, A07	LOPDP art. 10 literal e	T01, T03	Implementar
I03 Información laboral	Eliminar	No existe en el esquema	A06	LOPDP arts. 8 y 10	T01	Implementar (ausencia verificada)
I04 Salud	Eliminar	Agenda separada de lo clínico; motivo codificado	A06	LOPDP arts. 25, 26 y 30; AM 5216	T01	Implementar (ausencia verificada)
I05 Religión y política	Eliminar	No existe en el esquema	A06	LOPDP arts. 4, 25 y 26	T01	Implementar (ausencia verificada)
I06 Familiares	Modificar	Delegación con alcance, vigencia y revocación	A01, A07	LOPDP art. 21; Reglamento art. 19	T02	Implementar
I07 Autenticación	Modificar	Activación, Argon2id, bloqueo, segundo factor y sesiones	A07, A04	LOPDP art. 37; NIST SP 800-63B-4	T03	Implementar
I08 Permisos	Modificar	RBAC más relación asistencial y autorización por objeto	A01	Reglamento art. 60	T04, T13	Implementar
I09 Notificaciones	Modificar	Plantillas neutrales; tokens que no abren información	A01, A04	LOPDP art. 10 literal g	T05	Implementar (envío a archivo o consola)
I10 Integración	Conservar	Autenticación entre servicios, tiempos de espera, PENDIENTE	A10, A02	LOPDP arts. 34 y 35	T07	Simular servicios y probar fallos
I11 Auditoría	Modificar	Solo adición, hash encadenado y sin secretos	A09, A08	LOPDP art. 37	T06, T11b	Implementar
I12 Infraestructura	Modificar	Separación y redundancia; respaldos	A02	LOPDP art. 37	T08, T18	Simular con contenedores y documentar
I13 Disponibilidad	Modificar	Despliegue gradual; SLO	A06	LOPDP art. 37 (disponibilidad)	T08	Documentar y demostrar el despliegue
I14 Conservación e IA	Modificar	Plazos y borrado automático; sin entrega para IA	A06	LOPDP art. 10 literal i; SPDP-SPD-2026-0009-R	T10, T11	Implementar el vencimiento; documentar el contrato

10. Plan de verificación y hoja de ruta del prototipo

Estado de todos los casos: propuestos y no ejecutados. No hay aplicativo construido en esta actividad. El resultado esperado define el criterio de aceptación futuro; no equivale a una prueba aprobada. Las pruebas se ejecutan en un entorno autorizado, con datos sintéticos, y se verifican con casos negativos y positivos.

10.1 Pruebas T01 a T18

ID y riesgo	Procedimiento propuesto	Resultado esperado	Herramienta
T01 **R01, R02**	Reservar sin ningún dato laboral, religioso ni de salud; revisar el esquema de la base.	La reserva se completa; el esquema no tiene esos campos.	Revisión de esquema; pytest
T02 **R04**	Operar con una cédula ajena sin delegación; con delegación revocada; con delegación válida.	Denegación en los dos primeros casos y agenda intacta; con delegación válida solo el alcance aprobado; aviso al titular.	pytest; pruebas manuales
T03 **R05, R18, R19**	Probar la clave biográfica, una activación ya usada, fallos sucesivos, una cédula inexistente frente a una clave incorrecta, la expiración de sesión y la revocación.	Clave rechazada; activación no reutilizable; bloqueo progresivo; respuesta idéntica en los dos casos; sesión expirada a las 24 h y a 1 h de inactividad.	pytest; ZAP
T04 **R06**	Recorrer la matriz de permisos con recepción, profesional asignado, profesional no asignado, soporte y administración.	Cada rol accede solo a lo permitido; las denegaciones quedan auditadas.	pytest parametrizado
T05 **R03**	Leer una notificación en la pantalla bloqueada; reenviar su enlace y abrirlo sin sesión.	El mensaje es neutral; el enlace no muestra datos y pide autenticación.	Prueba manual
T06 **R08**	Enviar contraseñas, tokens y un diagnóstico ficticios en las solicitudes.	Ninguno aparece en los registros; el evento conserva actor y resultado.	Búsqueda en registros; gitleaks
T07 **R07, R13**	Dos solicitudes simultáneas por la última franja; reintento con la misma clave; tiempo de espera del servicio externo.	Un solo turno confirmado; el reintento no duplica; el estado externo desconocido queda PENDIENTE.	pytest con hilos; servicio simulado
T08 **R09, R10**	Retirar un nodo, restaurar un respaldo y desplegar una versión mientras se reserva.	RPO ≤ 5 min y RTO ≤ 30 min medidos; sin pérdida silenciosa de reservas.	Docker Compose; script de restauración
T09 **R21**	Carga de 200 solicitudes por segundo y ráfaga de 400.	Latencia p95 ≤ 2 s y errores < 1 % como metas; la limitación no bloquea a todos los usuarios.	k6 o Locust
T10 **R11**	Inspeccionar campos y permisos de las integraciones y los contratos.	Respuesta mínima y acceso revocable; no existe exportación para entrenar IA.	Revisión documental
T11 **R01, R11**	Ejecutar el vencimiento de datos y una solicitud de acceso y de eliminación.	Borrado, anonimización o bloqueo motivado; el expediente clínico sigue su propio régimen.	Tarea programada; pytest
T11b **R22**	Intentar modificar o borrar un registro; alterar uno en el entorno de pruebas y verificar la cadena.	La operación falla; la verificación detecta la alteración.	SQL de prueba; script de verificación
T12 **R20, R23**	Simulacro de incidente y de phishing con el personal.	Responsables identificados; tiempos de detección y notificación medidos y dentro de los plazos.	Ejercicio de mesa
T13 **R15**	Con otra cuenta, cambiar el identificador de un turno o de un afiliado.	Respuesta 403 y registro del intento.	pytest; ZAP
T14 **R16**	Cargas de inyección SQL, XSS y CSRF en formularios y API; análisis estático.	Los ataques fallan; sin hallazgos críticos abiertos.	Bandit; OWASP ZAP
T15 **R17**	Escaneo de dependencias, SBOM y comprobación de la versión de Django.	Sin críticos abiertos; Django en el último parche de 5.2.	pip-audit; SBOM
T16 **R12**	Segunda reserva en la especialidad; tope de citas; solape de horario; representante con seis representados; muchas cédulas desde una IP.	Cada intento se rechaza con un mensaje genérico y queda auditado.	pytest; script de carga
T17 **R14**	Flujo de confirmación y expiración; primera inasistencia; dos consecutivas; justificación; apelación; persona de atención prioritaria.	Se aplican las consecuencias de la sección 3.5 y se revierten al justificar; las personas prioritarias conservan el canal alterno.	pytest; pruebas manuales
T18 **R09, A02**	check --deploy, cabeceras, cookies, TLS, DEBUG y secretos.	Sin advertencias; cabeceras y cookies conforme a la lista de la sección 5.5.	manage.py; pruebas de cabeceras

Evidencia que se conserva de cada ejecución

Versión y configuración, fecha, responsable, precondiciones, identidad ficticia, entrada, respuesta, estado persistido antes y después, y evidencia de auditoría; sin secretos ni datos clínicos. Una denegación exige comprobar que no cambió la base. Un control que también bloquea las acciones legítimas no se acepta.

Secuencia de evaluación

1. Revisar requisitos y arquitectura; preparar datos y permisos.
2. Ejecutar el caso negativo y el positivo en la versión sin control (antes) y registrar el resultado.
3. Aplicar el control, repetir la misma prueba (después) y ejecutar la regresión.
4. Comparar con los criterios y corregir la causa si falla.

10.2 Hoja de ruta del prototipo local

El prototipo implementa en código los controles de este informe. Cada módulo tiene una demostración de antes y después para explicarlo en clase, con una versión intencionalmente insegura que se aísla en una rama de laboratorio.

Módulo	Controles y riesgos que cubre	Cómo se demuestra en clase (antes y después)
M01 Cuentas y activación	I07; R05, R18	La clave igual a la fecha de nacimiento entra en la versión insegura y falla en la segura; mensaje idéntico para cédula inexistente.
M02 Sesiones y segundo factor	I07; R05, R19	Expiración por tiempo e inactividad; TOTP para funcionarios; revocación remota.
M03 Autorización	I08, I06; R04, R06, R15	Cambiar el identificador del turno con otra cuenta devuelve 403; recepción no ve datos clínicos.
M04 Turnos y reglas	I01; RT-01 a RT-12; R12 a R14	Segunda reserva rechazada; doble clic idempotente; concurrencia con dos hilos; inasistencias y apelación.
M05 Delegaciones	I06; R04	Operar sin delegación, con delegación y tras revocarla.
M06 Notificaciones neutrales	I09; R03	Mensajes a archivo o consola sin datos clínicos; enlace de un solo uso que no abre información.
M07 Auditoría de solo adición	I11; R08, R22	Alterar una fila hace fallar la verificación de la cadena de hashes.
M08 Integraciones simuladas	I10; R07	Servicio de prueba con latencia y fallos: estado PENDIENTE, circuito abierto, sin cobertura inventada.
M09 Límites y antiautomatización	R21, R18, RT-09	Ráfaga con un script; respuestas 429 y desafío adaptativo.
M10 Cabeceras, CSRF y configuración	R16; A02	check --deploy sin advertencias; informe de ZAP.
M11 Dependencias e integración continua	R17; N07	pip-audit y SBOM; versión de Django parcheada; bloqueo si hay críticos.
M12 Retención y derechos	I14; R11	Tarea de vencimiento; consulta, rectificación y eliminación por el titular.
M13 Respaldos y restauración	I12; R09	Script de copia y restauración con medición de RPO y RTO.
M14 Paneles de auditor y DPD	I08, I11	Vistas de solo lectura con filtros; sin datos clínicos.

10.3 Qué es igual y qué cambia entre producción y la demostración local

Aspecto	En la demostración local	En producción
Código, configuración de seguridad y controles	Idénticos	Idénticos
Datos	100 % sintéticos; cédulas ficticias	Datos reales bajo el régimen de la LOPDP
TLS	Certificado de desarrollo en el proxy local	Certificado de la institución
Servicios de afiliación y agenda	Simulados con servicios de prueba que fallan a propósito	Interfaces oficiales con contrato
SMS y correo	Archivo o consola	Proveedor con contrato de encargado
Redundancia y WAF	Contenedores y un proxy local con límites	Nodos redundantes y WAF institucional
Secretos	Variables de entorno fuera del repositorio	Gestor de secretos

11. Explicación para el cliente

Su aplicación seguirá cumpliendo el objetivo de disminuir las filas y las llamadas: los afiliados podrán buscar, reservar, cancelar y reprogramar citas, y sus familiares podrán ayudarlos. La diferencia es que lo hará pidiendo menos datos y con menos riesgo para el IESS. Estos son los cambios principales y sus razones.

- **La información médica no entra en la agenda.** Reservar una cita no necesita diagnósticos, medicamentos ni resultados. Esos datos tienen un régimen más estricto y siguen en el sistema clínico. Pedirlos antes de mostrar horarios es innecesario y expone al IESS a sanciones.
- **No se preguntará por sueldo, banco, contrato, religión ni política.** No sirven para dar una cita y la ley solo permite pedir lo necesario. Exigirlos como condición de la reserva también anula el consentimiento.
- **La contraseña ya no será la fecha de nacimiento.** Esa fecha la conocen familiares y desconocidos. Cada persona activará su cuenta con un código de un solo uso y elegirá su clave. Los funcionarios usarán además un segundo factor.
- **Los familiares ayudarán con una autorización.** El titular o su tutor autoriza a un familiar, por un tiempo y solo para la agenda, y puede retirarla cuando quiera. Cédula y fecha de nacimiento no bastan para representar a nadie.
- **Cada funcionario verá lo que necesita.** Recepción verá la agenda; solo los profesionales asignados verán lo clínico. Los registros de auditoría no guardarán contraseñas y no se podrán editar.
- **Los mensajes no revelarán diagnósticos.** Solo avisarán de la fecha y la hora de la cita y llevarán al portal. Los enlaces no abrirán información sin iniciar sesión.
- **Habrá reglas contra el acaparamiento de turnos.** Una cita activa por especialidad, un tope de citas y la confirmación del turno. Quien no asista de forma repetida pierde por unos días la reserva en línea, no la atención, puede justificar su ausencia y apelar ante una persona.
- **El sistema estará preparado para el uso real.** En lugar de una computadora de oficina habrá una infraestructura separada, con respaldos fuera del equipo y mantenimiento sin cortar las reservas. La capacidad se probará con la carga esperada antes de abrirla al público.
- **No se entregarán los datos para entrenar inteligencia artificial.** Es una finalidad distinta de la agenda y exige una base legal, una evaluación de impacto y autorización específica.

Para cerrar el diseño necesitamos sus respuestas a las preguntas de la sección siguiente.

12. Supuestos y preguntas abiertas

12.1 Supuestos declarados

1. El IESS (o la unidad de atención) es el responsable del tratamiento y el proveedor tecnológico es encargado, bajo contrato.
2. El alcance son citas médicas de consulta externa; los turnos administrativos requieren otro catálogo.
3. Existen, o se simulan, interfaces del servicio de afiliación y del sistema de agenda; el prototipo no usa servicios reales del IESS.
4. El sistema clínico es independiente y no es accesible desde el portal.
5. Los plazos de conservación, los parámetros de turnos y los objetivos de capacidad son propuestas para que la institución las apruebe.
6. La distribución de 120 funcionarios es un supuesto: 60 en recepción, 40 en personal médico, 12 en administración y 8 en soporte.
7. No se verificó la normativa tributaria, contable ni de archivo del sector público.
8. El prototipo se presenta de forma local con datos sintéticos.

12.2 Preguntas al cliente

1. ¿La unidad gestiona solo citas médicas o también turnos administrativos?
2. ¿Existe un proveedor de identidad institucional (SSO) y qué segundo factor puede usar el personal?
3. ¿Existen interfaces oficiales del servicio de afiliación y del sistema de agenda, con sus cuotas y tiempos de respuesta?
4. ¿Cómo se acreditan las tutelas, los poderes y la discapacidad para delegar la gestión de citas?
5. ¿Qué plazos de conservación y archivo exige la institución para las citas y los registros de auditoría?

6. ¿Qué porcentaje de cupos debe reservarse para atención prioritaria y qué política de inasistencias aprueba la dirección médica?
7. ¿Existe un esquema de seguridad de la información obligatorio para la institución (mecanismo gubernamental del art. 38 de la LOPDP)?
8. ¿Hay datos históricos de uso: concurrencia máxima, días pico y mezcla de operaciones?
9. ¿El IESS cuenta con un delegado de protección de datos designado y registrado?
10. ¿Existe un proyecto de inteligencia artificial aprobado que requiera datos de agenda?

13. Fuentes y fecha de consulta

Fechas de consulta: **29 y 30 de octubre de 2026**. Las estimaciones de capacidad, los plazos operativos, los puntajes de riesgo y los vectores CVSS son decisiones de esta propuesta, diferenciadas de las obligaciones legales.

13.1 Normativa ecuatoriana

Norma o fuente	Dirección consultada
LOPDP, RO Suplemento 459, 26-may-2021 (incluye los textos de los arts. 66 y 92 de la Constitución)	https://usgn.espe.edu.ec/wp-content/uploads/2025/06/LEY-ORGANICA-DE-PROTECCION-DE-DATOS-PERSONALES.pdf
Reglamento General de la LOPDP, Decreto 904, RO Suplemento 435, 13-nov-2023	https://www.dspace.espol.edu.ec/server/api/core/bitstreams/48ff6b75-797b-4e97-a55a-2f54be708dcd/content
SPDP-SPD-2026-0003-R, actividades familiares o domésticas	PDF firmado de la resolución (archivo proporcionado)
SPDP-SPD-2026-0005-R, tratamiento a gran escala	PDF firmado de la resolución (archivo proporcionado)
SPDP-SPD-2026-0009-R, inteligencia artificial	PDF firmado de la resolución (archivo proporcionado)
SPDP-SPD-2026-0040-R, notificación de vulneraciones	PDF firmado de la resolución (archivo proporcionado)
SPDP-SPD-2025-0028-R, delegado de protección de datos	PDF firmado de la resolución (archivo proporcionado)
SPDP-SPD-2025-0030-R, seudonimización, anonimización, bloqueo y eliminación	PDF firmado de la resolución (archivo proporcionado)
Plan Regulatorio Institucional 2026 de la SPDP (norma de datos de salud prevista)	https://nmslaw.com.ec/blog/2026/01/04/spdp-plan-regulatorio-institucional-2026-ecuador/
MSP, Acuerdo Ministerial 5216, Reglamento de información confidencial	https://www.salud.gob.ec/wp-content/uploads/2022/09/A.M.-5216-Reglamento-de-informacion-confidencial-en-SNS.pdf
MSP, AM 00127-2021 (reforma), RO 391, 12-feb-2021	https://derechoecuador.com/registro-oficial-no391-viernes-12-de-febrero-de-2021/

13.2 Documentación técnica y vulnerabilidades

Fuente técnica	Dirección consultada
NIST SP 800-63B-4, niveles de aseguramiento	https://pages.nist.gov/800-63-4/sp800-63b/aal/
NIST SP 800-63B-4, gestión de sesiones	https://pages.nist.gov/800-63-4/sp800-63b/session
OWASP Top 10:2025, introducción y lista de categorías	https://owasp.org/Top10/2025/0x00_2025-Introduction/
Django, descargas y fechas de soporte	https://www.djangoproject.com/download/
Django, versiones de seguridad de marzo de 2026	https://www.djangoproject.com/weblog/2026/mar/03/security-releases/
Django, CVE-2026-1207 (CNA)	https://cve.circl.lu/cve/CVE-2026-1207
Django, CVE-2026-1207, explotación	https://www.herodevs.com/blog-posts/cve-2026-1207-sql-injection-in-django-raster-lookups-postgis
Django, CVE-2025-64459 (aviso del CSC de los EAU)	https://assets.adgm.com/download/assets/432317962-Security+Updates-Django+Framework+-+Alert+843.pdf/af350adebdf011f09792c26c190718e2
Django, CVE-2026-33034 (Tenable)	https://www.tenable.com/plugins/cloud-security/455196
Django, versiones de agosto de 2026	https://openwall.com/lists/oss-security/2026/08/04/6
PostgreSQL, notas de versión de seguridad (espejo)	https://releasebot.io/updates/postgresql/postgresql
PostgreSQL, fechas de fin de vida	https://endoflife.ai/article-postgresql-eol
Starlette y FastAPI, CVE-2026-48710	https://www.infoworld.com/article/4177714/fastapi-based-ai-tools-exposed-to-authentication-bypass-by-flaw-in-starlette-framework-2.html
Starlette, ingreso al catálogo KEV	https://www.penligent.ai/hackinglabs/ar/?p=7395
Spring Boot, CVE-2026-40976	https://spring.io/security/cve-2026-40976
Spring Boot, resumen de tres CVE	https://ccb.belgium.be/advisories/warning-multiple-vulnerabilities-spring-boot-patch-immediately
npm, CVE-2026-12866 (expr-eval)	https://advisories.gitlab.com/npm/expr-eval/CVE-2026-12866/

Fuente técnica	Dirección consultada
Express, CVE de Multer	https://cve.imfht.com/vendor/expressjs?lang=en
MITRE ATT&CK, T1070 Indicator Removal	https://attack.mitre.org/techniques/T1070/
MITRE ATT&CK, T1078 Valid Accounts	https://attack.mitre.org/techniques/T1078
MITRE ATT&CK, novedades de la versión 19 (abril de 2026)	https://attack.mitre.org/resources/updates/updates-april-2026/
MITRE ATT&CK, registro de cambios v19.0 a v19.1	https://attack.mitre.org/docs/changelogs/v19.0-v19.1/changelog-detailed.html
PostgreSQL, política de versiones (fechas de fin de vida y versión menor actual)	https://www.postgresql.org/support/versioning/
Python, estado de las versiones y fechas de fin de vida	https://devguide.python.org/versions/
NIST SP 800-218, Secure Software Development Framework versión 1.1 (feb-2022)	https://csrc.nist.gov/pubs/sp/800/218/final
OWASP API Security Top 10:2023	https://owasp.org/www-project-api-security/
Lexis Noticias: RO N.º 240 del 10-mar-2026 (resolución 0009-R) y RO Primer Suplemento 376 del 24-sep-2026 (0040-R)	https://www.lexis.com.ec/noticias/registro-oficial-del-dia-superintendencia-de-proteccion-de-datos-expide-norma-para-el-uso-de-inteligencia-artificial
MITRE ATT&CK v20, exportación oficial en Excel (técnicas, mitigaciones, estrategias de detección y relaciones)	Archivo proporcionado (enterprise-attack-v20_0.xlsx)

Anexo A. Modelado de amenazas con STRIDE

El modelado recorre cada elemento y flujo del diagrama de arquitectura (Figura 3) y pregunta, con las seis categorías de STRIDE, qué puede salir mal. Cada amenaza se relaciona con un riesgo de la matriz. Si una amenaza no tuviera riesgo asociado, se agregaría una fila a la matriz; en este análisis todas quedaron cubiertas por R01 a R23 o por las reglas RT.

Elemento o flujo	S Suplantación	T Manipulación	R Repudio	I Divulgación	D Denegación	E Elevación de privilegios
Afiliado y representante (entidad externa)	Usar la cédula y la fecha de nacimiento de otro (R04, R05)	Alterar identificadores y parámetros (R15)	Negar haber cancelado o reservado (RT-12, R22)	Enumerar cédulas (R18)	Bots que acaparan o saturan (R12, R21)	Un representante opera fuera de su delegación (R04)
Proxy inverso y WAF	Cabecera Host falsificada (R17)	Alterar solicitudes en tránsito (R07)	—	Errores con detalles técnicos (R16)	Inundación de solicitudes (R21)	Evadir reglas del WAF (R16)
Identidad y sesiones	Toma de cuenta; cookie robada (R05, R19, R20)	Fijar o falsificar una sesión (R19)	Inicios de sesión sin registro (R23)	Mensajes que revelan si la cédula existe (R18)	Bloqueo malicioso de cuentas ajenas (R05)	Sesión de afiliado usada como funcionario (R06)
Turnos y reglas	Reservar a nombre de otro (R04)	Doble reserva por concurrencia (R13); saltar reglas (R12)	Inasistencias sin evidencia (R14)	Ver turnos ajenos (R15)	Agotar cupos (R12)	Recepción ve datos clínicos (R06)
Delegaciones	Delegación falsa o con documento falso (R04)	Cambiar alcance o vigencia (R04)	Negar haber delegado (RT-12)	Revelar quién representa a quién (R15)	—	Ampliar el alcance a lo clínico (R04)
Notificaciones	Mensajes falsos que imitan al IESS (R20)	Cambiar el destinatario (R03)	—	Diagnóstico o enlace en el mensaje (R03)	Inundar de mensajes a un destinatario (R21)	—
Auditoría	Registrar eventos con otro usuario (R22)	Editar o borrar registros (R22)	Base del no repudio: se pierde si se edita (R22)	Secretos en los registros (R08)	Llenar el almacenamiento de registros (R23)	Administrador que edita registros (R22)
Base de datos	Conexión con credenciales robadas (R16)	Inyección SQL (R16)	—	Exfiltración de la base (R01, R02, R05)	Caída o pérdida del servidor (R09)	Cuenta de la aplicación con permisos excesivos (R16)
Flujo hacia el servicio de afiliación	Servicio falso (R07)	Respuesta alterada (R07)	—	Datos en tránsito sin cifrar (R07)	Servicio caído que arrastra al portal (R07)	—
Flujo hacia el sistema de agenda	Confirmación falsa (R07)	Reintentos que duplican turnos (R13)	Turno confirmado que no se persistió (R13)	Identificador personal innecesario (R04)	Cuota agotada (R07)	—
Flujo hacia el proveedor de SMS y correo	Remitente suplantado (R20)	Cambiar el texto (R03)	—	Datos clínicos al proveedor (R11)	Proveedor caído (R10)	—
Respaldos	—	Cifrar o borrar copias (R09)	—	Copias sin cifrar (R09)	Copia en el mismo servidor (R09)	Administrador borra copias inmutables (R09)
Funcionarios (VPN)	Cuenta compartida o robada (R06)	Corregir registros sin aprobación (R22)	Negar una consulta (R06, R22)	Consulta masiva (R06)	—	Soporte con acceso a todo (R06)

S suplantación (afecta la autenticidad), T manipulación (integridad), R repudio (trazabilidad y responsabilidad), I divulgación de información (confidencialidad), D denegación de servicio (disponibilidad) y E elevación de privilegios (autorización). Las celdas con «—» indican que la categoría no aplica de forma relevante a ese elemento. El flujo hacia el sistema clínico queda fuera: el portal no tiene acceso a él.

Anexo B. Borrador de evaluación de impacto del tratamiento

Por qué es obligatoria. La LOPDP exige una evaluación de impacto ante el tratamiento a gran escala de categorías especiales de datos (art. 42) y debe hacerse antes de empezar (Reglamento art. 31). La Norma General sobre el Tratamiento de Datos Personales a Gran Escala (Resolución SPDP-SPD-2026-0005-R) califica de forma directa como gran escala los tratamientos de salud en sistemas sanitarios, asistenciales o de seguridad social (art. 14.1) y vincula esa calificación con la evaluación de impacto, el delegado, el registro de actividades y las medidas reforzadas (art. 12). Este portal agenda atención de un sistema de seguridad social para 50.000 afiliados, por lo que se trata como gran escala aunque no almacene diagnósticos.

> **Límite de este borrador.** La resolución se leyó en su texto firmado. Falta confirmar su fecha de publicación en el Registro Oficial, de la que depende su vigencia. La evaluación definitiva la presenta el IESS ante la SPDP (Reglamento art. 32); este documento es una base académica y no la sustituye.

El contenido mínimo sigue el Reglamento (art. 32): descripción sistemática del tratamiento, justificación de su necesidad y proporcionalidad, evaluación de riesgos y medidas para enfrentarlos.

B.1 Identificación

Dato	Contenido
Tratamiento	Portal de gestión de turnos de atención médica de una unidad del IESS (web y móvil).
Responsable	IESS (unidad de atención). Nombre, domicilio legal y contacto: [por completar por la institución].
Delegado de protección de datos	[por designar y registrar ante la SPDP]. Obligatorio por tratarse del sector público (LOPDP art. 48 num. 1).
Encargados	Proveedor de SMS y correo; proveedor de infraestructura (si no es del IESS). Contratos por firmar (LOPDP art. 34; Reglamento art. 41).
Versión y fecha	Borrador 1, 29 de octubre de 2026. Debe actualizarse al cambiar el tratamiento.

B.2 Descripción sistemática del tratamiento

Elemento	Descripción
Operaciones	Registro y activación de cuentas, búsqueda de disponibilidad, reserva, confirmación, cancelación y reprogramación, delegación de familiares, notificación, auditoría y eliminación por vencimiento.
Finalidades	Asignar y gestionar citas médicas; comunicar cambios; prevenir el acaparamiento de cupos; demostrar el cumplimiento y la seguridad.
Titulares	Hasta 50.000 afiliados, algunos menores de edad o con discapacidad; 120 funcionarios.
Datos	Identidad mínima y contacto, relación de representación, turnos y su estado, motivo mínimo codificado, credenciales (hash) y registros de auditoría. No se tratan diagnósticos, datos laborales, religión ni política.
Categorías especiales	Datos vinculados a salud (la especialidad y la fecha del turno revelan una relación asistencial), datos de menores y de personas con discapacidad en delegaciones.
Destinatarios	Servicio de afiliación y sistema de agenda (consultas); proveedor de mensajería (teléfono y correo). Ninguno recibe datos clínicos. No hay transferencia internacional prevista.
Conservación	Plazos de la sección 2.2: cuenta, turnos más 12 meses, auditoría 12 meses; vencidos se eliminan, bloquean o anonimizan.
Decisiones automatizadas	Restricción temporal de la reserva en línea tras dos inasistencias consecutivas, con explicación y apelación humana (LOPDP art. 20).

Calificación del tratamiento con el modelo MTGE

Variable (art. 8)	Supuesto del portal	Puntos
Número de titulares en 12 meses	50.000 afiliados (de 10.001 a 100.000)	3
Volumen de datos	10 tipos de datos o menos por titular	0,5
Categorías de datos	Incluye una categoría especial (datos vinculados a salud); 3 si se cuentan menores y discapacidad	2
Frecuencia	Periódica (reservas recurrentes); 2 si se considera continua	1
Permanencia	Prolongada (3 años o más)	2
Alcance geográfico	Local (una unidad de atención); 2 si es nacional	1
Total (art. 9) y umbral (art. 10)	9,5 con los supuestos mínimos; el umbral es 6 puntos	9,5

El resultado supera el umbral aun con supuestos mínimos y, además, el caso es de calificación directa por el art. 14.1, sin necesidad de aplicar el modelo. El resultado debe constar en el registro de actividades (art. 7).

B.3 Necesidad y proporcionalidad

Dato o tratamiento	Necesidad y proporcionalidad	Alternativa descartada
Cédula, nombres, correo y teléfono	Necesarios para identificar al afiliado y avisarle; el teléfono es opcional.	Pedir además dirección y fecha de nacimiento: innecesario.
Datos laborales, religión y política	No se tratan: no tienen finalidad en una agenda.	Recolectarlos «para personalizar»: desproporcionado.
Datos clínicos	No se tratan en el portal: permanecen en el sistema clínico.	Pedirlos antes de mostrar horarios: desproporcionado.
Delegación de familiares	Necesaria para que un familiar ayude sin compartir claves.	Aceptar cédula y fecha de nacimiento: no acredita autorización.
Restricción por inasistencias	Proporcional: temporal, solo de la reserva en línea, apelable.	Bloqueo permanente o automático sin revisión humana.
Entrega para entrenar IA	No se realiza: finalidad distinta y sin base válida.	Cesión general de la base.

Base de licitud: obligación legal y misión de interés público para la prestación (LOPDP art. 7 numerales 2 y 4); consentimiento solo para lo opcional, como el SMS (art. 8).

B.4 Riesgos para los derechos y libertades

La evaluación de impacto mira el daño a las personas, no solo a la seguridad de los sistemas. Se resume la matriz de la sección 7 en esos términos.

Riesgo para los derechos y libertades	Riesgos relacionados	Nivel residual
Discriminación o daño por exposición de datos de salud o de atención	R02, R03, R06, R08	Bajo a medio
Pérdida de acceso a la atención por acaparamiento, caída del servicio o bloqueos injustos	R10, R12, R14, R21	Bajo a medio
Suplantación y acceso de terceros a datos de otra persona	R04, R05, R15, R19	Medio
Uso de datos para fines distintos o cesión no autorizada	R01, R11	Bajo
Pérdida de control e imposibilidad de ejercer derechos	R23 y N03	Medio
Pérdida o alteración de los datos y de la evidencia	R09, R22	Bajo a medio

B.5 Medidas y garantías

Las medidas son los controles preventivos, detectivos y correctivos de la sección 9 (catálogo 9.3), la minimización de la sección 1, las reglas de turnos con apelación humana (sección 3.5) y los derechos de los titulares: información, acceso, rectificación, eliminación y oposición, con respuesta en 15 días y un canal autenticado (N03).

B.6 Obligaciones asociadas y estado

Obligación	Fundamento	Estado en este informe
Evaluación de impacto previa al tratamiento	LOPDP art. 42; Reglamento arts. 29 a 32	Este anexo es el borrador; falta la presentación ante la SPDP
Delegado de protección de datos	LOPDP art. 48; SPDP-SPD-2025-0028-R arts. 5 y 9; SPDP-SPD-2026-0005-R art. 12	Por designar e inscribir en 15 días. El plazo transitorio de 90 días de la norma 0005-R excluye a quien ya debía designarlo; probablemente no aplica, a confirmar
Registro de actividades de tratamiento	Reglamento arts. 38 y 39 (100 o más trabajadores); SPDP-SPD-2026-0005-R arts. 4, 6 y 15; SPDP-SPD-2026-0009-R art. 5.4	Por elaborar con la tabla de la sección 2.2; actualizar al menos una vez al año
Registro en el Registro Nacional, en 10 días	LOPDP art. 51; Reglamento art. 86	Por realizar al iniciar el tratamiento
Auditoría cada 12 meses e informe anual de cumplimiento, conservados 5 años	SPDP-SPD-2026-0005-R arts. 17 y 18	Por planificar
Notificación de vulneraciones por el SISPDP	LOPDP arts. 43 y 46; SPDP-SPD-2026-0040-R arts. 8, 10 y 11	Plan de respuesta en N04

B.7 Consulta, conclusión y aprobación

- **Consulta:** opinión del delegado de protección de datos [pendiente] y, si se estima conveniente, de representantes de los afiliados [pendiente].
- **Conclusión propuesta:** el tratamiento puede iniciarse si los controles del riesgo P1 (R05, R06, R08) están implementados y verificados, y si se eliminan por diseño la recolección de datos clínicos y laborales (R01, R02) y la cesión para IA (R11). El riesgo residual queda en nivel medio o bajo.
- **Aprobación:** [responsable del tratamiento, firma y fecha, por completar]. **Revisión:** al cambiar el tratamiento y al menos una vez al año.

Anexo C. Matriz de trazabilidad

La trazabilidad une cada requisito del cliente con la decisión, los riesgos, los controles, las pruebas y el módulo del prototipo que lo demuestra. Sirve para comprobar que ningún requisito queda sin control y ningún control sin prueba.

C.1 Del requisito al módulo del prototipo

Requisito	Decisión	Riesgos	Controles principales	Pruebas	Módulo	Norma
I01	Conservar	R12, R13, R14, R15, R21	RT-01 a RT-12; restricciones únicas; idempotencia	T07, T09, T13, T16, T17	M04	LOPDP art. 20
I02	Modificar	R18	Datos mínimos; la fecha de nacimiento no autentica	T03	M01	art. 10 e
I03	Eliminar	R01	No se recolecta	T01	Esquema (M04)	arts. 8 y 10
I04	Eliminar	R02	Agenda separada de lo clínico	T01	Esquema (M04)	arts. 25, 26, 30; AM 5216
I05	Eliminar	R01	No se recolecta	T01	Esquema (M04)	arts. 4, 25, 26
I06	Modificar	R04, R15	Delegación con alcance y vigencia	T02, T13	M05	art. 21; Reglamento 19
I07	Modificar	R05, R18, R19, R20	Activación, Argon2id, segundo factor, bloqueo	T03, T12	M01, M02	art. 37; NIST 800-63B-4
I08	Modificar	R06	RBAC, relación asistencial, autorización por objeto	T04	M03, M14	Reglamento 60
I09	Modificar	R03, R20	Mensajes neutrales; tokens de un solo uso	T05, T12	M06	art. 10 g
I10	Conservar	R07	Autenticación entre servicios; PENDIENTE; circuito abierto	T07	M08	arts. 34, 35
I11	Modificar	R08, R22	Solo adición; hash encadenado; sin secretos	T06, T11b	M07, M14	art. 37
I12	Modificar	R09, R21	Separación, redundancia, respaldos	T08, T09	M13	art. 37
I13	Modificar	R10	Despliegue gradual; SLO	T08	M13	art. 37
I14	Modificar	R11	Plazos; sin entrega para IA; contratos	T10, T11	M12	art. 10 i; SPDP 0009-R

I03, I04 e I05 se eliminan: sus riesgos (R01 y R02) se verifican con la prueba T01, que comprueba que esos datos no existen en el esquema. Los requisitos nuevos N01 a N10 se trazan en la sección 1.1 y en las secciones 10 y 12.

C.2 Del riesgo al control, la prueba y el módulo

Riesgo	Requisitos	Nivel inicial	Control preventivo principal	Prueba	Módulo	Nivel residual
R01	I03, I05	20 Crítico	No recolectar: esquema sin esos campos y revisión de formularios.	T01	Esquema (M04, M12)	2 Bajo
R02	I04	20 Crítico	Separar agenda y sistema clínico; la agenda no almacena datos de salud.	T01	Esquema (M04)	3 Bajo
R03	I09	16 Alto	Mensajes neutrales; enlace sin datos que exige iniciar sesión; token de un solo uso y con caducidad.	T05	M06	4 Bajo
R04	I06	16 Alto	Delegación autenticada con alcance, vigencia y revocación; verificación documental de tutelas.	T02	M05	6 Medio
R05	I07	20 Crítico	Activación con secreto de un solo uso; clave propia con verificación de claves filtradas; Argon2id; bloqueo progresivo; segundo factor (TOTP o passkey) para funcionarios.	T03	M01, M02	6 Medio
R06	I08	20 Crítico	RBAC más relación asistencial; denegar por defecto; enmascaramiento; segundo factor.	T04	M03, M14	8 Medio
R07	I10	12 Alto	TLS con validación de certificado, autenticación entre servicios, lista blanca, tiempos de espera, circuito abierto e idempotencia.	T07	M08	6 Medio
R08	I11	20 Crítico	Lista blanca de campos, redacción de secretos y registros estructurados; acceso restringido.	T06	M07	4 Bajo
R09	I12	16 Alto	Aplicación y base de datos separadas, redundancia y respaldos externos inmutables.	T08	M13	6 Medio
R10	I13	15 Alto	Despliegues graduales sin interrupción; ventana mensual excepcional y anunciada.	T08	M13	4 Bajo
R11	I14	20 Crítico	Eliminar la entrega; contrato con cláusulas; plazos de conservación; anonimización autorizada para estadísticas.	T10, T11	M12	4 Bajo
R12	I01	12 Alto	RT-01 a RT-04, RT-08 y RT-09: una cita activa por especialidad, tope de citas activas, anti-automatización.	T16	M04, M09	4 Bajo
R13	I01	9 Medio	Índice único parcial por franja, bloqueo de fila e idempotencia.	T07	M04	2 Bajo
R14	I01	12 Alto	Confirmación, liberación automática, bloqueo temporal proporcional y apelación humana (RT-05 a RT-07).	T17	M04	6 Medio
R15	I01, I06	16 Alto	Autorización por objeto en el servidor e identificadores no secuenciales.	T13	M03	6 Medio
R16	Transversal	15 Alto	ORM y consultas parametrizadas, autoescape, token CSRF, CSP, validación en el servidor y WAF.	T14	M10	6 Medio
R17	Transversal	16 Alto	Versiones con soporte (LTS), análisis de dependencias en CI, SBOM y plazos de parcheo.	T15	M11	6 Medio
R18	I02, I07	12 Alto	Mensajes genéricos, tiempos de respuesta constantes y límites por origen.	T03	M01, M09	4 Bajo
R19	I07	12 Alto	Sesión de 24 h y 1 h de inactividad en operaciones sensibles, cookies HttpOnly, Secure y SameSite, rotación al iniciar sesión y revocación remota.	T03	M02	6 Medio
R20	I07, I09	12 Alto	Dominios oficiales, SPF, DKIM y DMARC; no pedir claves por mensaje; segundo factor resistente a phishing para funcionarios; capacitación.	T12	M01, M02	6 Medio
R21	I01, I12	12 Alto	Límites de solicitudes, tamaño y tiempo; caché; WAF o CDN; sala de espera; autoescalado.	T09	M09	6 Medio
R22	I11	12 Alto	Solo adición, hash encadenado, copia externa y separación de funciones.	T11b	M07	3 Bajo
R23	Transversal	12 Alto	Plan de respuesta, responsables y formatos de notificación.	T12	M07, M14	6 Medio

Cada riesgo tiene al menos una prueba y un módulo; cada módulo M01 a M14 de la sección 10.2 cubre al menos un riesgo o requisito. Los módulos no aparecen como entregable hasta que se construya el prototipo.

Anexo D. Inventario de endpoints

Cada ruta del portal se registra aquí con quién puede llamarla y cómo se comprueba. Una ruta que no está en el inventario no se publica. Reglas comunes: respuestas de error genéricas, campos desconocidos rechazados, CORS cerrado, versión en la ruta, y toda ruta que cambie estado exige método distinto de GET. Los valores de este anexo son propuestas de diseño para que el IESS las apruebe y para calibrarlas con pruebas; no son obligaciones legales.

ID	Método y ruta	Función	Autenticación	Autorización y objeto	Límites y validación	Idempotencia y CSRF	Riesgos y pruebas
E01	GET /disponibilidad	Franjas libres por especialidad, establecimiento y fecha	No (sin datos personales)	No aplica	Parámetros en lista blanca; paginación; caché; 60 por minuto y por IP	Lectura: no aplica	R21, R12; T09
E02	POST /cuentas/activar	Activar la cuenta con código de un solo uso	Código (Anexo F)	El código pertenece a esa cédula	5 intentos por código; mensajes genéricos	Token CSRF	R05, R18; T03
E03	POST /sesion	Iniciar sesión (cédula y clave)	Credenciales	No aplica	Bloqueo progresivo; respuesta idéntica ante cédula inexistente; 10 por minuto y por IP	Token CSRF	R05, R18, R19; T03
E04	POST /sesion/segundo-factor	Verificar TOTP o código de recuperación	Sesión parcial	La sesión parcial es de esa cuenta	5 intentos y bloqueo	Token CSRF	R05; T03
E05	POST /sesion/cerrar	Cerrar sesión (una o todas)	Sesión	Propia	—	Token CSRF	R19; T03
E06	GET /turnos	Lista de turnos del titular o de un representado	Sesión	Propios o delegación vigente; el titular se valida en el servidor	Paginación; filtros en lista blanca	Lectura	R15, R04; T13, T02
E07	GET /turnos/{id}	Detalle de un turno	Sesión	El turno pertenece al titular o a un representado con delegación vigente; id no secuencial (UUID); 404 igual para inexistente y ajeno	Formato del id validado	Lectura	R15; T13
E08	POST /turnos	Reservar un turno (RT-01 a RT-12)	Sesión	Titular o representante con delegación; reglas de negocio en el servidor	Esquema estricto (campos desconocidos se rechazan); 10 por hora y por cuenta; cuerpo máximo 64 KB	Clave de idempotencia obligatoria; token CSRF	R12, R13; T07, T16
E09	POST /turnos/{id}/confirmar	Confirmar dentro de 24 horas	Sesión	Objeto del titular o representante	Solo desde RESERVADO	Idempotente; token CSRF	R14; T17
E10	POST /turnos/{id}/cancelar	Cancelar hasta 2 horas antes	Sesión	Objeto del titular o representante	Confirmación explícita	Idempotente; token CSRF	R14; T17
E11	POST /turnos/{id}/reprogramar	Reprogramar (máximo 2 veces)	Sesión	Objeto del titular o representante	Contador por turno	Clave de idempotencia; token CSRF	R14, R13; T17
E12	POST /turnos/{id}/apelar	Apelar una restricción por inasistencias	Sesión	Restricción del propio titular	Texto limitado y escapado	Token CSRF	R14; T17
E13	POST /delegaciones	Crear una delegación	Sesión con segundo factor reciente	Solo el titular o el tutor verificado	Máximo 5 representados por representante	Token CSRF	R04; T02
E14	DELETE /delegaciones/{id}	Revocar una delegación	Sesión	Titular o representante	—	Idempotente; token CSRF	R04; T02
E15	POST /mis-datos/solicitudes	Acceso, rectificación, eliminación u oposición	Sesión con segundo factor reciente	Solo el titular	Registro de la solicitud; respuesta en 10 y 15 días	Token CSRF	N03; T11
E16	POST /interno/turnos/{id}/asistencia	Recepción registra asistió o no asistió	Funcionario con segundo factor	Rol recepción y misma unidad	Solo adición; el cambio queda auditado	Idempotente; token CSRF	R14, R22; T04, T11b
E17	GET /interno/agenda	Agenda de la unidad	Funcionario con segundo factor	Rol y unidad; sin datos clínicos	Paginación; sin exportación masiva	Lectura	R06; T04
E18	GET /interno/afiliados/{cedula}	Consulta de contacto por recepción o soporte	Funcionario con segundo factor	Datos enmascarados; completos solo con justificación registrada	Máximo 30 consultas por hora y funcionario	Lectura; auditada	R06, R08; T04, T06
E19	GET /auditoria	Consulta de registros	Auditor o DPD con segundo factor	Solo lectura; sin secretos	Filtros; paginación	Lectura	R22; T11b
E20	GET /enlaces/{token}	Confirmación desde un aviso	Token de un solo uso	El token pertenece a un turno; no abre datos	Caduca en 24 h; invalidado tras el uso	Redirige a iniciar sesión	R03; T05

ID	Método y ruta	Función	Autenticación	Autorización y objeto	Límites y validación	Idempotencia y CSRF	Riesgos y pruebas
E21	GET /salud	Verificación de estado del servicio	Solo red interna	No aplica	Sin datos ni versiones	Lectura	R09; T08

D.1 Cobertura de OWASP API Security Top 10:2023

Riesgo de OWASP API Security Top 10:2023	Cómo se cubre	Endpoints
API1 Autorización a nivel de objeto	Comprobación del propietario o de la delegación en cada solicitud; UUID; mismo error para inexistente y ajeno	E06, E07, E09 a E14
API2 Autenticación rota	Activación, bloqueo progresivo, segundo factor, sesiones cortas, mensajes genéricos	E02 a E05
API3 Autorización a nivel de propiedad	Esquemas estrictos: el cliente no puede enviar estado, propietario ni identificadores internos	E08, E11, E13
API4 Consumo de recursos sin límite	Límites por ruta, IP y cuenta; tamaño de cuerpo; paginación; tiempos de espera	Todos
API5 Autorización a nivel de función	Las rutas /interno exigen rol, unidad y segundo factor; el afiliado nunca llega a ellas	E16 a E19
API6 Acceso sin restricción a flujos de negocio sensibles	Reglas RT-01 a RT-12: una cita por especialidad, tope de citas, confirmación y límite por cuenta	E08, E09, E11
API7 Falsificación de solicitudes del lado del servidor	El portal no recibe URL del cliente; los destinos de las integraciones son fijos y están en lista blanca	Integraciones
API8 Configuración de seguridad incorrecta	check --deploy, cabeceras, CORS cerrado, errores genéricos, sin DEBUG	Todos; T18
API9 Gestión inadecuada del inventario	Este inventario es la fuente: toda ruta nueva se agrega aquí y se revisa; sin rutas de prueba en producción	Todos
API10 Consumo inseguro de APIs	Validación de esquema y tiempos de espera hacia afiliación y agenda; estado PENDIENTE ante fallo	Integraciones; T07

Anexo E. Parámetros de seguridad

Los valores que están dispersos en el informe se reúnen aquí para que el prototipo los lea de un solo lugar de configuración y para que cada prueba compruebe un valor concreto. Los valores de este anexo son propuestas de diseño para que el IESS las apruebe y para calibrarlas con pruebas; no son obligaciones legales.

Parámetro	Valor propuesto	Por qué	Se prueba en
Longitud mínima de la clave	12 caracteres y verificación contra claves filtradas	Evita claves cortas y reutilizadas. Confirmar el mínimo exacto en NIST SP 800-63B-4	T03
Almacenamiento de la clave	Argon2id con los parámetros vigentes de la guía de OWASP	Resiste ataques de fuerza bruta sin conocer la clave	T03, T18
Código de activación	8 dígitos, válido 15 minutos, un solo uso, 5 intentos	Limita el adivinado y la reutilización	T03, CA-04
Inicio de sesión	5 fallos seguidos por cuenta: espera de 1, 5, 15 y 60 minutos; 10 intentos por minuto y por IP	Frena la fuerza bruta sin bloquear de forma permanente	T03
Segundo factor	TOTP de 30 s con tolerancia de un paso; 10 códigos de recuperación de un solo uso	Resiste el cambio de SIM	T03
Sesión	24 horas en total y 1 hora de inactividad en operaciones sensibles; hasta 3 dispositivos	Guía de NIST SP 800-63B-4 (secciones 5.5 y 9)	T03, CA-11
Cookie de sesión	HttpOnly, Secure, SameSite Lax y prefijo __Host-	Reduce el robo y el CSRF	T18
Token de enlace	128 bits aleatorios, caduca en 24 horas, un solo uso	No adivinable; el reenvío deja de servir	T05, CA-06
Reserva	Hasta 30 días de anticipación; confirmar en 24 horas; cancelar hasta 2 horas antes; reprogramar 2 veces	RT-05 y RT-07	T17
Topes de citas	1 activa por especialidad; 3 activas en total; 5 representados por representante	RT-01, RT-02 y RT-08	T16
Inasistencias	Aviso a la primera; bloqueo de 14 días tras 2 consecutivas; justificar en 72 horas; apelar en 5 días hábiles	Política de la sección 3.5	T17
Límites de solicitudes	Disponibilidad 60 por minuto y por IP; reservas 10 por hora y por cuenta; API 120 por minuto y por cuenta	Frena bots y consumo excesivo	T09, T16
Tamaños y tiempos	Cuerpo máximo 64 KB; tiempo de solicitud 10 s	Evita agotamiento de recursos (CVE-2026-33034)	T09
Integraciones	Tiempo de espera 3 s; 2 reintentos con espera creciente; circuito abierto tras 5 fallos en 30 s; caché de afiliación 15 minutos	R07 y RT-10	T07
Auditoría	SHA-256 encadenado; verificación diaria; 12 meses en línea	R22	T11b
Respaldos	Diario con recuperación a un punto en el tiempo; RPO 5 min; RTO 30 min; restauración trimestral	R09	T08
Parcheo	72 horas, 7 días y 30 días según severidad	Sección 5.6	T15

Anexo F. Recuperación de cuenta y activación

El restablecimiento de claves es una de las rutas que más se explotan, porque suele saltarse los controles del inicio de sesión. Este anexo define cada flujo y lo que se prohíbe, y se verifica con los casos de abuso CA-04 a CA-06 y CA-16 (Anexo G).

Escenario	Flujo seguro	Qué no se hace
Activación de la cuenta	La cédula se valida con el servicio de afiliación. El código de activación se envía a un contacto que el IESS ya tiene registrado, o se entrega en ventanilla. La cuenta se activa una sola vez.	Aceptar el correo que escribe quien se registra: otra persona con la cédula podría activar la cuenta primero («pre-secuestro»).
Olvidó la clave	Enlace al contacto registrado con token de 128 bits, 15 minutos y un solo uso. El enlace se arma con el dominio fijo de la configuración. Al terminar se cierran todas las sesiones y se avisa al titular.	Revelar si la cédula existe; construir el enlace con la cabecera Host; enviar la clave nueva por mensaje.
Perdió el segundo factor	Códigos de recuperación guardados por la persona; si no los tiene, verificación presencial con documento en ventanilla.	Recuperar el segundo factor solo con un correo o un SMS.
Cambio de correo o teléfono	Exige clave y segundo factor, confirma en el contacto nuevo, avisa al anterior y aplica 24 horas de espera para operaciones sensibles.	Cambiar el contacto con solo una sesión abierta.
Solicitud al soporte	El soporte no restablece claves ni cambia contactos por sí mismo: inicia el flujo y la identidad se verifica en ventanilla.	Resolver por teléfono con datos que conocen terceros (cédula, fecha de nacimiento).
Sospecha de toma de cuenta	El afiliado o un funcionario revoca las sesiones; se exige restablecer la clave y el segundo factor; se registra el incidente (N04).	Dejar sesiones abiertas mientras se investiga.

Reglas técnicas comunes

- Los tokens se generan con un generador criptográfico, se guardan solo como hash y se comparan en tiempo constante.
- El mensaje y el tiempo de respuesta son iguales exista o no la cédula (CWE-204, CWE-640).
- Los enlaces se arman con un dominio fijo de la configuración y ALLOWED_HOSTS limita las cabeceras Host aceptadas (comparar con CVE-2026-48710).
- Un enlace no se registra completo en los registros, y la página de destino no envía el token a terceros por la cabecera Referer.
- El restablecimiento y la activación tienen límites por cédula, por IP y por dispositivo.
- Dos solicitudes simultáneas con el mismo token no pueden consumirlo dos veces: se consume dentro de una transacción.

Pregunta abierta al cliente: ¿el IESS tiene un contacto verificado de cada afiliado? Si no lo tiene, la activación se apoya en la ventanilla. Los valores de este anexo son propuestas de diseño para que el IESS las apruebe y para calibrarlas con pruebas; no son obligaciones legales.

Anexo G. Casos de abuso

Cada caso describe lo que un atacante o un usuario descuidado intentaría y lo convierte en un criterio de aceptación comprobable. Los casos extienden las pruebas T01 a T18 (no las renumeran) y son la lista de demostraciones «antes y después» para la clase.

ID	Caso de abuso	Riesgo	Criterio de aceptación (dado, cuando, entonces)	Control
CA-01	Como atacante, quiero reservar el turno de otra persona con su cédula y fecha de nacimiento	R04	Dado un usuario sin delegación, cuando reserva a nombre de otra cédula, entonces recibe 403, no se crea el turno y el intento queda auditado.	Delegación verificada (§4.4)
CA-02	Quiero acaparar cupos con varias reservas en la misma especialidad	R12	Dado un afiliado con un turno activo en una especialidad, cuando intenta otro en la misma, entonces se rechaza con un mensaje genérico.	RT-01 e índice único
CA-03	Quiero ganar la última franja con solicitudes simultáneas	R13	Dadas dos solicitudes simultáneas por la última franja, entonces solo una crea turno y la otra recibe franja ocupada.	RT-04 y bloqueo de fila
CA-04	Quiero activar la cuenta de otra persona con mi correo (pre-secuestro)	R05, R20	Dada una cédula sin cuenta, cuando alguien registra un contacto distinto del registrado por el IESS, entonces no se activa y no se envía el código.	Anexo F
CA-05	Quiero saber qué cédulas son afiliadas	R18	Dadas una cédula inexistente y una existente con clave incorrecta, entonces la respuesta y el tiempo son indistinguibles.	Mensajes genéricos; límites
CA-06	Quiero reutilizar un enlace de restablecimiento o de aviso	R03, R19	Dado un token ya usado o vencido, cuando se presenta de nuevo, entonces se rechaza y no abre datos.	Tokens de un solo uso
CA-07	Quiero leer el turno de otra persona cambiando el identificador	R15	Dado un usuario autenticado, cuando pide el turno de otro, entonces recibe la misma respuesta que para un turno inexistente.	Autorización por objeto
CA-08	Quiero inyectar SQL o scripts en login, búsqueda y apelaciones	R16	Dadas cargas de inyección, entonces fallan sin error técnico visible y sin cambiar datos.	ORM, escape, CSP
CA-09	Soy de recepción y quiero ver pacientes de otra unidad	R06	Dado un funcionario de la unidad A, cuando consulta una cédula atendida solo en la unidad B, entonces recibe denegación y queda auditado.	RBAC y unidad
CA-10	Soy supervisor y quiero editar un registro de auditoría	R22	Dado un intento de modificar o borrar un registro, entonces la base lo rechaza y la verificación de la cadena detecta cualquier alteración.	Solo adición y hash
CA-11	Quiero usar una cookie robada pasadas 24 horas	R19	Dada una sesión vencida o revocada, cuando se usa, entonces se rechaza.	Sesiones cortas
CA-12	Quiero automatizar reservas con un bot	R12, R21	Dadas 100 reservas por minuto desde una IP, entonces se aplican límites y desafío adaptativo sin bloquear a los usuarios legítimos.	RT-09
CA-13	Hago doble clic o reintento una reserva	R13	Dada la misma clave de idempotencia, entonces se crea un solo turno y la segunda respuesta es igual a la primera.	Idempotencia
CA-14	Un afiliado queda bloqueado sin poder reclamar	R14	Dada una restricción, entonces el afiliado ve la causa y la fecha, puede apelar ante una persona y mantiene el canal presencial.	§3.5 y LOPDP art. 20
CA-15	El servicio de afiliación falla y quiero que se confirme una cobertura falsa	R07	Dado un tiempo de espera del tercero, entonces el turno queda PENDIENTE y nunca se afirma cobertura.	RT-10; circuito abierto
CA-16	Quiero envenenar un enlace de restablecimiento con una cabecera Host falsa	R17, R20	Dada una solicitud con Host distinto de los permitidos, entonces se rechaza y los enlaces siguen usando el dominio configurado.	ALLOWED_HOSTS; dominio fijo

Anexo H. Ciclo de desarrollo seguro

La seguridad no se agrega al final: cada fase produce evidencia y una puerta que impide avanzar con un riesgo sin controlar. El marco de referencia es el Secure Software Development Framework del NIST (SP 800-218, versión 1.1, febrero de 2022), que reúne prácticas para integrar la seguridad en cada fase del ciclo de desarrollo.

Fase	Actividades de seguridad	Evidencia	Puerta para avanzar
Requisitos	Requisitos de seguridad y casos de abuso; evaluación de impacto (Anexo B)	Secciones 1 y 2; Anexos B y G	Cada requisito tiene riesgo, control y prueba (Anexo C)
Diseño	Modelado de amenazas (Anexo A); inventario de endpoints (Anexo D); parámetros (Anexo E)	Figuras 3 y 4; matriz de riesgos	Sin riesgo crítico sin control definido
Desarrollo	Estándar de código (sección 5.5); revisión de código con lista de verificación; sin secretos en el repositorio	Solicitudes de cambio revisadas	Una persona distinta del autor aprueba cada cambio
Integración continua	Pruebas, análisis estático (Bandit), análisis de dependencias (pip-audit), SBOM, detección de secretos (gitleaks)	Informes de cada ejecución	Sin hallazgos críticos o altos abiertos
Pruebas	Casos de abuso, pruebas negativas, concurrencia y carga; análisis dinámico (ZAP)	Informes con fecha y versión	Todas las pruebas T01 a T18 y CA-01 a CA-16 aprobadas
Entrega	check --deploy; cabeceras; configuración revisada; respaldo y restauración probados	Lista de la sección 5.5	Sin advertencias; restauración dentro de RPO y RTO
Operación	Monitoreo y reglas de detección (Anexo I); parcheo por severidad; simulacros	Registros y tickets	Plazos de parcheo cumplidos
Retiro	Eliminación de datos y de claves; entrega del certificado de eliminación	Constancia de eliminación	Cumple el plazo de conservación

Lista de verificación para la revisión de código

1. ¿Cada ruta nueva está en el inventario del Anexo D y comprueba autorización por objeto?
2. ¿Ninguna consulta se arma con texto del usuario (sin SQL crudo ni **request.GET en filtros)?
3. ¿Los formularios declaran campos explícitos (sin fields = '__all__')?
4. ¿Ninguna plantilla marca contenido del usuario como seguro?
5. ¿Las operaciones que cambian estado usan POST, token CSRF y, si corresponde, clave de idempotencia?
6. ¿Los mensajes de error y de login son genéricos y no revelan la existencia de cédulas?
7. ¿Los registros omiten contraseñas, tokens y datos clínicos?
8. ¿Los secretos vienen de la configuración y no del código?
9. ¿Cada regla de turnos tiene su restricción en la base de datos y una prueba concurrente?
10. ¿La dependencia nueva tiene soporte vigente y no tiene CVE críticos abiertos?

Flujo de trabajo con Git para el prototipo

- Rama principal protegida: solo se integra con una solicitud de cambio revisada y con la integración continua en verde.
- Los commits explican el control o el riesgo que cubren (por ejemplo, «R15: autorización por objeto en turnos»), lo que alimenta la trazabilidad del Anexo C.
- Las versiones inseguras que sirven para el «antes y después» de la clase viven en una rama de laboratorio aparte y nunca se integran a la principal.

Anexo I. Reglas de detección y respuesta

Estas reglas son los controles detectivos de la matriz expresados como condiciones que el sistema puede evaluar. Un registro o una alerta no impiden un ataque: ayudan a detectarlo y a responder. Por eso cada regla se acompaña de una acción y de los controles preventivos que la sustentan. Los valores de este anexo son propuestas de diseño para que el IESS las apruebe y para calibrarlas con pruebas; no son obligaciones legales.

ID	Regla de detección	Condición y umbral propuesto	Acción	Riesgos
D01	Fallos de inicio de sesión desde una IP	50 o más fallos en 10 minutos desde una misma IP	Alerta alta y bloqueo temporal del origen	R05, R18
D02	Relleno de credenciales distribuido	Fallos en 200 o más cuentas distintas en 10 minutos	Alerta alta; activar desafío adaptativo	R05
D03	Una cuenta atacada desde muchas IP	10 o más fallos en 10 minutos desde 5 o más IP	Alerta; avisar al titular y exigir restablecer la clave	R05
D04	Enumeración de cédulas	30 o más cédulas distintas consultadas desde una IP en 10 minutos	Alerta; bloqueo temporal	R18
D05	Inicio de sesión desde un dispositivo nuevo	Primer inicio desde un dispositivo no registrado	Aviso informativo al titular	R19, R20
D06	Acaparamiento de turnos	Más de 10 intentos de reserva en una hora por cuenta, o 5 o más cuentas distintas reservando desde una IP	Alerta; limitar y revisar	R12
D07	Sondeo de identificadores	20 o más respuestas 403 o 404 en 5 minutos por usuario	Alerta; revisar la cuenta	R15
D08	Consulta masiva por un funcionario	Más de 100 fichas distintas en una hora, o consultas fuera de horario	Alerta alta al responsable	R06
D09	Exportaciones	Cualquier exportación; una sin doble aprobación	Aviso; alerta crítica si no está aprobada	R05, R06
D10	Acceso excepcional	Uso del acceso de emergencia	Alerta inmediata al responsable y revisión posterior	R06
D11	Integridad de la auditoría	La verificación diaria de la cadena de hashes falla	Alerta crítica; abrir incidente	R22
D12	Errores del servidor	Más del 2 % de respuestas 5xx en 5 minutos	Alerta de disponibilidad	R21, R09
D13	Latencia y colas	Latencia p95 mayor de 2 s durante 5 minutos	Alerta; activar sala de espera	R21
D14	Fallos de terceros	5 fallos en 30 segundos al servicio de afiliación o de agenda	Circuito abierto, estado PENDIENTE y alerta	R07
D15	Respaldos	Copia fallida, o sin restauración probada en 90 días	Alerta; corregir antes del siguiente ciclo	R09
D16	Vulnerabilidades nuevas	CVE crítico o del catálogo KEV en una dependencia	Ticket con plazo de 72 horas	R17
D17	Token usado desde dos orígenes	Mismo token presentado desde IP o dispositivos distintos	Invalidar el token y alertar	R03
D18	Cambios de privilegios	Alta de un funcionario o cambio de rol	Aviso al responsable de seguridad	R06

I.1 Severidad y respuesta

Severidad	Quién responde	Tiempo objetivo
Crítica	Responsable de seguridad y DPD	Inmediato; evaluar la notificación a la SPDP, a la ARCOTEL y a los titulares (N04)
Alta	Equipo de seguridad	Dentro de 1 hora
Media	Equipo de operaciones	Dentro de 1 día hábil
Informativa	Se registra para revisión	Revisión periódica

Anexo J. Gestión de claves y secretos

Una clave filtrada anula los demás controles. Este inventario dice qué secretos existen, dónde viven, cuándo se cambian y qué se hace si se filtran. Los valores de este anexo son propuestas de diseño para que el IESS las apruebe y para calibrarlas con pruebas; no son obligaciones legales.

Secreto o clave	Uso	Dónde se guarda	Rotación	Si se filtra
SECRET_KEY de Django	Firma de sesiones, tokens y mensajes	Variable de entorno o gestor de secretos; nunca en el repositorio	Cada 90 días y ante sospecha; se rota con claves de respaldo para no invalidar todas las sesiones de golpe	Rotar de inmediato, cerrar sesiones y revisar la auditoría
Contraseña de la base de datos de la aplicación	Conexión con permisos mínimos (sin crear ni borrar tablas)	Gestor de secretos	Cada 90 días	Rotar, revisar accesos y notificar si hubo lectura de datos
Usuario de migraciones	Cambios de esquema	Gestor de secretos; solo en el despliegue	En cada cambio mayor	Rotar y revisar el esquema
Usuario de solo lectura de auditoría	Lectura de los registros	Gestor de secretos	Cada 90 días	Rotar
Credencial o certificado hacia afiliación y agenda	Autenticación entre servicios	Gestor de secretos o almacén de certificados	Según la política del tercero; certificados antes de vencer	Revocar en el tercero y rotar
Secreto TOTP de cada usuario	Segundo factor	Cifrado en la base con una clave de aplicación	Al restablecer el factor	Restablecer el factor de los afectados
Clave del hash encadenado de la auditoría	Integridad del registro	Sistema separado del de la aplicación	Con versión de clave en cada registro	Reverificar la cadena y abrir incidente
Clave de cifrado de respaldos	Confidencialidad de las copias	Gestor de claves, separada de las copias	Anual y ante sospecha	Recifrar las copias y rotar
Certificado TLS	Cifrado en tránsito	Almacén del proxy	Antes de su vencimiento	Revocar y emitir uno nuevo
Credenciales del proveedor de mensajería	Envío de avisos	Gestor de secretos	Cada 90 días	Rotar y revisar los envíos

Reglas

- Ningún secreto va en el código, en el repositorio, en imágenes de contenedor ni en los registros. El repositorio solo incluye un archivo de ejemplo sin valores.
- Cada entorno (desarrollo, pruebas, producción) usa secretos distintos.
- Un secreto filtrado se revoca primero y recién después se limpia el historial; limpiar el historial no devuelve la confidencialidad.
- Se rota también cuando una persona deja el equipo.
- Django permite rotar la SECRET_KEY con claves de respaldo (SECRET_KEY_FALLBACKS); se verifica en la documentación de la versión elegida.
- El prototipo local usa variables de entorno fuera del repositorio y un certificado de desarrollo para TLS; la gestión de claves de producción se documenta y se simula.

Pregunta abierta al cliente: ¿el IESS dispone de un gestor de secretos o de un módulo de seguridad de hardware?